

Modul 11 — IT-Security (INA)

Studiengang: DHBW Ravensburg · WDS224 · Data Science & Künstliche Intelligenz **Modul:** W4DSKI_207 — *IT-Recht und IT-Sicherheit* · **Informatik-Teil (35 UE)** **Dozent:** Prof. Dr. Aykan Inan
Schwestermodul: → 10_IT-Recht.md (juristischer Teil, Dr. Florian Deusch, 25 UE) **Quelle:** ZIP WDS224 - IT-Security (INA).zip, Ordner *Prüfungsrelevante Folien* — 13 PDFs, 587 Folienseiten **Stand der Folien:** 25.05.2025 (Krypto-Kapitel), 10.10.2025 (Kap. 02 Einführung, TOR), 23.01.2026 (GRC, Incident Response)

0. Wie dieses Dokument zu lesen ist

Der Dozent hat den Ordner explizit „**Prüfungsrelevante Folien**“ genannt. Das heißt: **Alles, was in diesem Dokument steht, ist per Definition Klausurstoff**. Es gibt in diesem Modul keinen „Beiwerk-Teil“, den man weglassen könnte — die 13 PDFs *sind* bereits die gefilterte Auswahl aus einer deutlich größeren Vorlesung.

Legende:

Symbol	Bedeutung
★	Hochgradig prüfungsrelevant — Definition/Formel, die man wörtlich können muss
⚠	Klassische Falle / häufige Verwechslung
📝	Durchgerechnetes Beispiel
🔑	Merksatz des Dozenten (wörtlich aus den Folien)
?	Rhetorische Frage, die der Dozent stellt — genau so kommt sie oft in der Klausur

Struktur der Folien: Prof. Inan arbeitet mit LaTeX-Beamer und benutzt durchgängig Kästen mit den Überschriften **Merke**, **Hinweis**, **Achtung**, **Wichtig**, **Idee**, **Erinnerung**, **Problem**, **Strategie**. Diese Kästen sind die verdichteten Kernaussagen — in diesem Dokument sind sie als Blockquotes mit 🔑 wiedergegeben. Wenn eine Klausurfrage nach einer *Definition* fragt, ist die Antwort fast immer wörtlich einer dieser Kästen.

0.1 Inhaltsübersicht der 13 Kapitel

#	Datei	Folie n	Thema	Gewicht
1	Kapitel_02_1_Einführung_Exam	160	Cyber-Sicherheit, Schutzziele, Angriffsmodelle	sehr hoch
2	Kapitel_02_3_GRC_Exam	155	Governance, Risk, Compliance, PDCA/SDCA	sehr hoch
3	Kapitel_02_4_Incidence_Response_Exam	132	Incident Response, Pyramid of Pain, MITRE ATT&CK	sehr hoch
4	Kapitel_03_Grundlagen_Krypto_Exam	88	Kryptologie-Begriffe, Kerckhoffs	mittel
5	Kapitel_04_Klassische_Chiffren_Exam	116	Algebra (Gruppe/Ring/Körper), Verschiebe-/Multiplikativ-/Affine/Vigenère-Chiffre	hoch
6	Kapitel_05_Stromchiffren_Exam	133	XOR-Prinzip, OTP, Zufallszahlengeneratoren, Trivium	hoch
7	Kapitel_06_DES_Exam	137	Konfusion/Diffusion, Feistel, f-Funktion, Schlüsselfahrplan	sehr hoch
8	Kapitel_07_AES_Exam	154	3-Schichten-Aufbau, S-Box-Herleitung, MixColumn	sehr hoch
9	Kapitel_08_Betriebsmodis_Exam	83	ECB, CBC, OFB, CFB, CTR, GCM	sehr hoch
10	Kapitel_10_DHKE_Exam	75	Diffie-Hellman, DLP	hoch
11	Kapitel_11_RSA_Exam	45	Schlüsselerzeugung, Faktorisierungsproblem	hoch
12	Kapitel_13_Hashing_Exam	100	6 Eigenschaften, Kollisionsresistenz, Geburtstagsparadoxon	sehr hoch
13	TOR_Exam	180	Onion Routing, Circuit-Aufbau, Guard Node	hoch

Beobachtung: Kapitel 09 (vermutlich Asymmetrische Verfahren allgemein) und Kapitel 12 (vermutlich Digitale Signaturen) fehlen im Ordner. Die Lücken sind gewollt — beides wird in Kap. 10/11 (DHKE, RSA) bzw. Kap. 13 (Hashing) mit abgehandelt.

TEIL A — CYBER-SICHERHEIT (Kapitel 02)

1. Warum überhaupt IT-Sicherheit?

1.1 Die Ausgangslage

Digitalisierung und ihre Auswirkungen:

- IT durchdringt **alle** gesellschaftlichen und wirtschaftlichen Bereiche
- Digitalisierung führt zur Transformation von der **Industrie- zur Informationsgesellschaft**
- Breitbandige Vernetzung schafft neue **Chancen und Risiken**

Wirtschaftlicher Wert von Information:

- Information ist einer der **wichtigsten Wirtschaftsfaktoren**
- Unternehmens-Know-how liegt **meist in elektronischer Form** vor
- Klassischer Schutz (z. B. physische Zugangskontrolle) **reicht nicht mehr aus**

Gefahren elektronisch gespeicherter Informationen:

- Informationsübertragung über Netzwerke ermöglicht **globale** Angriffe
- IT schafft neue Möglichkeiten, birgt aber auch neue Risiken
- Schutz elektronischer Daten ist entscheidend für die Unternehmenssicherheit

Private Risiken:

- Persönliche Daten sind für Dritte interessant (Werbung, Betrug)
- Gefahr durch Diebstahl von Bankdaten oder Smart-Home-Zugriff
- IT-Sicherheit schützt **auch im privaten Umfeld**

1.2 Der historische Fehler

🔑 Zu Beginn des Internets war „Cybersecurity“ **kein zentrales Thema**. Der Fokus lag auf **Innovation**: Kommunikation, Effizienz, globale Vernetzung. Sicherheitsaspekte wurden häufig vernachlässigt — **Vertrauen statt Absicherung**. Diese Lücke nutzten erste Angreifer gezielt aus, und das oft mit einfachen Mitteln.

★ **Das ist eine typische Einstiegsfrage:** „Warum ist das Internet strukturell unsicher?“ → Antwort: Weil es als Vertrauensnetz unter Forschern konzipiert wurde, nicht als Feindnetz. Sicherheit wurde nachträglich aufgesetzt.

2. Cyber-Raum, Cyber-Sicherheit, IT-Sicherheit, Informationssicherheit

2.1 Der Cyber-Raum ★

🔑 **Merke — Cyber-Raum:** Der Cyber-Raum umfasst **sämtliche mit dem Internet verbundene IT-Systeme und IT-Infrastrukturen**. Dazu zählt auch die dort angewendete Kommunikation, Anwendungen und alle Prozesse mit Daten und Informationen. Insgesamt ist es ein **globales und komplexes System** mit vielen Abhängigkeiten auf unterschiedlichen Ebenen und vielen involvierten Akteuren.

Technische Charakterisierung:

- Dynamischer **Verbund vieler Netzwerke**, in dem Daten in **IP-Paketen** transportiert werden
- Das Internet-Protokoll kann auf verschiedenen **physikalischen Basis-Infrastrukturen** betrieben werden:
 - Ethernet
 - WLAN
 - Satellit
- **Dezentrale Struktur** mit selbstorganisierten Netzen → **Autonome Systeme (AS)**

2.2 Das Gewaltmonopol-Problem ★ ⚠

🔑 Eine **Besonderheit des Cyber-Raums** ist, dass die Staaten hier ihr **Gewaltmonopol nicht vollständig ausüben** können und sich hier ein erfolgreiches **Ökosystem für kriminelle Organisationen** etabliert hat.

Warum globale Strafverfolgung nicht funktioniert:

1. Nicht alle Staaten arbeiten zusammen / kooperieren international
2. Angreifer greifen Länder **aus anderen Ländern** an, die nicht kooperieren
3. **Attributionsproblem**: Schwierigkeit, einen Cyber-Angriff eindeutig zuzuordnen

⚠ Das ist ein beliebter Brückenschlag zum IT-Recht-Teil des Moduls: Der Grund, warum die EU mit NIS2, CRA und KI-VO **regulatorisch** statt strafrechtlich vorgeht, ist genau dieses Vollzugsdefizit.

2.3 IT-Sicherheit — Definition ★

🔑 **IT-Sicherheit** umfasst **alle Maßnahmen zum Schutz von IT-Systemen, Daten und Netzwerken** vor unbefugtem Zugriff, Manipulation, Verlust oder Störungen. Sie verfolgt das Ziel, die **Sicherheit und Funktionsfähigkeit** dieser Systeme aufrechtzuerhalten.

Konkrete Ziele der IT-Sicherheit (Folie 37/38):

- Schutz von Daten, Anwendungen und Netzwerken
- Schutz vor unbefugtem Zugriff und Manipulation von Informationen
- Verhindern von Datenverlust, -unterbrechung und unbefugtem Zugriff
- Sicherstellung der **Verfügbarkeit und Integrität** von IT-Diensten
- Maßnahmen zur **Prävention, Entdeckung und Protokollierung** von Bedrohungen
- Absicherung der **Kommunikationskanäle** zwischen Systemen und Anwendungen
- Absicherung des **Netzwerks**, das für den Datenaustausch genutzt wird
- Vorbeugung gegen unbeabsichtigte Löschung oder Unterbrechung von Daten
- Abwehr von unerlaubten Zugriffen und Eingriffen durch Dritte

Anwendungsfelder: klassische IT-Systeme, **Industrie 4.0, Internet of Things (IoT)** — betrifft Unternehmen wie Privatpersonen (Sabotage, Angriffe, Manipulation).

🔑 **Wichtig**: Ziel ist die **Reduzierung der vorhandenen Risiken auf ein angemessenes Maß** in Bezug auf den Cyber-Raum.

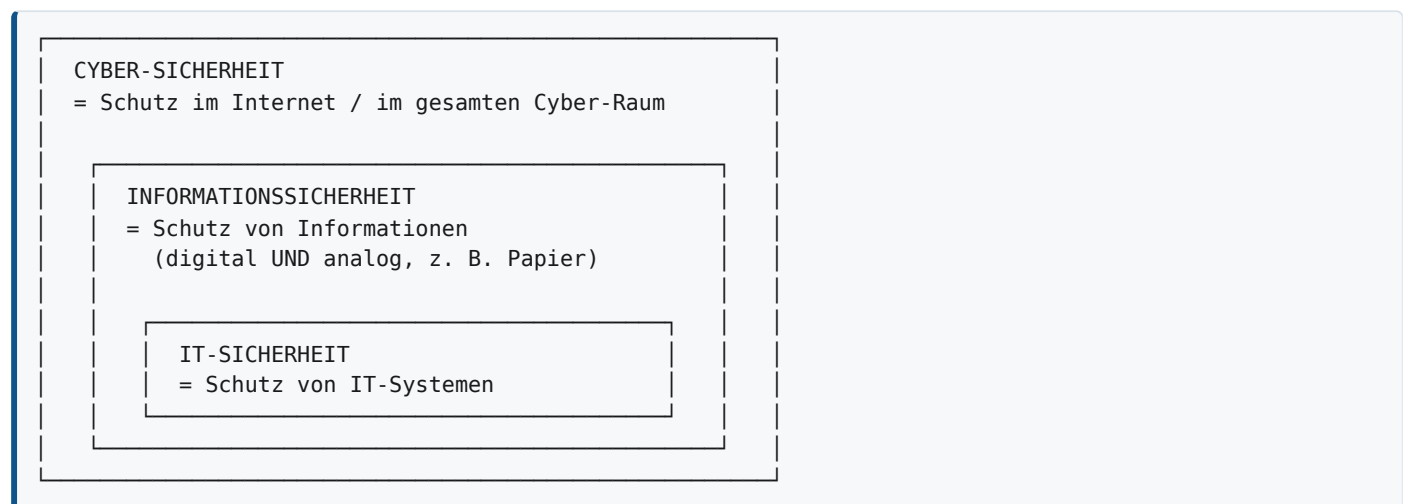
⚠ **Falle**: Das Ziel ist *niemals* „hundertprozentige Sicherheit“. Wer in der Klausur „absolute Sicherheit“ schreibt, hat die Kernbotschaft des Moduls verfehlt. Es geht immer um **Risikoreduktion auf ein angemessenes Maß** — genau die Formulierung, die auch im Risikomanagement (ALARP) und in § 30 BSIG (Stand der Technik, angemessene Maßnahmen) wiederkehrt.

2.4 Informationssicherheit — Definition ★

🔑 Die **Informationssicherheit** verfolgt das Ziel, **Informationen selbst** zu schützen. Damit sind **nicht nur digitale** Informationen auf IT-Systemen gemeint, **sondern auch analoge auf Papier**, wobei die IT-Sicherheit selbst wieder Teil der Informationssicherheit ist.

2.5 Das Zusammenspiel der drei Begriffe ★★☆☆

Dies ist **die** klassische Klausurfrage des ersten Kapitels.



Begriff	Schutzobjekt (Folie 63, wörtlich)
Informationssicherheit	Schutz von Informationen
IT-Sicherheit	Schutz von IT-Systemen
Cyber-Sicherheit	Schutz im Internet

🔑 Die Cyber-Sicherheit ist ein **übergreifender Begriff** für die Sicherheit im Cyber-Raum, wobei die IT-Sicherheit ein **Teil** der Cyber-Sicherheit ist.

⚠️ **Doppelbotschaft der Folien beachten!** Prof. Inan sagt an *zwei* Stellen scheinbar Widersprüchliches:

- Folie 40: „**IT-Sicherheit = Cybersicherheit**“ — Cybersicherheit wird *häufig synonym* verwendet, um die besondere Relevanz zu betonen.
- Folie 62/63: Cyber-Sicherheit $\supset$ Informationssicherheit $\supset$ IT-Sicherheit.

Auflösung für die Klausur: *Umgangssprachlich/werblich* werden die Begriffe synonym verwendet; *fachlich korrekt* ist die Schachtelung. Wenn nach dem „Zusammenhang“ gefragt wird, immer die Schachtelung zeichnen und den synonymen Sprachgebrauch als Randnotiz erwähnen.

3. Die Schutzziele: 3 Hauptziele + 5 Nebenziele ★★☆☆

Das ist **die** meistgeprüfte Aufzählung des gesamten Moduls.

3.1 Übersicht

#	Ziel	Kategorie
1	Vertraulichkeit (Confidentiality)	Hauptziel
2	Integrität (Integrity)	Hauptziel
3	Verfügbarkeit (Availability)	Hauptziel
4	Authentizität und Authentifikation (syn. Authentifizierung)	Nebenziel
5	Autorisation	Nebenziel
6	Verbindlichkeit (Nichtabstreitbarkeit)	Nebenziel
7	Maßnahmen zur Verhinderung, Entdeckung oder Protokollierung von Bedrohungen	Nebenziel
8	Anonymisierung / Pseudonymisierung	Nebenziel

Merkhilfe: Die drei Hauptziele sind die **CIA-Triade** (Confidentiality, Integrity, Availability). Die fünf Nebenziele bauen darauf auf: *Wer bist du?* (4) — *Was darfst du?* (5) — *Kannst du es leugnen?* (6) — *Merken wir es?* (7) — *Bleibst du unerkannt?* (8).

3.2 Die Ziele im Detail ★

(1) Vertraulichkeit (Geheimhaltung)

- Schutz von Information und Informationssystemen gegen **unbefugte Zugriffe**
- Nur **autorisierte** Benutzer bekommen Zugang zu der Information
- Übertragene oder gespeicherte Informationen sollen **nicht im Klartext** zu lesen sein
- **Mechanismen:** Verschlüsselung, **Steganografie**

(2) Integrität

- Schutz von Information gegenüber **Veränderung/Manipulation durch Unbefugte**
- Überprüfung, ob Informationen, die übertragen werden oder gespeichert sind, **unverändert** geblieben sind → Überprüfung der **Unversehrtheit**
- **Mechanismen:** Hash-Funktionen, **MACs**, digitale Signaturen, Checksummen

(3) Verfügbarkeit

- Gewährleistung, dass die **Ressourcen und Dienste** (elektronisches System) **legitimen Benutzern tatsächlich zur Verfügung stehen**
- z. B. Server oder Dateien
- (Gegenspieler: DoS/DDoS, Ransomware, Ausfälle)

(4) Authentizität und Authentifikation

- **Eindeutige Identifikation** eines Kommunikationspartners
- Verifizierung, dass **Informationen oder Identitäten echt** sind
- *Welcher Nutzer greift auf Betriebsmittel und Informationen zu?*
- **Mechanismen:** digitale Signaturen, Blockchain-Technologie, **MFA**, biometrische Verfahren

(5) Autorisation

- **Beschränkung des Zugriffs** auf eine Ressource auf **bestimmte (authentifizierte)** Benutzer
- **Mechanismen:** **ACLs** (Access Control Lists), MFA, **OAuth**

! Authentifizierung vs. Autorisierung — die Standardfalle ★

🔑 Auch wenn die Begriffe ähnlich klingen, handelt es sich bei Authentifizierung und Autorisierung um **verschiedene Schritte im Anmeldeprozess**.

	Frage	Definition der Folie (wörtlich)
Authentifizierung	<i>Wer bist du?</i>	Überprüfung, ob der Benutzer auch der ist, der er vorgibt zu sein
Autorisierung	<i>Was darfst du?</i>	Erteilung einer Erlaubnis/Befugnis an den Benutzer

Reihenfolge: Erst Authentifizierung, **dann** Autorisierung. Ohne festgestellte Identität kann man keine Rechte zuweisen.

(6) Verbindlichkeit (Nichtabstreitbarkeit / Non-Repudiation)

- Der **Sender einer Nachricht kann nicht abstreiten**, dass die Nachricht von ihm stammt
- Die Möglichkeit, **Inhalt und Absender** von Information gegenüber einem an der Kommunikation **nicht beteiligten Dritten** zu beweisen
- **Mechanismen:** digitale Signaturen, **PKI**, Blockchain

! Der Zusatz „*gegenüber einem nicht beteiligten Dritten*“ ist entscheidend und unterscheidet Verbindlichkeit von bloßer Authentizität. Deshalb genügt ein **MAC nicht** für Nichtabstreitbarkeit (beide Seiten kennen den Schlüssel → jeder könnte es gewesen sein), wohl aber eine **digitale Signatur** (nur der Inhaber des privaten Schlüssels kann sie erzeugen).

(7) Maßnahmen zur Verhinderung, Entdeckung oder Protokollierung von Bedrohungen

- Prävention (Firewall, Härtung), Detektion (IDS/IPS, SIEM, EDR), Protokollierung (Logging)
- → Direkte Brücke zu **Incident Response** (Kapitel 02_4)

(8) Anonymisierung / Pseudonymisierung

- Gewährleistung, dass eine Person **nicht oder nicht unmittelbar identifiziert** werden kann
- Schutz gegen die **Offenlegung und den Missbrauch von Identitäten**
- **Mechanismen:** Datenaggregation, Datenunterdrückung, Rauschüberlagerung

! Brücke zum IT-Recht: „nicht **unmittelbar** identifiziert“ ist genau die Grenze zwischen Pseudonymisierung (Art. 4 Nr. 5 DSGVO → **weiterhin personenbezogen**) und Anonymisierung (→ **kein** Personenbezug mehr, DSGVO nicht anwendbar). Und in Kapitel 07 „Fortgeschrittene Statistik“ ist „Rauschüberlagerung“ genau das Prinzip der *Differential Privacy*.

4. Safety vs. Security ★★

4.1 Warum die Unterscheidung nötig ist

🔑 Der deutsche Begriff „**Sicherheit**“ ist **mehrdeutig** und daher für eine präzise technische Definition **ungeeignet**. Sicherheit beschreibt hier im Allgemeinen die Gewissheit oder Zuverlässigkeit, dass für eine Person oder ein Objekt keine Gefahr droht. Im Englischen verwendet man daher die Begriffe „**Security**“ und „**Safety**“.

4.2 Gegenüberstellung ★

Kriterium	Safety	Security
Deutsch	Funktionale Sicherheit	Angriffssicherheit
Kernaussage	Stellt sicher, dass ein System keine gefährlichen Zustände verursacht	Schützt das System vor absichtlichen oder zufälligen Bedrohungen
Schutzrichtung	Schützt Mensch und Umwelt VOR dem System	Schützt das System VOR externen Bedrohungen
Auslöser	Fehlfunktionen, Ausfälle	Angriffe
Mechanismen	Leichter rekonstruierbare Mechanismen, z. B. CRC-Prüfsummen	Wirksamere kryptographische Mechanismen, z. B. kryptographische Prüfsummen
Schutzniveau	geringer	höher
Charakter	statisch , auf ein bestimmtes System zugeschnitten	dynamisch , muss sich kontinuierlich an neue Bedrohungen anpassen

🔑 Die Merkformel:

Safety = Schutz der Umwelt **vor** dem System. **Security** = Schutz des Systems **vor** der Umwelt.

🔑 Security setzt oft wirksamere kryptische Mechanismen ein als Safety. Kryptographische Prüfsummen zur Integritätsprüfung schützen vor **absichtlichen und zufälligen** Manipulationen — eine CRC-Prüfsumme nur vor zufälligen.

⚠️ **Warum eine CRC keine Security bietet:** CRC ist eine **lineare** Funktion ohne Schlüssel. Ein Angreifer, der die Nachricht ändert, kann die CRC einfach neu berechnen. Eine kryptographische Prüfsumme (MAC/HMAC) erfordert den geheimen Schlüssel. Merke: **CRC schützt gegen Rauschen, MAC gegen Menschen.**

📝 **Beispiel für die Klausur:** Ein Fahrassistenzsystem bremst wegen eines Sensorfehlers grundlos → **Safety-Problem**. Ein Angreifer manipuliert den CAN-Bus, damit das Fahrzeug bremst → **Security-Problem**. Ein Security-Vorfall kann ein Safety-Problem **auslösen** — das ist der Grund, weshalb IoT/Industrie 4.0 beide Disziplinen zusammenführen muss.

5. Sicherheitslücke, Angriffsfläche, Angriffsvektor ★★

🔑 Es gibt **drei wichtige Begriffe** im Zusammenhang mit Cyber-Security: **1. Sicherheitslücke — 2. Angriffsfläche — 3. Angriffsvektor**

5.1 Sicherheitslücke ★

🔑 Eine **Sicherheitslücke** ist eine **Schwachstelle in einer Software** (Softwareschwachstelle) **oder Hardware** (Hardwareschwachstelle), die es einem Angreifer erlaubt, mithilfe speziell dafür entwickelter Software (**Exploits**), Angriffe auf ein IT-System erfolgreich umzusetzen.

Begriffskette: Schwachstelle (die Lücke) → Exploit (das Werkzeug, das sie ausnutzt) → Angriff (die Handlung).

5.2 Angriffsfläche ★

Eine Angriffsfläche ist bestimmt durch ...

1. die **Anzahl der genutzten IT-Systeme und -Dienste**
2. die **vorhandenen Cyber-Sicherheitsmaßnahmen**

🔑 Eine Angriffsfläche umfasst die „**Kombination**“ aus **einer oder mehreren vorhandenen Schwachstellen und Angriffsvektoren**, die der Angreifer für einen erfolgreichen Angriff ausnutzen kann.

Ebenen der Angriffsfläche (Folie 90):

Nutzer
Netzwerk
IT-System
Betriebssystem
Anwendung(en)
Daten

🔑 **Erinnerung:** Je **größer** die Angriffsfläche ist, desto **höher** ist die Wahrscheinlichkeit, dass ein erfolgreicher Angriff durchgeführt werden kann.

→ Daraus folgt das Prinzip der **Angriffsflächenreduktion** (Attack Surface Reduction): Härtung, Abschalten nicht benötigter Dienste, Netzsegmentierung, Minimalprinzip.

5.3 Angriffsvektor ★

🔑 Ein **Angriffsvektor** (engl. *Attack Vector*) beschreibt die **Kombination aus einem Angriffsweg und einer Angriffstechnik**, die einen erfolgreichen Angriff auf ein IT-System oder -Dienst ermöglicht.

5.4 Die drei Begriffe im Verhältnis ⚠️

Begriff	Frage	Beispiel
Sicherheitslücke	Was ist kaputt?	Buffer Overflow in einer Bibliothek (CVE-XXXX)
Angriffsvektor	Wie kommt der Angreifer heran?	Weg (E-Mail-Anhang) + Technik (Makro-Ausführung)
Angriffsfläche	Wie viel Oberfläche bietet das System insgesamt?	Summe aller Lücken × aller Vektoren

⚠️ **Häufigster Fehler:** Angriffsvektor und Angriffsfläche verwechseln. Der **Vektor** ist ein **einzelner Pfad**; die **Fläche** ist die **Gesamtheit** aus Schwachstellen und Vektoren.

5.5 Das schwächste Glied

🔑 Ein Angreifer versucht meist, **mehrere Schwachstellen** auszunutzen, um in IT-Systeme einzudringen. Je mehr potenzielle Angriffsvektoren existieren, desto höher ist die Wahrscheinlichkeit eines erfolgreichen Angriffs. Dabei gilt es immer **das schwächste Glied in der Kette** zu finden, welches die grundlegende Ursache für erfolgreiche Angriffe auf IT-Systeme bildet.

6. Malware und die Web-Schichten

6.1 Malware ★

🔑 Der Begriff „**Malware**“ ist ein **Oberbegriff für Schadsoftware im Allgemeinen**. Der Begriff setzt sich aus zwei englischen Begriffen zusammen: **Malicious** (böartig, schädlich) + **Software** = **Malware**.

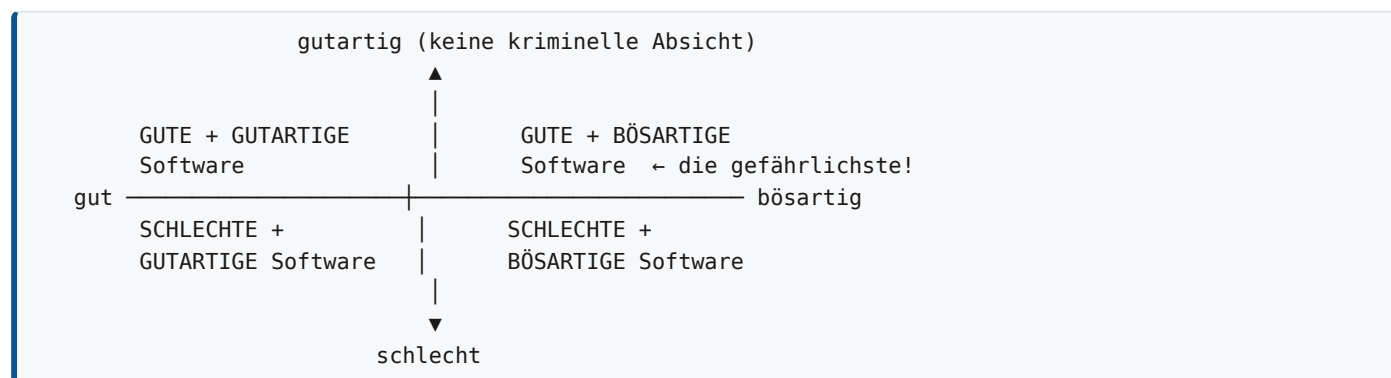
6.2 Die drei Web-Schichten ★

Schicht	Anteil	Beschreibung	Beispiele
Clear Web / Surface Web	~10 %	Leicht zugänglicher Teil des Internets, indexiert	Google, Wikipedia, Amazon, YouTube
Deep Web	ca. 90 %	Nicht indexiert, aber über normale Protokolle erreichbar	Firmendatenbanken, Streaming-Server, Online-Speicher
Dark Net	(Teilmenge)	Nicht auf herkömmliche Weise auffindbar	.onion-Seiten, nur über TOR erreichbar

⚠️ **Klassische Falle:** *Deep Web* ≠ *Dark Net*! Das Deep Web ist der weitaus größte Teil und völlig legal (jedes Online-Banking-Konto, jede Datenbank hinter einem Login). Das **Dark Net** ist eine kleine Teilmenge, die spezielle Software (TOR, I2P) erfordert. → Direkte Verbindung zu Kapitel 13 (TOR).

7. Softwarequalitäten — die 2×2-Matrix ★★

Prof. Inan spannt eine Matrix aus zwei unabhängigen Achsen auf: **Qualität** (gut ↔ schlecht) und **Absicht** (gutartig ↔ böartig).



7.1 Gute Software

Bietet ein **hohes Maß an Qualität**:

- **Minimale Anzahl** von Softwarefehlern/Schwachstellen
- **Hohe Funktionalität:** Funktionen arbeiten korrekt und zuverlässig
- **Einfache und verständliche Nutzerschnittstelle**
- Erfüllt IT-Sicherheits- und **Datenschutzansprüche**
- **Besserer Schutz** vor Malware-Angriffen

7.2 Gutartige Software

- „**Normale**“ Software-Produkte wie Betriebssysteme, Treiber, Anwendungen
- Einsatz im privaten und betrieblichen Umfeld
- **Entwickelt ohne kriminelle Hintergedanken**
- Kann **sowohl gut als auch schlecht** sein, je nach Eigenschaften und Funktionen
- **Bewertung der Gutartigkeit:** Maßstab durch Funktionen und Eigenschaften; Software kann durch Features nützlich, **aber auch bedenklich** sein („**Bezahlen mit persönlichen Daten**“)

7.3 Schlechte Software

Enthält **viele Softwarefehler** → Schwachstellen und hohe Risiken für Schäden.

Ursachen (★ Aufzählung merken):

- Steigende **Komplexität**
- Fehlendes **Sicherheitsbewusstsein** und mangelnde **Expertise der Entwickler**
- **Schlechter Programmierstil**, mangelnde Kenntnis über verwendete **Bibliotheken**
- **Zeitdruck** (*Time-to-Market*)
- **Unzureichendes Testen**
- **Unklare Anforderungen**

🔑 Schlechte Software **ist die Basis für den Erfolg böartiger Software** und wird daher als „**Übel für die moderne IT**“ angesehen. Sie trägt dazu bei, dass viele IT-Systeme mit Malware infiziert werden.

7.4 Böartige Software

- Software, die auf **fremden IT-Systemen Schadfunktionen** ausführt
- = Schadprogramm / Schadsoftware / **Malware**

🔑 **Hinweis (⚠ die Pointe!):** Bedauerlicherweise handelt es sich bei Malware sehr oft um eine **sehr gute Software** im Sinne der Klassifizierung von Software.

⚠ **Das ist eine Lieblings-Klausurfrage.** „Kann Malware ‚gute Software‘ sein?“ → **Ja**. Qualität und Absicht sind **orthogonale Dimensionen**. Professionelle Ransomware ist extrem robust, gut getestet, fehlerarm und hat oft sogar Support-Portale — sie ist technisch *gute* Software mit *bösartiger* Absicht.

🔑 **Merke: Absolute Fehlerfreiheit ist bei großer Software nicht erreichbar**, obwohl die Fehlerdichte sinkt. Trotz weniger Schwachstellen wächst die Bedrohung durch gezielte Angriffe aufgrund des zunehmenden **Know-hows der Angreifer** weiter.

8. Angriffsmethoden ★★

🔑 Nicht jeder Software- oder Hardwarefehler kann als Schwachstelle für einen Angriff genutzt werden.

8.1 Erste Achse: passiv vs. aktiv ★

	Passive Angriffe	Aktive Angriffe
Handlung	Angreifer liest Daten mit, ohne sie zu verändern	Modifizierung, Manipulation oder Sabotage von Daten und Diensten
Einschleusung	Es werden keine eigenen Daten in die Übertragung eingeschleust	Daten werden verändert oder neu eingeschleust
Entdeckbarkeit	Schwer zu erkennen , da der Angreifer nicht aktiv eingreift	Angriffe können auffallen oder Spuren hinterlassen
Verletztes Schutzziel	Vertraulichkeit	Integrität, Verfügbarkeit, Authentizität
Ziel	Informationen über das Ziel sammeln, Vertraulichkeit der Datenübertragung brechen	Informationen klauen, Daten verändern, neue Daten einschleusen

Beispiele für passive Angriffe (Folie 150):

- **Unverschlüsselte öffentliche WLANs** — jedes Gerät im Sendebereich des WLAN-Routers kann alle Datenpakete abhören
- **Schlecht konfigurierte Router** — Admin-Schnittstellen
- **Routing-Manipulation** — IP-Pakete nehmen immer die „günstigste“ Route → Umleitung über einen eigenen Knoten
- **Manipulation des Domain Name System — DNS Cache Poisoning**

Beispiele für aktive Angriffe:

- Identitätsdiebstahl, Brechen von Verschlüsselungen
- Systemmanipulation, Lahmlegen von Systemen

⚠ **Grenzfall in der Klausur:** DNS Cache Poisoning wird hier unter *passiv* geführt (als Mittel zum Mitlesen/Umleiten). Streng genommen ist die Cache-Manipulation selbst aktiv — für die Klausur die Folienzuordnung übernehmen und die Begründung des Dozenten nutzen: Ziel ist das **Mitlesen**, nicht die Veränderung der Nutzdaten.

8.2 Zweite Achse: nicht-zielgerichtet vs. zielgerichtet ★

	Nicht-zielgerichtet	Zielgerichtet
Opferauswahl	Kein gezieltes Auswählen der Opfer	Angriffe sind auf ein spezifisches Opfer zugeschnitten
Methode	Dieselbe Methode bei vielen Nutzern ; generisch und unspezifisch	Kombination aus Social Engineering und technischen Maßnahmen
Beispiel	Massenversand von Phishing-E-Mails	Advanced Persistent Threats (APT): langanhaltende, zielgerichtete Angriffe
Abwehr	Standardmaßnahmen greifen gut	Erkennung und Verteidigung sind oft schwierig

★ **APT** = *Advanced Persistent Threat*. Drei Wortbestandteile, drei Merkmale: **Advanced** (hochentwickelte Techniken, oft 0-Days), **Persistent** (langanhaltend, oft Monate/Jahre unentdeckt im Netz), **Threat** (organisierter, ressourcenstarker Akteur — häufig staatlich).

8.3 Tätertypen ★

Außentäter:

- Potenzielle Gefährdung hat sich **durch Vernetzung verstärkt**
- **PC, Internetzugang und wenig Fachwissen reichen** für Angriffe aus (→ *Crime-as-a-Service*, fertige Exploit-Kits)

Innentäter:

- Angriffe sind **ortsunabhängig** möglich
- **Gefährlich aufgrund von Insider-Informationen** und Kenntnis interner Abläufe
- Oft begünstigt durch **fehlende interne Schutzmechanismen**
- **Verschlüsselung und Härtung wichtiger Systeme selten umgesetzt**
- **Interne Überwachung und Protokollierung sind oft unzureichend**

🔑 **Achtung:** Die **Innentäterproblematik** sollte **nicht nur auf eigene Mitarbeiter** beschränkt werden. Vielmehr müssen **alle Personen mit internem Know-how** einbezogen werden, einschließlich **Geschäftspartner, Lieferanten, externe Dienstleister und Kunden**.

★ Das ist eine sichere Klausurfrage: „*Wer zählt zu den Innentätern?*“ → **Nicht nur Mitarbeiter**, sondern jeder mit internem Know-how: Geschäftspartner, Lieferanten, externe Dienstleister, Kunden.

9. Typische Schwachstellenkategorien ★★

🔑 Ein erfolgreicher IT-Angriff erfordert eine Schwachstelle/Sicherheitslücke, die der Angreifer ausnutzt. Diese Schwachstellen können **in jeder Phase des Entwicklungsprozesses** aus Hard- oder Softwarekomponenten entstehen und fallen in verschiedene Kategorien.

#	Kategorie	Definition (wörtlich)	Phase im Lebenszyklus
1	Anforderungsfehler	Sicherheitsanforderungen wurden nicht berücksichtigt , wodurch keine Schutzmechanismen vorhanden sind	Anforderungsanalyse
2	Designfehler	Die Spezifikation erfüllt die Anforderungen nicht und enthält Schwachstellen, die Angreifer ausnutzen können	Entwurf
3	Implementierungsfehler	Fehlerhafte Umsetzung des Designs , bei der die Implementierung von der Spezifikation abweicht und ausgenutzt werden kann	Implementierung
4	Installations- und Administrationsfehler	Schwachstellen durch unsachgemäße Konfiguration , z. B. Test-Accounts oder deaktivierte Sicherheitsfunktionen	Betrieb

★ **Merkstruktur:** Die vier Kategorien folgen exakt dem klassischen Wasserfall: **Anforderung → Design → Implementierung → Betrieb**.

⚠️ **Die Unterscheidung 1 vs. 2 ist die Falle:**

- **Anforderungsfehler:** Es wurde nie *gefordert*, dass Passwörter gehasht werden → die Anforderung fehlt komplett.
- **Designfehler:** Es wurde gefordert, aber die *Spezifikation* sieht MD5 vor → die Spezifikation erfüllt die Anforderung nicht.
- **Implementierungsfehler:** Spezifikation sagt bcrypt, der Code macht aber SHA-1 → Abweichung von der Spezifikation.
- **Administrationsfehler:** Alles korrekt spezifiziert und implementiert, aber der Admin lässt den Test-Account `admin/admin` aktiv.

 **Übungsbeispiel:** Log4Shell (CVE-2021-44228) — Die JNDI-Lookup-Funktion war **bewusst so design**t; die Sicherheitsimplikation wurde nicht bedacht → **Designfehler** (nicht Implementierungsfehler, denn der Code tat genau das, was spezifiziert war).

TEIL B — GOVERNANCE, RISK & COMPLIANCE (Kapitel 02_3)

10. Was ist GRC? ★★

 **GRC = Governance, Risk und Compliance**

 GRC ist ein **umfassendes Rahmenwerk**, das Unternehmen dabei unterstützt, **Informationssicherheit, Risikomanagement und Compliance systematisch zu steuern** und mit den Unternehmenszielen **in Einklang zu bringen**.

 GRC ist ein **integriertes Managementsystem** zur **koordinierten Steuerung** von Informationssicherheit, Risiken und regulatorischen Anforderungen im Unternehmen.

10.1 Die drei Komponenten ★

#	Komponente	Aufgabe (wörtlich)
1	Governance	Strategische Steuerung und Verantwortungsstruktur
2	Risk Management	Identifizieren, bewerten und steuern von Risiken
3	Compliance	Sicherstellung und Nachweis regulatorischer Konformität

Merkformel:

Governance = *Wer entscheidet und wohin steuern wir?* **Risk** = *Was kann schiefgehen und was tun wir dagegen?* **Compliance** = *Halten wir die Regeln ein und können wir es beweisen?*

10.2 Ziele von GRC

Allgemeine Hauptziele:

1. Schutz von **Unternehmensdaten, IT-Systemen und digitalen Vermögenswerten**
2. Einhaltung **gesetzlicher, regulatorischer und branchenspezifischer** Anforderungen
3. **Minimierung rechtlicher, finanzieller und reputativer Risiken** durch Nichteinhaltung

Hauptziele speziell in der Cybersicherheit:

- **Verbesserung des Informationssicherheits-Managements** — Schutz von Unternehmensdaten, IT-Systemen und digitalen Vermögenswerten
- **Risikominimierung** — Reduktion rechtlicher, finanzieller und organisatorischer Gefährdungspotenziale; **frühzeitige Erkennung und Bewertung von Sicherheitslücken**
- **Sicherstellung der Compliance** — Einhaltung relevanter gesetzlicher und branchenspezifischer Standards (z. B. **ISO 27001, NIST**)

Bedeutung: Vertrauen, Transparenz und Steuerbarkeit im digitalen Risiko-Umfeld schaffen — GRC ist eine **zentrale Komponente moderner Cybersecurity-Strategien**.

10.3 GRC in der Praxis ★

Sicherheitsstrategie:

- Cybersicherheit **wirksam steuern**
- Effizienz und Qualität im Schutz von Daten und Systemen erhöhen
- **Regelmäßige Audits** zur Bewertung von Schwachstellen und Lücken

Kontinuierlicher Prozess:

- **Dynamische Überwachung und Anpassung** von Richtlinien und Kontrollen
- Standardbasierte Orientierung (**ISO 27001, NIST**)

Die drei Praxis-Ziele (Folie 13) ★:

1. **Steuerbarkeit**
2. **Anpassungsfähigkeit**
3. **Nachweisbarkeit**

10.4 GRC ist kein IT-Thema ★

🔑 GRC ist **kein reines IT-Thema**, sondern ein **unternehmensweites Organisationsprinzip**, das **alle Geschäftsbereiche** betrifft. Es geht nicht nur um technische Sicherheitsmaßnahmen, sondern darum, **Prozesse, Verantwortlichkeiten und Entscheidungen** im gesamten Unternehmen so zu gestalten, dass Risiken erkannt, Regelverstöße vermieden und Unternehmensziele **sicher** erreicht werden.

11. Compliance ★★

11.1 Definition

- Die **Einhaltung gesetzlicher, regulatorischer sowie interner Vorgaben und Standards**
- Umfasst sowohl **verbindliche Vorschriften** (z. B. DSGVO) als auch **freiwillige Organisationsrichtlinien**
- Gilt **bereichsübergreifend**: unternehmensweite Relevanz, von IT über Finanzen bis HR
- Zielgruppen: Vorstand, Rechtsabteilung, IT usw.
- ➔ Stellt ein **klar definiertes Regelwerk** dar

🔑 Compliance stellt sicher, dass (IT-)Systeme im **Einklang mit rechtlichen Anforderungen** sowie mit **branchenspezifischen Standards** und mit **internen Vorgaben** betrieben werden.

11.2 Ziele von Compliance

- Richtlinien und Verhaltensregeln (**Code of Conduct**) schaffen **verbindliche Rahmenbedingungen**
- **Risikovermeidung** durch rechtskonforme und **nachvollziehbare Prozesse**
- ➔ Nachvollziehbare und wirtschaftliche Prozesse sichern
- ➔ **Vermeiden von Bußgeldern oder Reputationsschäden**

11.3 Arten von Compliance-Vorgaben ★

Art	Beispiele
Interne Vorgaben	Unternehmensrichtlinien, Verhaltensregeln, Betriebsvereinbarungen ; IT-Nutzung, HR-Richtlinien, Sicherheitsvorgaben
Externe Anforderungen — Datenschutz	DSGVO
Externe Anforderungen — IT-Sicherheit	NIS2, DORA
Externe Anforderungen — Branchenstandards	MaRisk, GoBD, ISO 27001

★ Abkürzungen, die man kennen muss:

Kürzel	Langform	Bereich
DSGVO	Datenschutz-Grundverordnung	Datenschutz, EU
NIS2	<i>Network and Information Security Directive 2</i>	IT-Sicherheit, EU (→ BSIG)
DORA	<i>Digital Operational Resilience Act</i>	Finanzsektor, EU
MaRisk	Mindestanforderungen an das Risikomanagement	Banken (BaFin)
MaSI	Mindestanforderungen an die Sicherheit von Internetzahlungen	Zahlungsverkehr
GoBD	Grundsätze zur ordnungsmäßigen Führung und Aufbewahrung von Büchern ... in elektronischer Form	Steuer/Buchhaltung
ISO 27001	Norm für Informationssicherheits-Managementsysteme (ISMS)	international
AI Act / KI-VO	EU-Verordnung über künstliche Intelligenz	KI, EU

11.4 IT-Compliance ★

- Sicherstellung, dass **IT-Systeme und -Prozesse** gesetzlichen, regulatorischen und internen Anforderungen **entsprechen**
- **Inhalte:**
 - **Informationssicherheit** (IT-Security, Verfügbarkeit, Datenschutz)
 - **Dokumentationspflicht**
 - **Datenaufbewahrung**

🔑 Compliance ist ein **integraler Bestandteil moderner Unternehmensführung** und weit mehr als nur eine IT-Aufgabe. Es geht auch darum, digitale Prozesse **wirtschaftlich, sicher und regelkonform** zu gestalten.

11.5 Die drei Säulen der IT-Security ★★★

Eine der wichtigsten Merkstrukturen des Kapitels.

#	Säule	Inhalte
1	Regulatorische Vorgaben	DSGVO, GoBD, MaRisk, NIS2, AI Act , DORA etc.
2	Technische Maßnahmen	Zugriffskontrollen, Verschlüsselung , Patchmanagement , Netzwerksegmentierung
3	Organisatorische Prozesse	Richtliniendefinition, Schulungen , Notfallmanagement , kontinuierliche Kontrolle

🔑 **Idee:** Ein **belastbares Sicherheitsniveau** kann nur erreicht werden, wenn **alle drei Säulen systematisch aufeinander abgestimmt** sind.

⚠️ Diese Dreiteilung entspricht exakt den **TOM** (technische *und* organisatorische Maßnahmen) aus Art. 32 DSGVO, ergänzt um die regulatorische Ebene. → Querverweis `10_IT-Recht.md`, Teil 3.2.

11.6 Ziele der IT-Compliance

1. **Fundament für nachvollziehbare Sicherheitsprozesse**
2. **Einheitliche Grundlage** für Kunden, Behörden und Zertifizierer
3. **Stärkung von Struktur und Kontrolle** — Verantwortlichkeiten, Abläufe und Nachweise sind eindeutig definiert
4. **Risiko- und Marktanforderungen adressieren** — Reduktion rechtlicher/finanzieller Risiken

12. Die Grenzen von Compliance — „Compliance ≠ Sicherheit“ ★★★

Dies ist **die zentrale Botschaft** des GRC-Kapitels und mit sehr hoher Wahrscheinlichkeit eine Klausurfrage.

12.1 Das Grundproblem

🔑 Compliance allein genügt nicht und wird häufig **nur als Kostenfaktor** empfunden.

Compliance ist leicht messbar:

- Fokus auf **Erfüllungsgrade, Quoten, Fristen, Auditstatus**
- ➡ Liefert **objektive Nachweise**, **ABER keine Aussage über Wirksamkeit**

🔑 **Wichtig:** Compliance liefert **keine Aussage über Angemessenheit und Wirksamkeit** der Maßnahmen.

12.2 Erfüllung ≠ Wirksamkeit ★

Aussage	Erläuterung
Erfüllung ≠ Wirksamkeit	Einhaltung von Vorgaben sagt nichts über deren Effektivität aus
Reaktives „Häkchen setzen“	ersetzt keine Sicherheitsstrategie
Prüfungslücke	Technische Angriffe nutzen oft Lücken außerhalb des Prüfungsfokus → mangelnde Reaktionsfähigkeit
Prüfungen bestehen ≠ Bedrohung abwehren	Compliance ≠ strategische Sicherheit

12.3 Die Komfortzonen-Falle ★★

🔑 **Compliance ≠ Komfortzone.** Die Erfüllung von Compliance-Vorgaben kann eine **trügerische Sicherheitsillusion** erzeugen.

Symptome:

- **Zertifizierungen und Nachweise vermitteln ein falsches Sicherheitsgefühl**
- Kritische Entscheidungen werden **nicht gesteuert, sondern reaktiv abgearbeitet**
- Compliance-Erfüllung bedeutet **nicht automatisch**, dass Risiken **aktiv gesteuert** oder Bedrohungen **wirksam abgewehrt** werden

Konkrete Beispiele aus den Folien:

- Nutzung **veralteter Software**
- Nutzung **nicht freigegebener Software und Prozesse** (→ *Shadow IT*)
- **Meldewege für Sicherheitsvorfälle werden ignoriert**

🔑 Ein **bestandenes Audit** bedeutet **nicht automatisch**, dass ein Unternehmen vor identitätsbasierten Angriffen geschützt ist. Während Compliance häufig **vergangenheitsorientiert** auf die Erfüllung von Vorschriften abzielt, agieren Angreifer **vorausschauend, dynamisch und anpassungsfähig**.

🔑 Je stärker Unternehmen ihre Compliance-Anforderungen erfüllen, desto größer wird oft die **Gefahr, sich in einer trügerischen Komfortzone einzurichten**. Die **formale Regelkonformität vermittelt Sicherheit, ohne tatsächliche Risiko- oder Wirksamkeitsprüfung**.

★ **Musterantwort für die Klausur** („Warum bedeutet Compliance nicht Sicherheit?“):

Compliance ist **vergangenheitsorientiert** und **erfüllungsorientiert**: Sie misst, ob zu einem Stichtag definierte Vorgaben erfüllt waren. Sie sagt nichts über die **Angemessenheit und Wirksamkeit** der Maßnahmen aus. Angreifer agieren dagegen **vorausschauend, dynamisch und anpassungsfähig** und nutzen gezielt Lücken außerhalb des Prüfungsfokus. Ein bestandenes Audit erzeugt daher eine **trügerische Sicherheitsillusion** („Komfortzone“). Erforderlich ist zusätzlich eine aktive **Governance**, die Risiken steuert statt nur Regeln abzhaken.

12.4 Compliance by Design ★

🔑 **Compliance-by-Design-Philosophie:** Compliance als **integraler Bestandteil von Anfang an**. Neue Prozesse und digitale Lösungen werden **von Beginn an regelkonform gestaltet**. Das vermeidet nachträgliche Anpassungen („**Compliance drüberstülpen**“).

⚠️ Direkte Parallele zu **Privacy by Design** (Art. 25 DSGVO) und **Security by Design** (Cyber Resilience Act). Prinzip ist immer dasselbe: Schutzanforderungen in der **Anforderungs- und Designphase** verankern, nicht nachträglich — vgl. die Schwachstellenkategorien 1 und 2 aus Kapitel 02_1!

Erfolgsfaktoren:

🔑 IT-Compliance ist **kein einmaliges Projekt mit festem Endpunkt**, sondern ein **kontinuierlicher Regelprozess**. Nur durch diese dauerhafte Steuerung kann Compliance im Unternehmen wirksam und nachhaltig verankert werden.

Die Schlussfolgerung, die zu Governance überleitet ★:

➔ **Governance ist notwendig, um zu steuern, nicht nur zu erfüllen. ➔ Ohne Governance wird Compliance zur Illusion von Sicherheit.**

13. Security Governance ★★

13.1 Definition

- **Strategischer Rahmen** zur Steuerung von Informationssicherheit
- Besteht aus **Richtlinien, Rollenmodellen und Entscheidungsprozessen**
 - Datenschutz- und Informationssicherheitsrichtlinien
 - **Incident-Response-Pläne**
- Definiert **Verantwortlichkeiten**: Führungskräfte, **IT-SB** (IT-Sicherheitsbeauftragter), **DSB** (Datenschutzbeauftragter)
- **Entwicklung von Strategien** und **Implementierung von Maßnahmen**

🔑 Governance soll sicherstellen, dass **Sicherheitsziele ebenso verbindlich sind wie Umsatz- oder Qualitätsziele**. D. h. sie bestimmt, **welchen Stellenwert (IT-)Sicherheit in der Strategie hat**.

🔑 Governance ist **keine Regelverletzungskontrolle**, sondern **strategischer Ordnungsrahmen**.

13.2 Ziele der Governance

1. **Sicherheitsrisiken strukturiert managen** und mit Unternehmenszielen abstimmen
2. **Minimierung von Sicherheitsrisiken**
3. Sicherheitsziele **planbar und messbar** machen
4. **Erfüllung von Compliance-Anforderungen**

Wirkungen:

- ➔ Klare Sicherheitsstrategie mit **Prioritäten, Mandaten und Ressourcen**
- ➔ Verlässliche **Entscheidungsfähigkeit im Falle von Zielkonflikten**
- ➔ **Schnellere Reaktionen** auf Bedrohungen durch definierte **Rollen und Eskalationslogik**
- ➔ **Reduzierung der Angriffsfläche** durch **proaktive Steuerung**

13.3 Kernelemente der Governance ★

1. Sicherheitsrichtlinien und Standards
2. Strategische Steuerung und klare Verantwortlichkeiten
3. Incident Response
4. Risikomanagement und Risikotragfähigkeit
5. Awareness und Schulung
6. Monitoring, Audits und Reporting

13.4 Was Governance NICHT bedeutet ★ ⚠

🔑 Governance bedeutet **nicht**, dass die Führung **jede Einzelmaßnahme absegnet**, sondern dass sie **den Rahmen vorgibt**, innerhalb dessen solche Entscheidungen verantwortungsvoll getroffen werden können.

- **Keine** zentrale Entscheidung über jede Einzelmaßnahme
- Fachbereiche handeln **selbstständig innerhalb definierter Leitplanken**
- Governance definiert **Rollen, Entscheidungskriterien und Eskalationswege**
- Führt **nicht über Detailvorgaben**, sondern über **Richtung und Konsequenz**

Was Governance bedeutet:

🔑 Die **Unternehmensleitung gibt die strategische Richtung vor**, und Sicherheitsziele werden **fest in die Gesamtstrategie integriert**, während **Steuerkreise** den Rahmen, Risiken und Berichtspflichten definieren.

13.5 Die Rolle der Führung ★

- **Governance ist Chefsache**
- **Prioritäten und Zielkonflikte brauchen legitime Entscheidungen**
- Der **Vorstand** gibt **Richtung und Vertrauensschutz** vor

13.6 Governance messbar machen ★

Reifegrad statt Checkliste — bewertet die **Fähigkeit zur Anpassung und Umsetzung**.

Mögliche Kennzahlen (KPIs):

- **Zeit von Risikoerkennung bis zur Entscheidung**
- **Häufigkeit und Begründung von Ausnahmen**
- **Budgeteinsatz vs. Risikoprioritäten**
- **Eingriffe durch Steuerkreise**

Ziel: Entscheidungsfähigkeit sichtbar machen.

⚠ Beachte: Das sind alles **Entscheidungs-Kennzahlen**, keine technischen Kennzahlen (z. B. „Anzahl geblockter Angriffe“). Genau das ist der Unterschied zwischen Governance- und Compliance-Metriken: Compliance misst **Erfüllungsgrade**, Governance misst **Steuerungsfähigkeit**.

14. Risikomanagement ★★☆☆

14.1 Definition ★

🔑 **Risikomanagement** ist der **systematische Prozess** zur **Identifikation, Bewertung, Steuerung und Überwachung von Risiken** mit dem Ziel, potenzielle Gefährdungen für das Unternehmen **frühzeitig zu erkennen** und geeignete Maßnahmen zu ergreifen.

Merkmale:

- Steuert **aktiv** den Umgang mit Bedrohungen und Unsicherheiten
- Frühzeitiges Erkennen kritischer Gefahren wie **Datenverlust, Systemausfälle, rechtliche und regulatorische Risiken**
- ★ **Risiken ≠ nur Bedrohungen**: Manche Risiken können **gezielt akzeptiert, kontrolliert oder bewusst getragen** werden

14.2 Ziele

- Risiken **frühzeitig erkennen, bewerten, steuern und dokumentieren**
- Schutz der Organisation vor Schäden und **Zielgefährdung**
- **Erhaltung des Geschäftsbetriebs** und Vermeidung von **Folgeschäden**
- **Proaktive Maßnahmen statt Schadensbewältigung**

14.3 Bestandteile

- **Strategie und Zielsetzung**
- **Etablieren des Risikobewusstseins** im Unternehmen
- **Controlling und Reporting**
- **Integration der gewonnenen Erkenntnisse in die Strategie**

14.4 Managementverantwortung ★

- Verantwortung liegt bei der **Unternehmensführung**, nicht nur bei einzelnen Fachabteilungen
- **Governance schafft den Rahmen**: *Welche Risiken werden getragen, welche nicht?*
- **Kommunikation ist entscheidend**: Risiken müssen **verstanden, akzeptiert und verfolgt** werden

14.5 IT-Risikomanagement ★

- Risiken in **IT-Systemen und -Prozessen** erfassen und steuern
- **Identifizierung, Bewertung und Priorisierung** von Sicherheitsrisiken
- Beispiele: Cyber-Angriffe, Datenverlust, **Fehlkonfigurationen**, Systemausfälle

Wesentliche Elemente:

- **Technische Risikoanalyse + organisatorische Bewertungsprozesse**
- **Einsatz von Tools** (Risikoerfassung, Frühwarnung, Reporting)
- **Reaktionsplanung** durch **Incident Management und Notfallpläne**
- **Sicherheitsbewertungen und Audits**
- **Implementierung von Maßnahmen zur Risikominderung**

🔑 **Merke:** Das IT-Risikomanagement ist ein **spezialisierte Bestandteil des unternehmensweiten Risikomanagements**. Es konzentriert sich auf Risiken im Bereich der Informations- und Kommunikationstechnologien und ist **eng verknüpft mit Informationssicherheit, Business Continuity und Governance**.

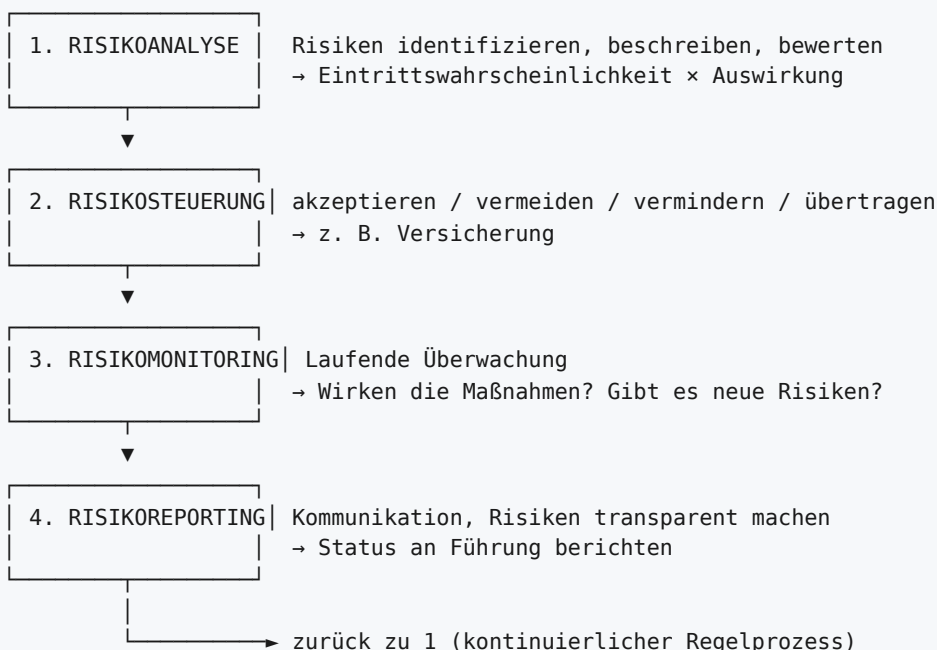
14.6 Security Incident Management

- **Spezialbereich innerhalb der IT-Sicherheit**, fokussiert sich **ausschließlich** auf den Umgang mit **sicherheitsrelevanten Ereignissen** → **Incident Response**
- Basiert auf **vordefinierten Prozessen und Verhaltensregeln**
- ★ **Entscheidungen, die bereits VOR dem Eintritt eines Sicherheitsvorfalls festgelegt werden**

🔑 Die **Identifikation von Risiken** bildet den **ersten und entscheidenden Schritt** im Risikomanagement. **Wird ein Risiko nicht erkannt, können weder eine fundierte Bewertung noch geeignete Maßnahmen** zur Risikosteuerung eingeleitet werden.

14.7 Der Risikomanagementprozess ★★★★★

🔑 Der **Risikomanagementprozess** (nach **ISO 31000** oder den **BSI-Standards**) beschreibt die **fachlich-inhaltlichen Schritte**, mit denen ein Unternehmen Risiken systematisch identifizieren, bewerten und steuern kann, mit dem Ziel, potenzielle Gefährdungen frühzeitig zu erkennen und angemessen zu behandeln.



Schritt	Inhalte (wörtlich aus den Folien)
1. Risikoanalyse	Risiken identifizieren, beschreiben, bewerten ; Eintrittswahrscheinlichkeit und Auswirkung
2. Risikosteuerung	Entscheidungen: akzeptieren, vermeiden, vermindern oder übertragen (z. B. Versicherung)
3. Risikomonitoring	Laufende Überwachung : Wirken die Maßnahmen? Gibt es neue Risiken?
4. Risikoreporting	Kommunikation : Risiken transparent machen, Status an die Führung berichten

★★ Die vier Steuerungsstrategien (Schritt 2) sind eine sichere Klausurfrage:

Strategie	Bedeutung	Beispiel
Akzeptieren	Risiko bewusst tragen (Restrisiko)	Kleiner Schaden, hohe Vermeidungskosten
Vermeiden	Risikoursache eliminieren	Risikanten Dienst abschalten
Vermindern	Wahrscheinlichkeit oder Auswirkung senken	Patchmanagement, Backups, Segmentierung
Übertragen	Risiko auf Dritte verlagern	Cyber-Versicherung , Outsourcing

⚠ **Merkhilfe (englische Standardbezeichnungen):** *Accept – Avoid – Reduce/Mitigate – Transfer*. Das **Übertragen** überträgt nur die **finanzielle** Folge, **nicht die Verantwortung** (und im Datenschutzrecht bleibt der Verantwortliche stets verantwortlich!).

15. Methoden der Risikoanalyse ★★

15.1 SWOT-Analyse ★

SWOT =

- Strengths (Stärken) — *intern*
- Weaknesses (Schwächen) — *intern*
- Opportunities (Chancen) — *extern*
- Threats (Risiken/Bedrohungen) — *extern*

Ziel:

- **Systematische Gegenüberstellung interner und externer Faktoren**
- Grundlage für **strategische Entscheidungen und Risikobewertung**

Einsatz: Management, Strategieentwicklung, Risikoanalyse

Aufbau als 2×2-Matrix ★:

	Positiv	Negativ
INTERN	Stärken (S) — <i>Was können wir gut?</i>	Schwächen (W) — <i>Wo haben wir Defizite?</i>
EXTERN	Chancen (O) — <i>Welche Potenziale ergeben sich?</i>	Bedrohungen (T) — <i>Was gefährdet unsere Ziele?</i>

Erkenntnis: Verbindungen von **innen** (Stärken/Schwächen) und **außen** (Chancen/Risiken) zeigen Handlungsmöglichkeiten.

Anwendung — Entwicklung von Handlungsstrategien:

- *Wie nutzen wir unsere **Stärken**, um **Chancen** zu ergreifen?* (S-O-Strategie)
- *Wie wehren wir **Risiken** ab?* (S-T-Strategie)
- **Identifikation kritischer Schwächen in Bezug auf externe Bedrohungen** (W-T-Strategie)

🔑 Die SWOT-Analyse hilft dabei, Risiken und Chancen im Kontext **allgemeiner Unternehmensfaktoren** zu betrachten, indem sie **externe Bedrohungen und Chancen mit internen Stärken und Schwächen systematisch verknüpft**.

🔑 Die SWOT-Analyse ist besonders hilfreich in **frühen Phasen der strategischen Planung**, etwa bei der **Bewertung von Projekten**, der Analyse eines möglichen **Markteintritts** oder zur strukturierten Übersicht **unternehmensweiter Risiken**.

Vorteile und Grenzen ★:

Vorteile	Grenzen
Einfache, verständliche Methode	Subjektive Einschätzungen ohne klare Bewertungsskala
Fördert interdisziplinären Dialog	Keine Gewichtung von Faktoren vorgesehen
Unterstützt ganzheitliche Risiko- und Chancenbewertung	Keine Maßnahmenplanung → nur Analyse

🔑 Die SWOT-Analyse eignet sich ideal **als Einstieg** in eine strukturierte Bewertung, sollte jedoch durch **tieferegehende Methoden ergänzt** werden, um fundierte Entscheidungen ableiten zu können.

15.2 ALARP-Risikomatrix ★★

ALARP = As Low As Reasonably Practicable — „so gering wie vernünftigerweise praktikabel“

Ziel: Bewertung und Visualisierung von Risiken auf Basis von:

- **Eintrittswahrscheinlichkeit**
- **Schadensausmaß**

Farblogik ★:

Farbe	Bedeutung
● Grün	Risiko akzeptabel (gering)
● Gelb	Risiko muss abgewogen werden (= der eigentliche ALARP-Bereich)
● Rot	Risiko ist nicht tragbar → Handlung erforderlich

Anwendung:

- **Häufig genutzte Standardmethode** der Risikobewertung
- Nutzt z. B. **3×3- oder 5×5-Felder** zur Klassifizierung

Schadens- ausmaß				
hoch	●	●	●	
mittel	●	●	●	
gering	●	●	●	
	gering	mittel	hoch	
	Eintrittswahrscheinlichkeit			

★ Grundformel der Risikobewertung:

$$\text{Risiko} = \text{Eintrittswahrscheinlichkeit} \times \text{Schadensausmaß}$$

⚠ Die **ALARP-Logik** besagt: Im gelben Bereich muss man **abwägen** — Maßnahmen sind so lange umzusetzen, wie ihr Aufwand **in einem vernünftigen Verhältnis** zur Risikoreduktion steht. Das ist exakt derselbe Gedanke wie das „**angemessene Maß**“ aus Kap. 02_1 und die „**angemessenen Maßnahmen nach dem Stand der Technik**“ aus § 30 BSIG.

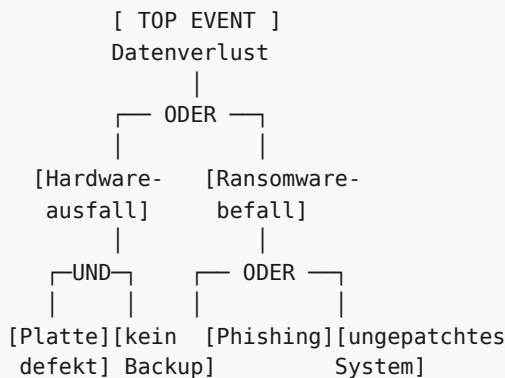
15.3 Fehlerbaumanalyse (FTA) ★

FTA = *Fault Tree Analysis* = Fehlerbaumanalyse

Ziel: Ursachenanalyse für systemweite Fehlfunktionen

Methode:

- **Graphisch-deduktiv: Top-Down-Analyse**
- Beginn mit einem **Fehler/Ereignis (Top Event)**
- **Analyse verknüpfter Ursachen bis zur Basis** (Basisereignisse)
- **Gute Visualisierung komplexer Zusammenhänge**
- Unterstützt **Ursachenpriorisierung**



⚠ **Merkmal FTA:** *deduktiv* und *top-down* — man geht **vom Schaden zur Ursache**. Das Gegenstück wäre die **FMEA** (induktiv, bottom-up: von der Komponente zum Schaden). In der Klausur reicht: **FTA = Top-Down, deduktiv, vom Top Event abwärts**.

16. PDCA- und SDCA-Zyklus ★★★★★

Dies ist die dritte große Klausurfrage des GRC-Kapitels.

16.1 PDCA-Zyklus

🔑 **PDCA = Plan – Do – Check – Act**. Auch bekannt als **Demingkreis**, **Deming-Rad** oder **Shewhart Cycle**. Basierend auf der **DIN-Norm 31000**.

Typische Prozessschritte im Risikokontext:

- **Risikoidentifikation:** Welche Risiken gibt es?
- **Risikobewertung:** Wie wahrscheinlich / wie schwerwiegend?
- **Risikobehandlung:** Welche Maßnahmen und Prioritäten?
- **Risikoüberwachung:** Werden Maßnahmen eingehalten und wirken sie?

Ziel:

- **Kontinuierliche Verbesserung** und Anpassung von Prozessen und Systemen
- Einsatz in **Qualitätsmanagement, Risikomanagement, IT-Sicherheit**

16.2 Die vier Phasen im Detail ★★

Phase	Bezeichnung	Inhalt
1. Plan	Planung und Problemerkennung	Bestehende Abläufe analysieren , Verbesserungspotenzial erkennen ; Lösungsvorschläge gemeinsam mit betroffenen Mitarbeitenden entwickeln
2. Do	Testweise Umsetzung im Kleinen	Lösungsansatz im Pilotumfeld umsetzen/testen; iteratives Feintuning vor breiter Einführung
3. Check	Überprüfung der Wirksamkeit	Kontrolle, ob Ziele erreicht wurden
4. Act	Standardisierung und Umsetzung	Entscheidung über breite Umsetzung zur Freigabe ; neue Prozesse offiziell einführen , dokumentieren und auditen ; Grundlage für die nächste PDCA-Iteration

⚠️ **DIE Falle des Kapitels — Prof. Inan hebt sie ausdrücklich hervor:**

🔑 **Anders als oft angenommen bedeutet „Do“ NICHT die sofortige umfassende Umsetzung, sondern das gezielte Ausprobieren und Testen im kleinen Rahmen.**

Wer in der Klausur bei *Do* „Maßnahme wird ausgerollt“ schreibt, verliert Punkte. Richtig: **Do = Pilot / Test im Kleinen**. Der Rollout passiert erst in **Act**.

Anwendung des PDCA:

- Einsatz im **kontinuierlichen Verbesserungsprozess (KVP)**
- Grundlage im **Qualitätsmanagement** (z. B. **ISO 9001**)
- Wichtiger Bestandteil von **ISMS** und Risikomanagement:
 - **ISO/IEC 27001**
 - **ISO 14000, ISO 20000**
 - **BSI-Standard 200-1**
- Ziel: **nachhaltige Effizienzsteigerung, Fehlerreduktion, höhere Kundenzufriedenheit**

16.3 SDCA-Zyklus ★★

🔑 **SDCA = Standardize – Do – Check – Act.** Nach **jeder erfolgreichen PDCA-Iteration** wird der neue Prozess **standardisiert**.

Phase	Bezeichnung	Inhalt
S	Standardize (Standardisieren)	Standard sichern
D	Do (Durchführen)	Standard durchführen
C	Check (Überprüfen)	Prüfen auf Konsistenz/Funktion
A	Act (Anpassen)	Bei Bedarf Verbesserung einleiten → neuer PDCA-Zyklus

🔑 SDCA ist **wie ein PDCA-Zyklus, aber mit einem anderen Fokus**: Er dient dazu, einen **erreichten verbesserten Zustand zunächst dauerhaft zu stabilisieren, bevor** der nächste Verbesserungszyklus beginnt.

🔑 Nach dem PDCA kommt immer der SDCA zur Stabilisierung.

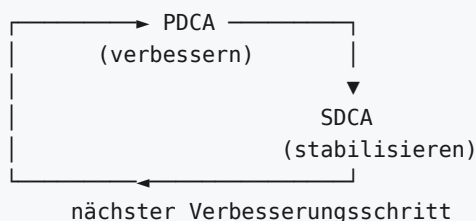
16.4 PDCA vs. SDCA ★★★★★

	PDCA	SDCA
Zweck	Verbesserung bestehender Prozesse	Sicherung und Einhaltung eines erreichten Standards
Fokus	Veränderung und Weiterentwicklung	Stabilität, Wiederholbarkeit und Schulung nach dem Verbesserungsschritt
Merkformel	PDCA = Veränderung und Verbesserung	SDCA = Einhaltung und Stabilisierung

Nach einer erfolgreichen PDCA-Runde will man sichergehen, dass:

- die neue Lösung **als Standard festgelegt** wurde (**S**)
- **korrekt in der Praxis durchgeführt** wird (**D**)
- **regelmäßig kontrolliert** wird (**C**)
- bei Bedarf **weiter angepasst** werden kann (**A**)

🔑 Die beiden Zyklen gehören zusammen: **Erst verbessern (PDCA), dann sichern (SDCA), dann wieder weiterentwickeln (neuer PDCA)**. Damit ergibt sich ein **Kreislauf stetiger Verbesserung**.



16.5 Risikomanagementprozess vs. PDCA vs. SDCA ★★★★★

Das ist die anspruchsvollste Abgrenzungsfrage des Kapitels. Prof. Inan formuliert sie so:

Konzept	Rolle (wörtlich)	Erklärung	Beispiel
Risikomanagementprozess	Das WAS	Inhaltlicher Ablauf: Risiken identifizieren, bewerten, steuern, überwachen und berichten . Nach ISO 31000 oder BSI : fachlich, technisch, operativ	—
PDCA-Zyklus	Das WIE verbessern wir den Prozess?	Steuert und entwickelt den Risikomanagementprozess weiter ; systematische Steuerung und Verbesserung	Neue Risikobewertungsmethode einführen, testen, optimieren, etablieren
SDCA-Zyklus	Das WIE stellen wir Stabilität sicher?	Sichert bewährte Prozesse und Standards im Tagesgeschäft ; Reife sichern, nicht sofort wieder ändern	Eine eingeführte Risikoklassifikation dauerhaft korrekt anwenden

Die Zusammenfassung des Dozenten (Folie 125) ★:

➤ Risikomanagement analysiert und behandelt Risiken ➤ PDCA verbessert den Risikomanagementprozess strategisch ➤ SDCA hält ihn operativ stabil

🔑 **Erinnerung:** Risikomanagement ist ein **kontinuierlicher Regelprozess**, der eine zentrale Rolle für den **langfristigen Erfolg und die Stabilität** eines Unternehmens spielt.

TEIL C — INCIDENT RESPONSE (Kapitel 02_4)

17. Warum Incident Response? ★★

17.1 Der Paradigmenwechsel ★★★

🔑 Incident Response gewinnt an Bedeutung — Verteidigung allein reicht nicht aus.

Die zentrale Frage:

Die entscheidende Frage lautet heute **nicht mehr nur**: → *Wie lässt sich ein Angriff **verhindern**?*
Sondern auch: → *Welche Maßnahmen greifen, wenn **sämtliche Schutzsysteme versagen**?* Anders ausgedrückt: **Was passiert, wenn Präventionsmechanismen versagen?**

Der Paradigmenwechsel im Sicherheitsmanagement ★:

- Wandel im **Sicherheitsverständnis**
- Fokus verschiebt sich **von reiner Prävention hin zu effektiver Incident Response**
- Eine **schnelle und strukturierte Reaktionsfähigkeit** gewinnt zunehmend an Bedeutung
- Sicherheitsverantwortliche erkennen die Notwendigkeit, **nicht nur zu verhindern, sondern auch auf Vorfälle effektiv zu reagieren**

🔑 Incident Response war **früher eher ein Randthema**, steht **heute jedoch im Zentrum moderner Sicherheitsstrategien**.

Notwendige Maßnahmen:

- **frühzeitige Erkennung**
- **konsequente Behandlung**
- **schnelle Eingrenzung** von Vorfällen

Unternehmen benötigen effektive Prozesse zur **1. Erkennung — 2. Behandlung — 3. Eindämmung** von Sicherheitsvorfällen. **Ziel: maximale Abschreckung und Verlangsamung von Angreifern.**

★ Die Grundannahme dahinter heißt in der Literatur „**Assume Breach**“: Man geht davon aus, dass ein Angreifer bereits im Netz ist oder es sein wird. Deshalb rückt die **Detektions- und Reaktionsfähigkeit** (Mean Time to Detect / Mean Time to Respond) neben die Prävention.

17.2 Gründe für das wachsende Interesse ★

1. Die **Vielzahl öffentlich bekannt gewordener Sicherheitsvorfälle** erhöht das **Risikobewusstsein**
2. **Strengere gesetzliche und regulatorische Anforderungen**

17.3 Regulatorische Treiber ★★

Treiber	Bereich	Erläuterung
MaSI	Finanzsektor	Mindestanforderungen an die Sicherheit von Internetzahlungen — branchenspezifische Vorschrift
NIS2-Richtlinie	EU-weit	<i>Network and Information Security Directive 2</i>
IT-Sicherheitsgesetz (Deutschland)	KRITIS	Unternehmen aus kritischen Infrastrukturen unterliegen dem deutschen IT-Sicherheitsgesetz — seit Oktober 2024; verlangt eine strukturierte und dokumentierte Incident-Response-Strategie

⚠ **Klausurrelevant:** Die Folie nennt ausdrücklich **Oktober 2024** und die Pflicht zu einer **strukturierten und dokumentierten IR-Strategie**. Querverweis auf `10_IT-Recht.md`, Teil 3.3 (BSIG/KRITIS, § 30 BSIG, Meldefristen 24 h / 72 h / 1 Monat).

17.4 Incident Response als strategischer Prozess ★★

🔑 **Merke:** Incident Response ist ein **integraler Bestandteil der Sicherheitsstrategie** eines Unternehmens mit dem Ziel, durch **frühzeitige Maßnahmen Folgeschäden, Betriebsunterbrechungen und Reputationsverluste zu verhindern**.

Der Prozess umfasst:

- **nicht nur** die akute Behandlung eines Vorfalls
- eine **Kombination aus Reaktion UND Prävention**
- **proaktive Elemente** (Planung, Monitoring) **und reaktive Maßnahmen** (Reaktion, Forensik)

Ziele:

1. **Vorfälle schnell erkennen**
2. **Schäden minimieren**
3. **Geschäftsrisiken senken**

17.5 Missverständnis vs. Realität ★★

🔑 Häufig wird Incident Response als **rein reaktive Notmaßnahme** verstanden — „eine Eingreiftruppe, die erst gerufen wird, wenn alles brennt“. **Tatsächlich handelt es sich um einen strategischen Prozess, der Planung, klare Kommunikation, wiederkehrende Übungen und eine ganzheitliche Eingliederung in die Sicherheitsarchitektur erfordert.**

★ **Sichere Klausurfrage:** „Incident Response ist nur eine Feuerwehr — richtig oder falsch? Begründen Sie.“ → **Falsch.** Vier Stichworte: **Planung, Kommunikation, Übungen, Eingliederung in die Sicherheitsarchitektur.**

17.6 Der Wert der Planung ★

Wert einer guten Vorbereitung:

- In **kaum einem Bereich der Informationssicherheit lässt sich mit guter Planung so viel erreichen**
- Ein **durchdachter, dokumentierter und regelmäßig getesteter Incident-Response-Plan ist unverzichtbar**

Breites Spektrum an Angriffsszenarien:

- Die **Vielfalt möglicher Vorfallsarten ist enorm**
- Ein effektiver Plan **berücksichtigt verschiedenste Szenarien und definiert passende Reaktionswege**

18. Incident Response vs. IT-Forensik ★★★★★

? „Ist dann Incident Response nicht das Gleiche wie IT-Forensik?“

🔑 Leider wird Incident Response in der Praxis **häufig fälschlicherweise mit IT-Forensik gleichgesetzt oder verwechselt**. Es gibt **unterschiedliche Rollen mit Schnittstellen**.

18.1 Die Abgrenzung ★★

	Incident Response	IT-Forensik
Charakter	Organisatorischer Rahmen zur Bewältigung von Sicherheitsvorfällen	Technischer Teilbereich , der sich mit der Analyse digitaler Spuren befasst
Fokus	Handlungsfähigkeit, Eindämmung, Wiederherstellung	Rekonstruktion, Beweissicherung, Erkenntnisgewinn
Zeitdruck	hoch (Betrieb steht)	geringer (Gründlichkeit vor Tempo)
Gemeinsames Ziel	Aufklärung und Reaktion auf Sicherheitsvorfälle	← dasselbe

Ziele der IT-Forensik (★ 4-Punkte-Liste):

1. **Rekonstruktion von Abläufen**
2. **Klärung der Vorgehensweise eines Angreifers**
3. **Identifikation kompromittierter Daten**
4. **Liefert Informationen, die das IR-Team zur fundierten Entscheidungsfindung benötigt**

18.2 IT-Forensik in der IR-Praxis: die Triage ★

- **Schnelle Erfassung durch forensische Triage zur fokussierten Analyse einzelner Sachverhalte**
- D. h. für eine **rasche Ersteinschätzung** werden **selektive Artefakte** untersucht:
 - **Log-Dateien**
 - **Prozesse**
 - **Netzwerkaktivität**

🔑 **Achtung:** Es handelt sich um **keine vollständige IT-forensische Analyse**. Häufig genügt bereits eine **gezielte Voruntersuchung/Vorabanalyse**, um **erste Maßnahmen wie Eindämmung oder Isolierung** einzuleiten.

🔑 **Merke:** Eine **vollumfängliche forensische Analyse** erfolgt ggf. **nachgelagert** im **Ermittlungs- oder Compliance-Kontext**.

🔑 Der **Handlungsspielraum** hängt auch **stark von der zu analysierenden Umgebung** ab.

⚠️ **Die Kernpunkte:** IR braucht **schnell genug** Informationen, um handeln zu können — nicht die vollständige Wahrheit. Die vollständige Forensik kommt **danach**, wenn es um Strafverfolgung, Versicherung oder Meldepflichten geht. **Triage ≠ Vollanalyse**.

19. Die Rolle des Managements ★★

🔑 Incident Response ist kein reines IT-Thema.

- Der **Aufbau einer Incident-Response-Strategie** kann nicht allein durch **IT-Sicherheit oder IT-Betrieb** erfolgen
- **Strategische und operative Entscheidungen überschneiden sich** mit Themen wie **Produktion, Finanzen und Kommunikation**

Unternehmensweite Bedeutung:

- Maßnahmen im Rahmen von Incident Response können **erhebliche Auswirkungen auf Geschäftsprozesse** haben
- **Entscheidungen über Betriebsunterbrechungen oder Ressourcenverlagerung erfordern Managementverantwortung**
- Die Initiative muss **von der Unternehmensleitung getragen, unterstützt und priorisiert** werden

🔑 Erfolgreiche und nachhaltige Strategien entstehen **nur durch aktives Commitment des Managements**.

★ Beachte die Parallele zu Governance: „*Governance ist Chefsache*“ — und „*IR-Strategie braucht Management-Commitment*“. Beide Aussagen stützen dieselbe Kernidee des Moduls: **Sicherheit ist eine Führungsaufgabe, keine Technikaufgabe**.

20. Individuelle Anforderungen an Incident Response ★

Unterschiedliche Strategien in Unternehmen:

- IR-Strategien und -Pläne unterscheiden sich je nach **Unternehmensgröße, Branche und vorhandener Infrastruktur**
- **Einflussfaktoren: organisatorische Reife, vorhandene Prozesse, personelle Ressourcen, technische Fähigkeiten**

Entscheidung über Einbindung externer Hilfe:

- Ein zentraler Aspekt ist die Überlegung, **ob und wann externe Dienstleister hinzugezogen** werden
- Auch diese Entscheidung hängt stark von **internen Kapazitäten und Reaktionszeiten** ab

 **Achtung:** Anders als in anderen Sicherheitsbereichen **existiert KEIN einheitlicher Goldstandard für Incident Response**. Stattdessen orientieren sich viele Organisationen an **etablierten, international anerkannten Rahmenwerken**.

20.1 Die zwei Rahmenwerke ★★

Rahmenwerk	Herausgeber
ISO/IEC 27035	ISO/IEC (international)
NIST SP 800-61	NIST (USA)

Gemeinsame Struktur beider Rahmenwerke:

1. Vorbereitung und organisatorische Grundlagen
2. Incident-Response-Zyklus

21. Playbooks ★★

 **Playbooks = strukturierte Handlungsanleitungen: Wer macht was, wann, wie?**
Standardisierte Reaktion auf häufige Vorfälle.

Aufbau eines Playbooks ★:

Abschnitt	Inhalt
Identifikation	IOCs, Quellen, Erkennungen
Eindämmung	Maßnahmen, Kommunikation
Bereinigung	Ursachenbehebung
Wiederherstellung	Backups , Dienste aktivieren

Playbooks: Lessons Learned — Rückblick und Optimierung **nach** dem Vorfall:

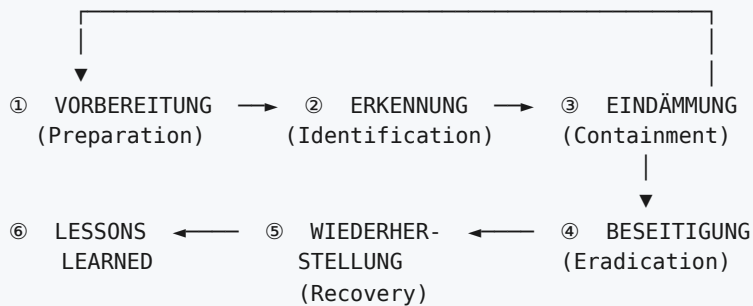
- War das Playbook verständlich/anwendbar?
- Gab es unklare Zuständigkeiten oder technische Hürden?
- Ergebnis: Verbesserung und Anpassung des Playbooks

★ **IOC = Indicator of Compromise** (Kompromittierungsindikator). Der Begriff kommt in Kapitel 22 (Pyramid of Pain) wieder — dort wird er systematisch aufgeschlüsselt.

⚠ Das Playbook selbst durchläuft einen **PDCA-Zyklus**: Es wird geplant, im Ernstfall/in Übungen angewandt, in „Lessons Learned“ geprüft und angepasst. Das ist eine sehr gute Verknüpfungsfrage zwischen Kapitel 02_3 und 02_4.

22. Der Incident-Response-Zyklus: die 6 Phasen ★★★★★

Das ist die wichtigste Aufzählung des Kapitels. Merkhilfe: **P – I – C – E – R – L** (*Preparation, Identification, Containment, Eradication, Recovery, Lessons Learned*).



Phase 1: Vorbereitung (Preparation) ★

Ziel: Organisation auf Sicherheitsvorfälle vorbereiten

Maßnahmen:

- **Incident-Response-Plan (IRP)** erstellen
- **Incident-Response-Teams (IRT)** strukturieren und aufbauen
- Definition **interner Zuständigkeiten und Kommunikationswege**
- **Schulungen, Kommunikation und Awareness** fördern
- **Technische Vorbereitung: Logging, Monitoring, SIEM und Forensik-Tools** etablieren

Phase 2: Erkennung (Identification) ★

Ziel: Vorfälle erkennen, analysieren und klassifizieren

Maßnahmen:

- **Monitoring mit SIEM, EDR, IDS/IPS**
- **Analyse von Logs und Warnungen**
- **Verifizierung des Vorfalls: Fehlalarm vs. echter Angriff**
- **Einstufung nach Kritikalität** (Schweregrad und betroffene Systeme)
- **Dokumentation und Vorfallmeldung** (für spätere Auswertung)

★ **Abkürzungen:**

Kürzel	Langform	Funktion
SIEM	<i>Security Information and Event Management</i>	Zentrale Sammlung + Korrelation von Logs
EDR	<i>Endpoint Detection and Response</i>	Erkennung/Reaktion auf Endgeräten
IDS	<i>Intrusion Detection System</i>	Erkennt Angriffe (nur Alarm)
IPS	<i>Intrusion Prevention System</i>	Erkennt und blockiert Angriffe
IRP	<i>Incident Response Plan</i>	Der Plan
IRT	<i>Incident Response Team</i>	Das Team
IOC	<i>Indicator of Compromise</i>	Kompromittierungsindikator

Phase 3: Eindämmung (Containment) ★

Ziel: Ausbreitung verhindern; Auswirkungen des Vorfalls begrenzen

Maßnahmen:

- **Kurzfristig: Isolierung infizierter Systeme**
- **Langfristig: temporäre Netzwerkanpassungen / Netzsegmentierung / Re-Konfiguration**
- **Beweissicherung** (z. B. Images, RAM, Logs)

Wichtige Entscheidungen:

- Wann und wie isoliert man kompromittierte Systeme?
- Welche Systeme dürfen weiter betrieben werden?

⚠️ Klassischer Zielkonflikt: **Sofort abschalten** (stoppt den Angriff, **vernichtet aber flüchtige Beweise** im RAM und warnt den Angreifer) vs. **beobachten** (mehr Erkenntnisse, **aber Risiko weiterer Ausbreitung**). Genau deshalb ist Containment eine **Management-** und nicht nur eine Technikentscheidung.

Phase 4: Beseitigung (Eradication) ★

Ziel: Ursache des Vorfalls vollständig entfernen

Maßnahmen:

- Rücksetzen kompromittierter Konten oder Zugangsdaten
- Entfernen von Malware, Backdoors und kompromittierten Dateien
- Sicherheitslücken schließen (Update/Patch)
- Forensisch prüfen, ob alles beseitigt wurde

🔑 **Achtung:** Der Wiederaufbau eines „sauberen“ und vertrauenswürdigen Zustands soll gewährleistet werden.

Phase 5: Wiederherstellung (Recovery) ★

Ziel: Rückführung in den sicheren Normalbetrieb

Maßnahmen:

- Wiederherstellung aus geprüftem Backup
- Integritätsprüfung und Monitoring
- Kommunikation mit Stakeholdern (Management, Kunden, Behörden)

🔑 **Achtung:** Ein **sicherer und kontrollierter Übergang in den Regelbetrieb** soll sichergestellt werden.

⚠️ „Geprüftes Backup“ ist kein Füllwort: Wenn das Backup den Angreifer bereits enthielt (z. B. eine Backdoor, die seit Monaten liegt), wird der Vorfall durch das Restore reproduziert. Deshalb Phase 4 **vor** Phase 5.

Phase 6: Lessons Learned (Nachbereitung) ★

Ziel: Lernen aus dem Vorfall und Verbesserung der Prozesse

Wichtige Aktivitäten:

- **Post-Incident-Review** durchführen
- **Schwächen in Technik, Organisation, Kommunikation** analysieren
- **Pläne, Playbooks und IRT aktualisieren**
- **Sensibilisierung der Belegschaft** basierend auf dem Vorfall

★ Phase 6 schließt den Kreis zurück zu Phase 1 — das ist ein **PDCA-Zyklus in Reinform**: *Plan* = Preparation, *Do* = Phasen 2–5, *Check* = Post-Incident-Review, *Act* = Aktualisierung von Plänen und Playbooks.

23. Pyramid of Pain ★★

23.1 Grundlagen

- Deutsch: **Schmerzpyramide**
- **Konzept aus der Cybersicherheitswelt**
- Entwickelt von **David J. Bianco**
- Beschreibt die **verschiedenen Arten von Indikatoren**, die bei der **Erkennung und Bekämpfung von Cyberangriffen** verwendet werden können
- Zeigt auf, **wie „schmerzhaft“** (d. h. wie effektiv und aufwendig) es **für einen Angreifer** ist, **wenn diese Indikatoren erkannt und blockiert werden**

🔑 **Merke:** Die verschiedenen Ebenen werden mithilfe von **Indikatoren für Kompromittierungen (Indicators of Compromise, IoCs)** beschrieben.

Für jede Ebene stellt der Dozent vier Fragen (Folie 67) ★:

1. Was bedeutet die Ebene?
2. Warum ist sie wichtiger oder schmerzhafter für den Angreifer?
3. Wie leicht oder schwer ist sie für den Angreifer zu ändern?
4. Beispiel zur Veranschaulichung

23.2 Der Aufbau ★★

Die Folien nennen ausdrücklich **Ebene 6: TTPs** an der Spitze und beschreiben die Achse: **oben** = *sehr schmerzhaft, schwer ersetzbare Informationen*; **unten** = *wenig schmerzhaft, leicht austauschbare Indikatoren*.



⚠ **Das Kernprinzip, das die Klausur abfragt:** Je **weiter oben** ein Indikator liegt, desto **teurer** ist es für den Angreifer, ihn zu wechseln — und desto **nachhaltiger** ist die Verteidigung. Einen **Hashwert** zu blocken kostet den Angreifer **Sekunden** (ein Byte in der Binärdatei ändern → völlig neuer Hash, siehe **Lawineneffekt** in Kapitel 07/08 und Kap. 13). Sein **TTP** (z. B. „Persistenz über geplante Aufgaben + Lateral Movement per Pass-the-Hash“) zu ändern kostet ihn **Monate**.

📝 **Verbindung zur Kryptographie:** Warum ist ein Hash der schwächste Indikator? Weil kryptographische Hash-Funktionen den **Avalanche-Effekt** haben: Die Änderung *eines* Bits im Eingang ändert **durchschnittlich die Hälfte aller Ausgangsbits**. Was die Hash-Funktion sicher macht, macht sie als IOC nutzlos.

🔑 **Fazit:** Die Pyramid of Pain stellt einen **wertvollen Anhaltspunkt für IT-Sicherheitsverantwortliche** dar, um die **technischen Aspekte von Cyberangriffen besser nachvollziehen und einschätzen** zu können.

🔑 **Idee:** Bei der Indikatorebene der **TTPs** setzt das öffentlich zugängliche **MITRE-ATT&CK-Framework** an.

24. MITRE-ATT&CK-Framework ★★★★★

24.1 Was ist MITRE ATT&CK? ★

- **MITRE = Eigenname und KEINE Abkürzung** ⚠ (beliebte Fangfrage!)
- **Non-Profit-Organisation**, die **im Auftrag der US-Regierung** Forschung und Systementwicklung betreibt
- **ATT&CK = Adversarial Tactics, Techniques, and Common Knowledge**
- **Frei verfügbares, umfangreiches Wissensmodell** über **bekannte Verhaltensweisen und Angriffstechniken** von Cyberkriminellen bzw. **Bedrohungsakteuren** (engl. *threat actors*)
- Das Framework **kategorisiert typische Angriffsarten** und stellt sie in Form einer **Matrix** dar

24.2 Taktiken vs. Techniken ★★

	Taktiken (Tactics)	Techniken (Techniques)
Frage	„Was will der Angreifer erreichen?“	„Wie wird dieses Ziel erreicht?“
Ebene	Ziel / Absicht	Umsetzung / Methode
Beispiele (Folie)	Initialzugriff, Privilegienerweiterung, Datenexfiltration	Spear-Phishing, Pass-the-Hash, Skriptausführung über PowerShell

🔑 **Hinweis:** Jede Technik kann auch noch in Untertechniken unterteilt sein, um sie noch spezifischer zu beschreiben.

24.3 Warum ist diese Unterteilung sinnvoll? ★

1. **Besseres Verständnis der Angriffsmethode**
2. **Genauere Detektionsmöglichkeiten** — z. B. **Phishing allgemein vs. Phishing mit Anhang**
3. **Feingranulare Maßnahmen planen** — z. B. für **PowerShell eine Detektion bauen, aber nicht für Cmd** möglich
4. **Vergleiche und Analysen zwischen Vorfällen sind strukturierter**

24.4 Ziele des Frameworks ★★

🔑 **Merke:** Das **Hauptziel** des MITRE-ATT&CK-Frameworks ist es, ein **gemeinsames, standardisiertes Vokabular** und eine **strukturierte Darstellung** für die **Beschreibung und Analyse von Cyberangriffen** bereitzustellen.

Die drei konkreten Ziele (Folie 116) ★:

#	Ziel	Erläuterung
1	Besseres Verständnis von Angreiferverhalten	Verbesserte Erkennung gängiger Angriffsmuster/-wege
2	Verbesserung der Erkennung und Verteidigung	Überprüfung der Wirksamkeit von Sicherheitsmaßnahmen gegen bekannte Techniken; ermöglicht zielgerichtete Schutzmaßnahmen
3	Unterstützung bei Threat Intelligence und Security Operation Centers (SOC)	Ermöglicht eine klare Beschreibung und Vergleichbarkeit von Angriffen

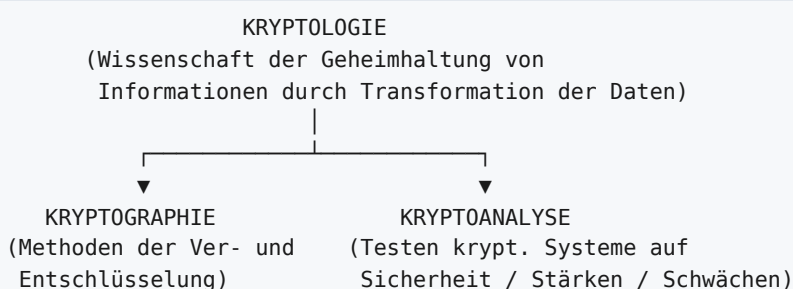
★ Die Verbindung Pyramid of Pain ↔ MITRE ATT&CK ist eine sehr wahrscheinliche Verständnisfrage:

Die Pyramid of Pain zeigt, dass Verteidigung auf **TTP-Ebene** am wirksamsten ist. Genau diese TTP-Ebene systematisiert MITRE ATT&CK, indem es Taktiken (das Was) und Techniken (das Wie) in einer Matrix katalogisiert. Damit macht ATT&CK die oberste, schmerzhafteste Ebene der Pyramide **operationalisierbar** — man kann Detektionen gegen konkrete Techniken bauen und ihre Abdeckung messen.

TEIL D — KRYPTOGRAPHIE

25. Grundlagen der Kryptologie (Kapitel 03) ★★

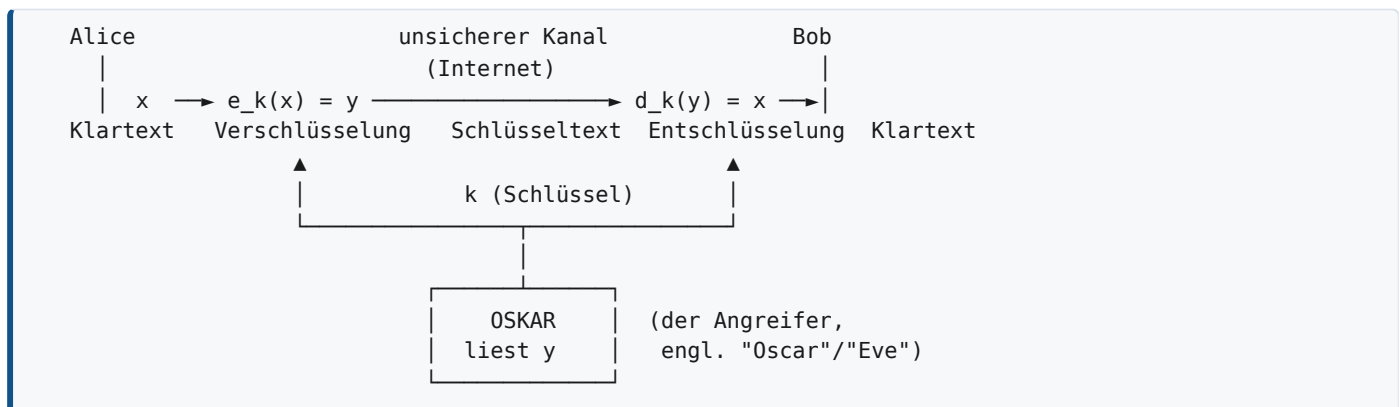
25.1 Die Begriffshierarchie ★★★



Begriff	Definition (wörtlich aus den Folien)
Kryptologie	Die Wissenschaft der Geheimhaltung von Informationen durch Transformation der Daten ; umfasst dabei die Kryptographie und Kryptoanalyse
Kryptographie	Die Wissenschaft von den Methoden der Ver- und Entschlüsselung
Kryptoanalyse	Die Wissenschaft, kryptographische Systeme und Verfahren auf ihre Sicherheit bzw. ihre Stärken und Schwächen zu testen

⚠ **Falle:** *Kryptographie* ist der **Teil**, *Kryptologie* das **Ganze**. Wer beides gleichsetzt, macht den häufigsten Begriffsfehler dieses Kapitels.

25.2 Das Standardszenario: Alice, Bob und Oskar ★



Notation, die durchgängig verwendet wird ★:

Symbol	Bedeutung
x	Klartext (<i>plaintext</i>)
y	Schlüsseltext / Chiffre / Geheimtext (<i>ciphertext</i>)
k	Schlüssel (<i>key</i>)
e bzw. $e_k(x)$	Verschlüsselungsfunktion (<i>encryption</i>)
d bzw. $d_k(y)$	Entschlüsselungsfunktion (<i>decryption</i>)
Alice / Bob	die legitimen Kommunikationspartner
Oskar	der Angreifer

Grundgleichung:

$$d_k(e_k(x)) = x$$

25.3 Das Kerckhoffs'sche Prinzip ★★★★★

? „Warum macht es Sinn, e und d offenzulegen?“

🔑 **Kerckhoffs'sches Prinzip:** Ein **Kryptosystem** muss auch dann noch sicher sein, wenn ein **Angreifer ALLE Details des Kryptosystems**, d. h. auch der Ver- und Entschlüsselung, **kennt — bis auf den Schlüssel**.

Begründungen (die man in der Klausur nennen sollte):

1. **Verfahren lassen sich nicht geheim halten** — Reverse Engineering, Insider, Leaks
2. Ein Schlüssel lässt sich **austauschen**, ein Verfahren praktisch nicht
3. **Öffentliche Verfahren werden von der Wissenschaft geprüft** → Schwächen werden gefunden, bevor Angreifer sie finden („**Security by Obscurity**“ ist keine Sicherheit)
4. Standardisierung und Interoperabilität werden erst dadurch möglich

🔑 **Merke:** Dieses Vorgehen funktioniert jedoch **nur, wenn Alice und Bob den gleichen Schlüssel haben, welcher zuvor sicher ausgetauscht wurde.**

🔑 **Merke:** Die **moderne Kryptographie verlagert das Problem der Geheimhaltung des Verschlüsselungsverfahrens auf die Geheimhaltung des Schlüssels.**

★ Damit ist die Brücke zum **Schlüsselaustauschproblem** geschlagen — und das ist genau die Motivation für **Diffie-Hellman (Kapitel 10)** und **RSA (Kapitel 11)**.

26. Algebraische Grundlagen (Kapitel 04, Teil 1) ★★

Für alle klassischen und modernen Chiffren braucht man das Rechnen in **Restklassenringen** $\mathbb{Z}_m$. Prof. Inan führt dazu Gruppe → Ring → Körper ein.

26.1 Gruppe

Eine Menge mit einer Verknüpfung, in der jedes Element ein **Inverses** besitzt.

🔑 Eine Menge ist **aber KEINE Gruppe bezüglich der Multiplikation**, sobald es Elemente a gibt, die **keine Inverse a^{-1}** haben.

26.2 Ring ★★

Beispiel der Folien: $(\mathbb{Z}_9, +, \times) = \{0, 1, 2, 3, 4, 5, 6, 7, 8\}$

Additionstabelle mod 9 (Ausschnitt) — jedes Element hat ein additives Inverses. **Multiplikationstabelle mod 9** — **nicht** jedes Element hat ein multiplikatives Inverses.

📝 **Beispiel aus den Folien:**

$$2 \cdot 5 = 10 \equiv 1 \pmod{9} \Rightarrow 5 \equiv 2^{-1} \pmod{9}$$

🔑 **Hinweis:** Wenn der **ggT(a, m) = 1** (größter gemeinsamer Teiler), **existiert $a^{-1} \pmod{m}$** . D. h. a **besitzt eine Inverse modulo m** .

🔑 **Wichtig:** Die multiplikative Inverse a^{-1} , d. h. $a \cdot a^{-1} \equiv 1 \pmod{m}$, **existiert NICHT für alle Elemente $a \in \mathbb{Z}_m$** .

📝 **Die Beispiele der Folie:**

Rechnung	Ergebnis	Folgerung
ggT(2, 9)	= 1	⇒ Inverse existiert
ggT(3, 9)	= 3	⇒ keine Inverse

★★ Die zentrale Merkregel des ganzen Kapitels:

$$\gcd(a, m) = 1 \iff a^{-1} \bmod m \text{ existiert}$$

Diese eine Zeile beantwortet:

- **welche Schlüssel** bei der multiplikativen Chiffre erlaubt sind,
- **welche a** bei der affinen Chiffre erlaubt sind,
- **welches e** bei RSA erlaubt ist ($\text{ggT}(e, \phi(n)) = 1$),
- **wann $\mathbb{Z}_m$ ein Körper ist** (nämlich wenn m prim ist).

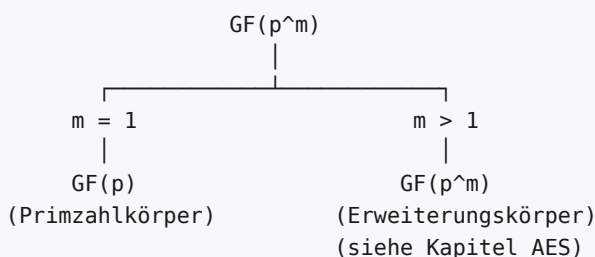
26.3 Körper ★

🔑 **Merke:** Jede reelle Zahl a hat eine additive Inverse $-a$. Ebenso hat jedes Element a , mit Ausnahme der 0, eine multiplikative Inverse a^{-1} ($= 1/a$).

🔑 **Merke:** Dies ist **nur der Fall**, wenn alle Zahlen **relativ prim (teilerfremd)** zu m sind. → also genau dann, wenn **m eine Primzahl** ist.

🔑 **Merke:** Um in der Kryptografie sinnvoll mit den (großen) Zahlen arbeiten zu können, ist es sinnvoll, **immer mit Körpern zu arbeiten, die eine endliche Anzahl an Elementen besitzen**. Daher spricht man in diesem Zusammenhang auch von einem **endlichen Körper**.

26.4 Galois-Körper $\text{GF}(p^m)$ ★



Fall	Name	Beispiel	Verwendung
$m = 1 \rightarrow \text{GF}(p)$	Primzahlkörper	$\text{GF}(29)$ bei DHKE	DHKE, RSA ($\mathbb{Z}^*_p$)
$m > 1 \rightarrow \text{GF}(p^m)$	Erweiterungskörper	$\text{GF}(2^8)$	AES (S-Box, MixColumn)

★ **GF** = *Galois Field* (nach Évariste Galois). Für die Klausur wichtig: **AES rechnet in $\text{GF}(2^8)$** — 8 Bit = 1 Byte, deshalb ist AES **byteorientiert**.

26.5 Zusammenfassung der Struktur-Hierarchie

Struktur	Bedingung
Gruppe (additiv)	Jedes Element hat ein additives Inverses
Ring	Addition + Multiplikation, aber nicht jedes Element hat ein multiplikatives Inverses
Körper	Jedes Element außer 0 hat ein multiplikatives Inverses → $\mathbb{Z}_m$ ist Körper $\iff m$ prim

27. Klassische Chiffren (Kapitel 04, Teil 2) ★★★★★

27.1 Das Alphabet $\mathbb{Z}_{26}$ ★

Alle klassischen Chiffren rechnen in $\mathbb{Z}_{26} = \{0, 1, \dots, 25\}$:

a	b	c	d	e	f	g	h	i	j	k	l	m
0	1	2	3	4	5	6	7	8	9	10	11	12
n	o	p	q	r	s	t	u	v	w	x	y	z
13	14	15	16	17	18	19	20	21	22	23	24	25

⚠ **Diese Tabelle muss man in der Klausur auswendig hinschreiben können** — sie ist die Basis jeder Rechnung. Eselsbrücke: **a = 0** (nicht 1!), **m = 12**, **n = 13**, **z = 25**.

27.2 Verschiebechiffre (Cäsar) ★★

Es seien $x, y, k \in \mathbb{Z}_{26} = \{0, 1, 2, \dots, 25\}$

	Formel
Verschlüsselung	$e_k(x) = y \equiv x + k \pmod{26}$
Entschlüsselung	$d_k(y) = x \equiv y - k \pmod{26}$

🔑 **Merke:** Diese Art von Chiffren ist **sehr leicht zu knacken**, indem man einfach **alle Verschiebungen systematisch durchprobiert**, bis ein lesbarer Text herauskommt. (= **Brute-Force / exhaustive Suche**)

🔑 **Merke:** Der **Schlüsselraum besteht nur aus 26 möglichen Schlüsseln**, da eine Verschiebung um **mehr als 25** Positionen keinen Sinn ergeben würde, weil eine Verschiebung um **26 Positionen das Gleiche ist wie eine Verschiebung um 0** Positionen.

★ **Schlüsselraum:** $|K| = 26$ (praktisch 25 sinnvolle, da $k = 0$ nichts verschlüsselt).

📝 **Rechenbeispiel:** Klartext HALLO, $k = 3$.

Buchstabe	H	A	L	L	O
x	7	0	11	11	14
$x + 3 \pmod{26}$	10	3	14	14	17
Geheimtext	K	D	O	O	R

→ KD00R . Entschlüsselung: $10 - 3 = 7 \rightarrow H$ usw.

27.3 Multiplikative Chiffre ★★

Es seien $x, y, k \in \mathbb{Z}_{26}$

	Formel
Verschlüsselung	$e_k(x) = y \equiv (x \cdot k) \pmod{26}$
Entschlüsselung	$d_k(y) = x \equiv (y \cdot k^{-1}) \pmod{26}$

Das Gegenbeispiel der Folie: $k = 2$ ⚠️

Klartext	a	b	c	d	e	f	g	h	i	j	k	l	m
x	0	1	2	3	4	5	6	7	8	9	10	11	12
$x \cdot 2 \bmod 26$	0	2	4	6	8	10	12	14	16	18	20	22	24
Geheimtext	A	C	E	G	I	K	M	O	Q	S	U	W	Y

Klartext	n	o	p	q	r	s	t	u	v	w	x	y	z
x	13	14	15	16	17	18	19	20	21	22	23	24	25
$x \cdot 2 \bmod 26$	0	2	4	6	8	10	12	14	16	18	20	22	24
Geheimtext	A	C	E	G	I	K	M	O	Q	S	U	W	Y

❓ „Wo liegt hier das Problem?“ → **Die Abbildung ist nicht injektiv!** **a** und **n** werden beide auf **A** abgebildet, **b** und **o** beide auf **C** usw. **Die Entschlüsselung ist nicht eindeutig** — nur die 13 geraden Zahlen werden getroffen.

Ursache: $\text{ggT}(2, 26) = 2 \neq 1 \rightarrow 2$ hat kein Inverses mod 26.

Das Positivbeispiel: $k = 3$

Klartext	a	b	c	d	e	f	g	h	i	j	k	l	m
x	0	1	2	3	4	5	6	7	8	9	10	11	12
$x \cdot 3 \bmod 26$	0	3	6	9	12	15	18	21	24	1	4	7	10
Geheimtext	A	D	G	J	M	P	S	V	Y	B	E	H	K

Klartext	n	o	p	q	r	s	t	u	v	w	x	y	z
x	13	14	15	16	17	18	19	20	21	22	23	24	25
$x \cdot 3 \bmod 26$	13	16	19	22	25	2	5	8	11	14	17	20	23
Geheimtext	N	Q	T	W	Z	C	F	I	L	O	R	U	X

→ **Alle 26 Buchstaben werden genau einmal getroffen** (bijektiv). Ursache: $\text{ggT}(3, 26) = 1$.

 **Merke:** Zu jeder multiplikativen Chiffre $e_k(x)$ mit $\text{ggT}(k, n) = 1$ gibt es eine **multiplikative Dechiffrierfunktion** $d_k(y) = x$ für alle $x \in \mathbb{Z}_m$.

 **Hinweis:** Es müssen alle möglichen Schlüssel k mit $\text{ggT}(k, 26) = 1$ und $k < 26$ gefunden werden, da der Schlüsselteil k für das Entschlüsseln **invertiert** werden muss.

Berechnung von k^{-1} ★

❓ „Wie berechnet man k^{-1} ?“ Für einen gegebenen Wert k testet man alle Möglichkeiten für k^{-1} , bis die folgende Gleichung erfüllt ist:

$$k \cdot k^{-1} \equiv 1 \bmod 26$$

 **Beispiel der Folie:** $k = 3 \rightarrow k^{-1} = 9$, denn

$$3 \cdot 9 = 27 \equiv 1 \bmod 26 \checkmark$$

Der Schlüsselraum der multiplikativen Chiffre ★★

🔑 Es gibt nur **ZWÖLF multiplikative Chiffren** bei einem Alphabet mit 26 Zeichen: **1, 3, 5, 7, 9, 11, 15, 17, 19, 21, 23 und 25**. Der Schlüsselraum ist noch kleiner als bei den Verschiebechiffren!

⚠️ **Achtung — die Folie enthält an dieser Stelle einen Zahlendreher:** Die aufgezählte Liste hat **12 Einträge**, aber es fehlt die **13**. Mathematisch korrekt ist: $\phi(26) = \phi(2) \cdot \phi(13) = 1 \cdot 12 = 12$ teilerfremde Zahlen zu 26, nämlich **{1, 3, 5, 7, 9, 11, 15, 17, 19, 21, 23, 25}**. Die 13 ist **nicht** dabei ($\text{ggT}(13, 26) = 13$), ebenso keine gerade Zahl. **Die Liste der Folie ist also richtig und vollständig** — man muss nur aufpassen, dass zwischen 11 und 15 wirklich die 13 fehlt und das kein Tippfehler ist.

★ **Merkregel:** Erlaubt sind genau die **ungeraden Zahlen außer 13**. $|K| = \phi(26) = 12$.

Vollständige Inversentabelle mod 26 (★ für die Klausur!):

k	1	3	5	7	9	11	15	17	19	21	23	25
k ⁻¹	1	9	21	15	3	19	7	23	11	5	17	25

Probe: $5 \cdot 21 = 105 = 4 \cdot 26 + 1 \equiv 1 \checkmark$ | $7 \cdot 15 = 105 \equiv 1 \checkmark$ | $11 \cdot 19 = 209 = 8 \cdot 26 + 1 \equiv 1 \checkmark$ | $17 \cdot 23 = 391 = 15 \cdot 26 + 1 \equiv 1 \checkmark$ | $25 \cdot 25 = 625 = 24 \cdot 26 + 1 \equiv 1 \checkmark$

27.4 Affine Chiffre ★★★

Die Kombination aus multiplikativer und Verschiebechiffre.

Es seien $x, y, k \in \mathbb{Z}_{26}$, Schlüssel **k = (a, b)**:

	Formel
Verschlüsselung	$e_k(x) = y \equiv (a \cdot x) + b \pmod{26}$
Entschlüsselung	$d_k(y) = x \equiv a^{-1} \cdot (y - b) \pmod{26}$
Bedingung	$\text{gcd}(a, 26) = 1$

🔑 **Merke:** Auch hier gilt die Einschränkung **$\text{ggT}(a, 26) = 1$** , da der Schlüsselteil a für das Entschlüsseln **invertiert** werden muss. D. h. **a kann nur Werte annehmen, für die $a^{-1} \pmod{26}$ existiert.**

Schlüsselraum ★:

$$|K| = (\# \text{Werte für } a) \cdot (\# \text{Werte für } b) = 12 \cdot 26 = \boxed{312}$$

🔑 **Hinweis:** Der Schlüsselraum ist **nicht viel größer** als der der Verschiebechiffre bei Cäsar.

⚠️ 312 Schlüssel sind für einen Computer in **Mikrosekunden** durchprobiert. Alle monoalphabetischen Chiffren scheitern zusätzlich an der **Häufigkeitsanalyse**: Im Deutschen ist **e** mit ~17 % der häufigste Buchstabe, gefolgt von **n, i, s, r, a**. Da jeder Klartextbuchstabe immer auf denselben Geheimtextbuchstaben abgebildet wird, überträgt sich diese Statistik 1:1.

📝 **Musteraufgabe (Typ Klausur):** Entschlüsseln Sie **R** mit $k = (a, b) = (5, 8)$.

1. $a^{-1} = 5^{-1} = \mathbf{21}$ (aus der Tabelle)
2. $y = R = \mathbf{17}$
3. $x \equiv 21 \cdot (17 - 8) = 21 \cdot 9 = 189 \bmod 26$
4. $189 = 7 \cdot 26 + 7 \rightarrow \mathbf{x = 7 = h}$

Probe: $e(7) = 5 \cdot 7 + 8 = 43 \equiv 43 - 26 = 17 = R \checkmark$

27.5 Monoalphabetisch vs. polyalphabetisch ★★

 **Hinweis:** Die bisher gezeigten **monoalphabetischen** Chiffren stellen eine **reine bijektive Abbildung** von Klartext auf Chiffretext dar. Bei einer **polyalphabetischen** Chiffre ist dies **nicht mehr der Fall**, da hier **jedes Klartextzeichen, je nach Kontext, auf unterschiedliche Chiffretextzeichen abgebildet** werden kann.

	Monoalphabetisch	Polyalphabetisch
Abbildung	bijektiv , fest	kontextabhängig
e wird immer zu ...	demselben Zeichen	verschiedenen Zeichen
Häufigkeitsanalyse	direkt anwendbar	nicht direkt anwendbar
Beispiele	Cäsar, multiplikativ, affin	Vigenère , One-Time-Pad

Homophone Chiffren ★:

 **Merke:** **Homophone Chiffren** sind Chiffren, bei denen im Geheimtext **jedes Zeichen (in etwa) gleich häufig vorkommt**. D. h. sie **verschleiern die Häufigkeiten der Klartextzeichen**.

★ Prinzip: Ein häufiger Klartextbuchstabe (z. B. e) bekommt **mehrere** mögliche Geheimtextzeichen zugeordnet, ein seltener nur eines — so wird die Häufigkeitsverteilung im Geheimtext geglättet.

27.6 Vigenère-Chiffre ★★★

Prinzip:

- Verwendung eines **Codeworts = Schlüsselworts**
- **Klartext + Schlüsselwort = Geheimtext**
- i -ter Buchstabe Klartext + i -ter Buchstabe Schlüsselwort = i -ter Buchstabe Geheimtext
- **Schlüsselwort zu Ende → Beginn von vorne** (zyklische Wiederholung)
- Umwandlung der Buchstaben in Zahlen

Es seien $x, k \in \mathbb{Z}_{26}$:

	Formel
Verschlüsselung	$e_k(x) = y \equiv x + k \bmod 26$
Entschlüsselung	$d_k(y) = x \equiv y - k \bmod 26$

⚠ Formal identisch mit der Verschiebechiffre — der Unterschied ist, dass **k jetzt pro Position wechselt** statt konstant zu sein. Das ist genau der Sprung von mono- zu polyalphabetisch.

 **Das Beispiel der Folien:** Klartext **TOPSECRET**, Schlüsselwort **GEHEIM**

Position	1	2	3	4	5	6	7	8	9
Klartext	T	O	P	S	E	C	R	E	T
x	19	14	15	18	4	2	17	4	19
Schlüssel	G	E	H	E	I	M	G	E	H
k	6	4	7	4	8	12	6	4	7
x + k	25	18	22	22	12	14	23	8	26
mod 26	25	18	22	22	12	14	23	8	0
Chiffretext	Z	S	W	W	M	O	X	I	A

Die Folie rechnet den ersten Schritt explizit vor:

$$e_k(x) = y \equiv x + k \bmod 26 \equiv 19 + 6 \bmod 26 \equiv 25 \bmod 26 \equiv 25 \rightarrow Z$$

⚠ Man beachte Position 5 und 8: Der Klartextbuchstabe **E** wird einmal zu **M** und einmal zu **I** — genau das ist der polyalphabetische Effekt.

Vorteile und Nachteile ★:

Vorteile	Nachteile
1. Relativ einfaches Verfahren	1. Kleine Schlüssellänge lässt sich mittels Häufigkeitsanalyse knacken (Kasiski-Test)
2. Häufigkeitsanalyse nicht mehr direkt anwendbar	
3. Beliebige Schlüssellänge	

★ **Kasiski-Test** (Friedrich W. Kasiski, 1863): Man sucht **wiederholte Zeichenfolgen** im Geheimtext. Der **Abstand** zwischen zwei identischen Folgen ist mit hoher Wahrscheinlichkeit ein **Vielfaches der Schlüssellänge**. Hat man die Schlüssellänge m , zerfällt der Geheimtext in m einzelne **Cäsar-Chiffren**, die man jeweils per Häufigkeitsanalyse bricht.

27.7 Vom Vigenère zum One-Time-Pad ★★★★★

🔑 Durch die **beliebige Schlüssellänge** ist es möglich, selbst die Vigenère-Verschlüsselung **unknackbar** zu machen.

? „Doch wie?“

🔑 **Merke:** Mit dem „**Buch-Verfahren**“ kann ein Vigenère-Schlüssel verwendet werden, der **genau so lang ist wie der Klartext selbst**. Dazu benutzt man als Schlüssel einen Text aus einem Buch. (Siehe OTP)

🔑 **Merke:** Anstatt von einem „Buch-Verfahren“ spricht man auch von einem „**Einmal-Schlüssel-Verfahren**“ oder auch „**individuelle Wurmverschlüsselung**“, „**Zahlenwurm**“ oder „**One-Time-Pad**“.

★ Die vier Namen für dasselbe Verfahren merken:

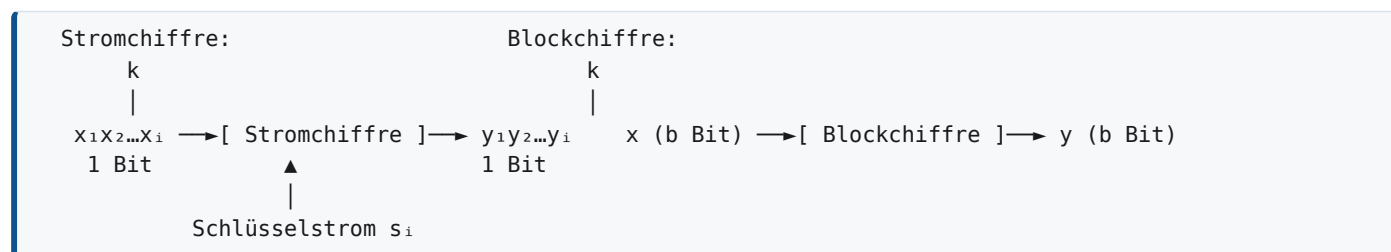
1. Buch-Verfahren
2. Einmal-Schlüssel-Verfahren
3. individuelle Wurmverschlüsselung / Zahlenwurm
4. **One-Time-Pad (OTP)**

⚠ **Wichtige Einschränkung, die die Folie zum Buch-Verfahren nicht ausspricht:** Ein **Buchtext ist kein echter Zufall** — er hat Sprachstatistik. Streng beweisbar sicher ist das OTP nur mit einem **echt zufälligen** Schlüssel, der **genauso lang** wie die Nachricht ist und **nur einmal** verwendet wird. Genau dorthin führt Kapitel 05 (Stromchiffren).

28. Stromchiffren (Kapitel 05) ★★★★★

28.1 Strom- vs. Blockchiffre ★★

	Stromchiffre	Blockchiffre
Einheit	verschlüsselt jedes Klartextbit einzeln (1 Bit)	verschlüsselt Blöcke von b Bit
Mechanismus	Verwendung eines Schlüsselstroms , der zum Klartextbit addiert wird	Substitution + Permutation über den ganzen Block
Beispiele	Trivium, RC4, A5/1	DES (64 Bit), AES (128 Bit)



28.2 Ver- und Entschlüsselung ★★★★★

Der Klartext, das Chifftrat und der Schlüsselstrom bestehen aus **individuellen Bits** $x_i, y_i, s_i \in \mathbb{Z}_2 = \{0, 1\}$:

	Formel
Verschlüsselung	$e_{s_i}(x_i) = y_i \equiv x_i + s_i \pmod{2}$
Entschlüsselung	$d_{s_i}(y_i) = x_i \equiv y_i + s_i \pmod{2}$

🔑 **Merke:** Die **Ver- und Entschlüsselung sind quasi identisch** (gleiche Operation) und basieren auf einer **einfachen Addition modulo 2**.

🔑 **Merke:** Die Formeln beziehen sich auf **individuelle Bits**, was durch das i gekennzeichnet ist, wobei y_i **ein Bit** repräsentiert und die verschlüsselte Version des Bits x_i darstellt.

28.3 Die drei Leitfragen des Kapitels ★

Prof. Inan strukturiert das gesamte Kapitel um drei Fragen:

1. Warum sind die Ver- und Entschlüsselung die gleiche Operation?
2. Warum reicht eine einfache Addition modulo 2 als Verschlüsselung?
3. Was genau sind die Bits s_i des Schlüsselstroms bzw. wie genau wird der Schlüsselstrom erzeugt?

28.4 Antwort auf Frage 1: Der Beweis ★★

 **Idee:** Hierfür ist es erforderlich nachzuweisen, dass durch die Entschlüsselung die **Klartextbits** x_i **wiederhergestellt** werden können.

Der Beweis (Folie 18) — muss man reproduzieren können:

$$\begin{aligned}
 d_{s_i}(y_i) &\equiv y_i + s_i && \text{mod } 2 \\
 &\equiv (x_i + s_i) + s_i && \text{mod } 2 \\
 &\equiv x_i + 2 \cdot s_i && \text{mod } 2 \\
 &\equiv x_i + 0 && \text{mod } 2 \\
 &\equiv x_i && \text{mod } 2 \quad \blacksquare
 \end{aligned}$$

Der Schlüsselschritt: $2 \cdot s_i \equiv 0 \text{ mod } 2$, **egal ob $s_i = 0$ oder $s_i = 1$** . Deshalb hebt sich das zweimalige Addieren von s_i auf — **XOR ist selbstinvers**.

28.5 Antwort auf Frage 2 (Teil 1): XOR ★★

Die Wahrheitstabelle (Folie 19):

x_i	s_i	$y_i \equiv x_i + s_i \text{ mod } 2$
0	0	0
0	1	1
1	0	1
1	1	0

 **Merke:** Eine **Addition modulo 2** ist gleichbedeutend (äquivalent) mit der **XOR-Operation**.

$$x \oplus s = (x + s) \text{ mod } 2$$

? „Warum macht das XOR-Gatter kryptografisch mehr Sinn als andere boolesche Verknüpfungen wie die AND-Operation?“

Die zwei Gründe (Folie 23) ★★:

#	Eigenschaft	Erläuterung
1	XOR ist perfekt ausbalanciert	Bei einem gegebenen Ausgangswert sind alle Eingangswerte immer gleich wahrscheinlich . Ermöglicht kein anderes Gatter.
2	XOR ist invertierbar	$a \oplus b \oplus b = a$

 **Vergleich mit AND — die Begründung ausformuliert:**

Ausgang	AND: mögliche Eingänge	XOR: mögliche Eingänge
0	(0,0), (0,1), (1,0) → 3 von 4	(0,0), (1,1) → 2 von 4
1	(1,1) → 1 von 4	(0,1), (1,0) → 2 von 4

Bei **AND** verrät ein Ausgang von 1 sofort, dass **beide** Eingänge 1 waren → **Information leckt**. Bei **XOR** ist die Verteilung **perfekt 50:50** → **keine Information leckt**. Zusätzlich ist AND **nicht invertierbar** (aus $y = 0$ kann man x nicht rekonstruieren).

28.6 Antwort auf Frage 2 (Teil 2): beweisbare Sicherheit ★★

🔑 **Achtung:** Wenn das Schlüsselstrombit s_i **echt zufällig** gewählt wird, d. h. **nicht vorhersagbar** ist und **genau eine 50:50-Chance** hat, null oder eins zu sein, dann verhält sich auch das **Chifftratbit echt zufällig** und ist mit einer 50-prozentigen Wahrscheinlichkeit null oder eins.

📝 Das Beispiel der Folien (Folie 31):

Alice $x_0 \dots x_6 = 0100\ 0001 = \text{'A'}$ (ASCII 65) $s_0 \dots s_6 = 0010\ 1100$ XOR $y_0 \dots y_6 = 0110\ 1101 = \text{'m'}$	Bob $y_0 \dots y_6 = 0110\ 1101$ $s_0 \dots s_6 = 0010\ 1100$ XOR $x_0 \dots x_6 = 0100\ 0001 = \text{'A'}$
---	---

Oskar sieht: $0110\ 1101 = \text{'m'}$

★ Die Pointe: Oskar sieht ein völlig unverdächtiges **m** — der Klartext **A** ist nicht rekonstruierbar.

Die Sicherheitsargumentation (Folien 35–41) ★★:

Der Angreifer kennt y_i (0 oder 1), **kann aber nicht auf den Wert von x_i schließen**. **Beide potenziellen Lösungen, $x_i = 0$ und $x_i = 1$, haben die gleiche Wahrscheinlichkeit** — ➔ vorausgesetzt, das s_i wurde von einem **TRNG** erzeugt.

Beobachtetes y_i	mögliche (x_i, s_i)	Wahrscheinlichkeit für $x_i = 0$
0	(0,0) oder (1,1)	50 %
1	(0,1) oder (1,0)	50 %

🔑 **Achtung:** Wenn man mit Bits arbeitet, die **wirklich/echt zufällig** erzeugt wurden, und sie **mittels XOR zum Klartext addiert**, erhält man ein Chifftrat, **das nicht gebrochen werden kann**.

🔑 **Merke:** Da **jede Nachricht mit einem Schlüssel gleicher Länge** verknüpft wird, geht auch im Schlüsseltext **jegliche Struktur verloren**, wodurch für die Kryptanalyse **keinerlei Anhaltspunkte** geboten werden.

★ Das ist die **perfekte Sicherheit** (*perfect secrecy*) nach **Claude Shannon (1949)** — das One-Time-Pad ist das **einzige** beweisbar sichere Verschlüsselungsverfahren.

Die drei OTP-Bedingungen (klausurrelevant):

1. Schlüssel **echt zufällig** (TRNG)
2. Schlüssel **genauso lang** wie die Nachricht
3. Schlüssel wird **nur ein einziges Mal** verwendet

28.7 Wann die Sicherheit zusammenbricht ★★

🔑 **Achtung:** Die Situation ändert sich jedoch, wenn die **Schlüsselstrombits nicht mehr echt zufällig** sind. Denn dann besteht eine **funktionale Abhängigkeit/Zusammenhang zwischen den Bits s_i und den mod-2-Gleichungen**. Diese sind dann auch **nicht mehr unabhängig voneinander**.

🔑 **Achtung:** Das Verfahren gilt dann **nicht mehr als beweisbar sicher**, auch wenn das so entstandene **Gleichungssystem schwer zu lösen** ist.

⚠️ **Der feine, aber prüfungsrelevante Unterschied:**

- **beweisbar sicher** (*information-theoretically secure*) = auch mit unendlicher Rechenkraft nicht brechbar → nur das echte OTP
- **praktisch sicher** (*computationally secure*) = mit heutiger Rechenkraft nicht in vernünftiger Zeit brechbar → alle realen Verfahren (AES, RSA, Trivium ...)

28.8 Antwort auf Frage 3: Schlüsselstromerzeugung ★★

🔑 Die Schwierigkeit besteht nun darin, die s_i zu erzeugen.

1. Die **Generierung des Schlüsselstroms s_i bildet die zentrale Fragestellung** bei Stromchiffren
2. ⚠️ **Die Bits des Schlüsselstroms sind NICHT der Schlüssel selbst**

🔑 **Achtung:** Die **Sicherheit der Chiffre hängt vollständig vom Schlüsselstrom ab**.

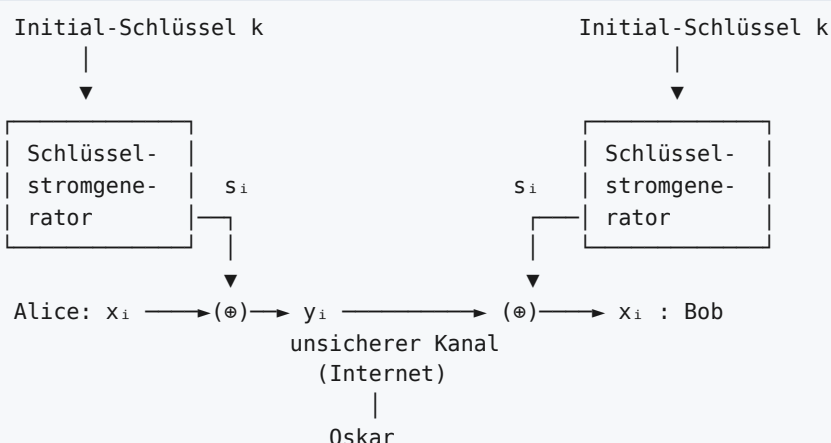
🔑 **Merke:** Eine besonders wichtige Anforderung an den Schlüsselstrom ist, dass dieser **für den Angreifer wie eine zufällig gewählte Bitfolge erscheint**.

Die zwei Eigenschaften des Schlüsselstroms (Folie 78) ★★:

1. **Für den Angreifer muss der Schlüsselstrom wie eine zufällige Bitfolge erscheinen**
2. **Der Schlüsselstrom kann NICHT von einem TRNG stammen → Deterministischer Generator**

⚠️⚠️ **Das ist die Schlüsselstelle des Kapitels und eine sichere Klausurfrage:** „Warum darf der Schlüsselstrom nicht von einem TRNG kommen?“

Weil **Bob denselben Schlüsselstrom reproduzieren** muss, um entschlüsseln zu können. Ein echter Zufallsgenerator ist **nicht reproduzierbar** — man müsste den gesamten Schlüsselstrom (also so viele Bits wie die Nachricht lang ist) sicher übertragen, und dann hätte man das Schlüsselaustauschproblem des OTP. Also braucht man einen **deterministischen** Generator, der aus einem **kurzen gemeinsamen Initial-Schlüssel k** einen **langen, zufällig *aussehenden*** Strom erzeugt. Der Preis: Man verliert die beweisbare Sicherheit und erhält nur noch praktische Sicherheit.



28.9 Zufallszahlengeneratoren ★★★★★

🔑 **Merke:** In der Kryptografie werden **Zufallszahlen für verschiedenste Konstruktionen** gebraucht, wie für die **Erzeugung von Sitzungsschlüsseln** oder **Randomisierungswerte**, die als Eingabe für Verschlüsselungen benötigt werden.

Die drei Typen ★★★★★:

#	Typ	Abkürzung	Eigenschaften
1	Pseudozufallszahlengeneratoren	PRNG — <i>Pseudo Random Number Generator</i>	deterministisch, aus einem Seed berechnet; statistisch gut, aber vorhersagbar
2	Echte Zufallszahlengeneratoren	TRNG — <i>True Random Number Generator</i>	physikalische Quelle (Rauschen, radioaktiver Zerfall, Jitter); nicht reproduzierbar , oft langsam
3	Kryptografisch sichere Pseudozufallszahlengeneratoren	CSPRNG — <i>Cryptographically Secure PRNG</i>	deterministisch und unvorhersagbar: aus den bisherigen Ausgabebits lässt sich das nächste Bit nicht besser als mit 50 % vorhersagen

★ Wofür welcher Generator?

Zweck	Generator
Simulation, Monte Carlo, Spiele	PRNG genügt
Erzeugung des Initial-Schlüssels / Seeds , Langzeitschlüssel, IVs	TRNG
Schlüsselstrom einer Stromchiffre, Sitzungsschlüssel, Nonces	CSPRNG

⚠ **Die Kombination in der Praxis:** Ein **TRNG** liefert den **Seed** (kurz, echt zufällig), ein **CSPRNG** expandiert ihn zum langen Schlüsselstrom. Genau so arbeitet z. B. `/dev/urandom`.

28.10 Trivium ★

Die Folien nennen **Trivium** als konkretes Beispiel einer modernen Stromchiffre (Folie 131).

Eckdaten (Standardwissen zu Trivium):

- Entstanden im europäischen **eSTREAM**-Projekt
- **80-Bit-Schlüssel, 80-Bit-IV**
- Drei gekoppelte **nichtlineare Schieberegister** mit insgesamt **288 Bit** Zustand
- Sehr **hardwarefreundlich** (wenige Gatter), daher für RFID/IoT interessant

29. DES — Data Encryption Standard (Kapitel 06) ★★★★★

29.1 Die Ausgangsfrage ★

? „Gibt es ein Verfahren, einen Algorithmus oder eine Herangehensweise, mit der man eine sichere Blockchiffre konstruieren kann?“

🔑 **NEIN.**

🔑 **Aufpassen! ABER es gibt ZWEI atomare Operationen für Blockchiffren, die das ermöglichen.**

29.2 Konfusion und Diffusion (Claude Shannon) ★★★★★

Claude Shannon — zwei grundlegende Operationen, mit denen eine starke Verschlüsselung bzw. Chiffre realisiert werden kann:

#	Operation	Definition (wörtlich)	Realisierung
1	Konfusion	Verschleierung der Beziehung bzw. des Zusammenhangs zwischen dem Schlüssel/Klartext und dem Chifftrat	Substitutionstabellen (S-Box)
2	Diffusion	Streuung des Einflusses eines Klartextsymbols auf zahlreiche Chiffratsymbole; Einfluss jedes Klartext-Bits soll sich über das ganze Chifftrat verteilen; Verbergen von statistischen Eigenschaften des Klartextes	DES: Bitpermutation (P-Box) / AES: MixColumn-Operation

★★ Merkformel:

Konfusion = Verschleiern (Zusammenhang Schlüssel↔Chifftrat) → **S-Box** (Substitution) **Diffusion = Verteilen** (Einfluss eines Bits über den ganzen Block) → **P-Box** (Permutation) bzw. **MixColumn**

29.3 Der Avalanche-Effekt (Lawineneffekt) ★★★★★

🔑 **Merke:** Die **Änderung EINES Bits im Klartext** hat die Änderung von **durchschnittlich der HALFTE aller Ausgabebits** zur Folge. Demzufolge sind dann **zwei Chifftrate, deren Klartexte sich in nur einem Bit unterscheiden, statistisch vollkommen unabhängig** voneinander.

🔑 **Merke:** Dies **verhindert bzw. zerstört eine 1:1-Abbildung, Korrelation oder Zusammenhang**, wie dies bei der **reinen Substitution** (feste Abbildung) der Fall ist.

★ **Zahlenbeispiel:** Bei DES (64-Bit-Block) ändern sich bei Änderung eines einzigen Klartextbits im Schnitt **32 der 64** Chifftratbits.

29.4 Warum beide Operationen nötig sind ★★★★★

🔑 **Achtung:** Nur die **Konfusion** (z. B. Enigma) ODER die **Diffusion** (z. B. Vigenère) als **einzige Operation** zu verwenden, hat gezeigt, dass **diese nicht sicher sind**.

🔑 **Strategie:** Aus diesem Grund verfolgt man eine „**besondere**“ Strategie, um beides zu vereinen.

29.5 Produktchiffren ★★★★★

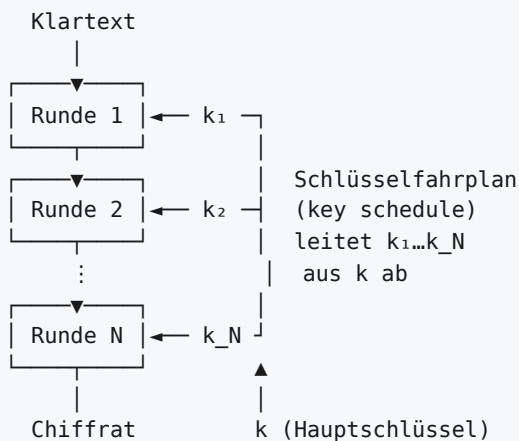
🔑 Durch die **Hintereinanderschaltung beider Operationen** kann jedoch eine **starke Chiffre** gebildet werden. Solche Algorithmen werden auch als **Produktchiffren** bezeichnet, **zu denen ALLE heutigen Blockchiffren gehören**.

Die drei Konstruktionsregeln (Folie 18) ★:

1. Eine **S-Box als ganze Chiffre** aufzubauen ist **keine gute Idee**
2. Eine **S-Box als Teil-Operation** zu verwenden dagegen schon
3. Eine **P-Box** sorgt für ein „**Verschmieren**“ bzw. „**Verstreuen**“ der Bits, damit das Ersetzen **nicht nur lokal beschränkt** bleibt, sondern sich **über das ganze Chifftrat verteilt**

🔑 **Achtung:** Diese Produktchiffren bestehen aus **sich wiederholenden Runden**, die die Eingangsdaten **nicht auf einmal, sondern sukzessiv** verschlüsseln.

🔑 **Merke:** In **jeder Runde** wird ein **anderer eigener Rundenschlüssel** k_i verwendet. Die einzelnen Rundenschlüssel werden jedoch **vom Hauptschlüssel k abgeleitet**.



29.6 Das Feistel-Netzwerk ★★★★★

Horst Feistel (IBM) — die Struktur, auf der DES basiert.

Eigenschaften (Folie 23) ★:

- **Ver- und Entschlüsselung sind fast identisch**
- Die **Entschlüsselung benötigt die Schlüsselableitung in umgekehrter Reihenfolge** → **Schlüsselfahrplan** rückwärts ($k_{16}, k_{15}, \dots, k_1$)
- **Pro Runde wird immer nur EINE Hälfte der eingehenden Bits verschlüsselt**

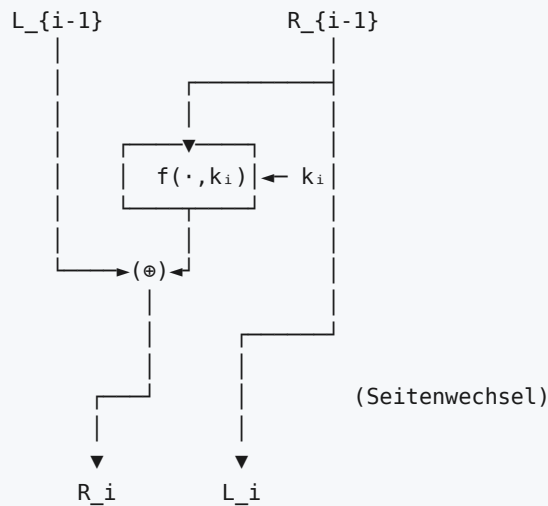
? „Welche Hälfte wird in der ersten Runde verschlüsselt?“

🔑 **Die LINKE Hälfte.**

Die Feistel-Gleichungen ★★★★★ (auswendig!):

$$L_i = R_{i-1}$$

$$R_i = L_{i-1} \oplus f(R_{i-1}, k_i)$$



🔑 **Merke:** Die **grundlegenden Eigenschaften von Chiffren, Konfusion und Diffusion**, werden **INNERHALB** der **f-Funktion** realisiert. D. h. die **eigentliche Krypto** steckt in der **f-Funktion**!

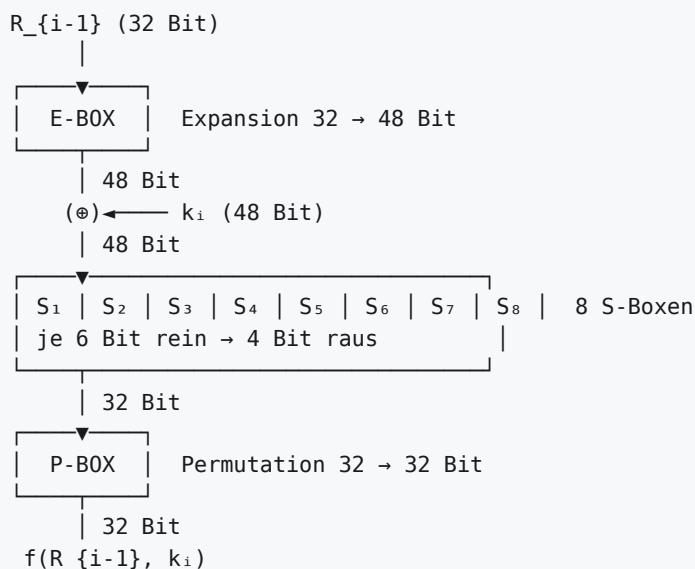
★★ **Der große Vorteil des Feistel-Netzwerks:** Die f-Funktion muss **nicht invertierbar** sein! Beim Entschlüsseln gilt:

$$R_{i-1} = L_i \quad L_{i-1} = R_i \oplus f(L_i, k_i)$$

Man braucht also nur **dieselbe** f-Funktion, nur die Rundenschlüssel in umgekehrter Reihenfolge. Das spart in Hardware die **halbe** Schaltung.

29.7 Die f-Funktion im Detail ★★★★★

Die f-Funktion des DES besteht aus **vier Stufen**:



(a) Die E-Box (Expansion) ★

? „Welchen Zweck verfolgt die E-Box?“

🔑 **Merke:** Die **E-Box erhöht die Diffusionseigenschaft von DES**, da sich **manche Eingangsbits auf ZWEI verschiedene Positionen am Ausgang auswirken**.

Funktion: 32 Bit → 48 Bit (16 Bit werden verdoppelt), damit die Breite zum 48-Bit-Rundenschlüssel passt.

(b) Die S-Boxen (Substitution) ★★★★★

🔑 **Hinweis: ALLE S-Boxen sind unterschiedlich aufgebaut.** (⚠️ Unterschied zu AES!)

Wie liest man eine S-Box-Tabelle? ★ Eingang: **6 Bit**. Ausgang: **4 Bit**.

- Die **äußeren zwei Bits** (Bit 1 und Bit 6) bestimmen die **Zeile** (0–3)
- Die **inneren vier Bits** (Bit 2–5) bestimmen die **Spalte** (0–15)

📝 Die Folie zeigt das Beispiel: $08_{10} = 1000_2 \rightarrow$ „4. Zeile, 3. Spalte“ (Zeilen-/Spalten-Index je nach Zählweise).

Die Eigenschaften der S-Boxen (Folie 64) ★★★★★:

1. **Bilden den eigentlichen kryptografischen Kern**
2. **Sind die EINZIGEN nichtlinearen Elemente** $\rightarrow S(a) \oplus S(b) \neq S(a \oplus b)$
3. **Erzeugen die Konfusion**

(c) Die P-Box (Permutation) ★

? „Welchen Zweck verfolgt die P-Box?“

- **Verwürfelung der 32 Ausgangsbits**
- **Fügt eine Diffusion in die Verschlüsselung ein**

Die zwei Wirkungen (Folie 73) ★★:

1. Die **vier Ausgabebits jeder S-Box** werden derart permutiert, dass sie **jeweils mehrere S-Boxen in der nächsten Runde beeinflussen**
2. Durch die von der **E-Box, den S-Boxen und der P-Permutation** erzeugte Diffusion wird garantiert, dass **jedes Bit am Ende der FÜNFTEN Runde eine Funktion von JEDEM Bit des Klartexts UND des Schlüssels ist**

★★ „Nach 5 Runden hängt jedes Chifftratbit von jedem Klartext- und Schlüsselbit ab“ — das ist eine sehr wahrscheinliche Klausurfrage. Merken: **DES hat 16 Runden, volle Diffusion aber schon nach 5.**

(d) Die Bedeutung der Nichtlinearität ★★★★★

🔑 **Achtung:** Die **f-Funktion** spielt **DIE zentrale Rolle für die Sicherheit des DES**. Vor allem die **Nichtlinearität der S-Boxen** sind die **wichtigsten Kernelemente**.

? „Warum ist diese Nichtlinearität so wichtig?“

🔑 **Merke:** Würde dieses nichtlineare Element fehlen, könnte ein Angreifer den Zusammenhang zwischen DES-Input und -Output durch ein **LINEARES GLEICHUNGSSYSTEM** beschreiben, bei dem die **Schlüsselbits** die zu berechnenden **Unbekannten** sind.

⚠️ **Das ist die wichtigste Einzelaussage des DES-Kapitels.** Ausformuliert: Alle anderen DES-Bausteine (E-Box, P-Box, XOR mit dem Rundenschlüssel, IP/IP⁻¹) sind **linear** über GF(2). Wären auch die S-Boxen linear, wäre der **gesamte DES** eine lineare Abbildung — und ein lineares Gleichungssystem mit 56 Unbekannten löst man mit dem Gauß-Algorithmus in Sekundenbruchteilen. **Die S-Boxen sind das Einzige, was DES überhaupt sicher macht.**

Zuordnung der Elemente (Folie 82) ★:

Element	Typ
E-Box	Diffusionselement
S-Boxen	Konfusionselement (+ einzige Nichtlinearität)
P-Box	Diffusionselement

29.8 Der Schlüsselfahrplan (Key Schedule) ★★★★★

? „Woher stammen die ganzen Unterschlüssel bzw. wie werden Rundenschlüssel $k_1 \dots k_{16}$ erzeugt?“

🔑 **Merke:** Der **Schlüsselfahrplan** leitet die einzelnen **16 Rundenschlüssel (Unterschlüssel) k_i** ab.

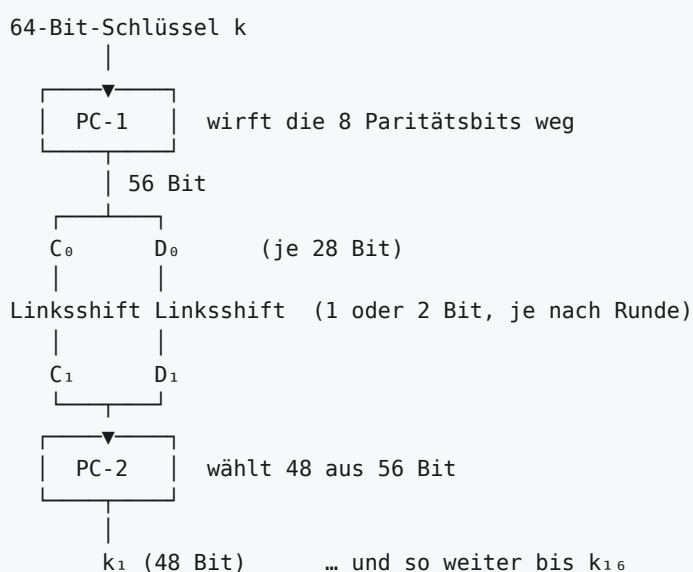
Die wichtigste Zahl des Kapitels ★★★★★

🔑 **Merke:** DES ist **KEINE 64-Bit-Chiffre**, sondern nur eine **56-BIT-Chiffre**.

⚠️ **Erklärung (unbedingt können):** Der DES-Schlüssel wird als **64 Bit** angegeben, aber **jedes 8. Bit ist ein Paritätsbit** (8 Stück insgesamt). Die Permutation **PC-1** wirft diese 8 Bits weg → **56 effektive Schlüsselbits**. Der Schlüsselraum ist damit $2^{56} \approx 7,2 \cdot 10^{16}$ — heute per Brute Force in Stunden zu durchsuchen. **Das ist der Grund, warum DES als gebrochen gilt.**

🔑 **Hinweis (PC-2):** Pro Runde werden jeweils **nur 48 Bit aus dem 56-Bit-Hauptschlüssel** verwendet.

Der Ablauf:



Warum ist PC-2 kryptographisch wichtig? ★★★★★

? „Warum ist in diesem Fall PC-2, d. h. das Permutieren, kryptographisch wichtig?“

🔑 **Erinnerung:** Sorgt wieder für eine **gleichmäßige Verteilung der Bits auf die einzelnen S-Boxen**.

? „Und wie kriegt man diese gleichmäßige Verteilung hin?“

🔑 **Merke:** Dafür sorgt das **Zusammenspiel zwischen PC-2 mit den Linksverschiebungen**.

Zusammenfassung des Schlüsselfahrplans ★★

? „Warum so kompliziert?“

1. Jeder Rundenschlüssel ist eine Auswahl von 48 Bits des Hauptschlüssels k
2. Jeder der 16 Rundenschlüssel könnte auch durch eine einzige bestimmte Permutation des Hauptschlüssels beschrieben werden
3. Der Schlüsselfahrplan ist lediglich eine Methode, die 16 Permutationen systematisch und einfach zu erzeugen → besonders in Hardware
4. So gestaltet, dass jedes der 56 Schlüsselbits in durchschnittlich 14 der 16 Runden vorkommt

★ Die Zahl „14 von 16“ ist eine typische Detailfrage. Rechnung: 16 Runden × 48 Bit = 768 verwendete Bitpositionen; $768 / 56 \approx 13,7 \approx 14$.

29.9 DES-Steckbrief ★★★

Eigenschaft	Wert
Typ	Blockchiffre, Feistel-Netzwerk, Produktchiffre
Blockgröße	64 Bit
Schlüssellänge (nominal)	64 Bit
Schlüssellänge (effektiv)	★ 56 Bit (8 Paritätsbits)
Anzahl Runden	16
Rundenschlüssellänge	48 Bit
Erfinder der Struktur	Horst Feistel (IBM)
Theoretische Basis	Claude Shannon (Konfusion/Diffusion)
Konfusionselement	8 unterschiedliche S-Boxen (6 Bit → 4 Bit), einziges nichtlineares Element
Diffusionselemente	E-Box (32→48), P-Box (32→32)
Volle Diffusion	nach 5 Runden
Schwäche	zu kurzer Schlüssel (2^{56} brute-forcebar)

30. AES — Advanced Encryption Standard (Kapitel 07) ★★★

30.1 Die Anforderungen der AES-Ausschreibung ★★

1. Blockchiffre mit 128 Bit Blockgröße
2. Unterstützung von DREI Schlüssellängen: 128, 192 und 256 Bit
3. Hohe Sicherheit relativ zu den anderen eingereichten Algorithmen
4. Effizienz in Soft- UND Hardware

30.2 AES vs. DES — der Strukturunterschied ★★★

🔑 AES besitzt KEINE Feistel-Struktur. Feistel-Netzwerke verschlüsseln pro Iteration NICHT den gesamten Block. AES verschlüsselt in JEDER Runde ALLE 128 Bits.

🔑 Hinweis: AES ist, im Gegensatz zum DES, welcher sehr viele Bitpermutationen ausnutzt, eine BYTEORIENTIERTE Struktur.

	DES	AES
Struktur	Feistel-Netzwerk	Substitutions-Permutations-Netzwerk (SPN)
Pro Runde verschlüsselt	eine Hälfte (32 von 64 Bit)	alle 128 Bit
Orientierung	bitorientiert (viele Bitpermutationen)	byteorientiert ($GF(2^8)$)
S-Boxen	8 unterschiedliche , 6→4 Bit	16 identische , 8→8 Bit
Blockgröße	64 Bit	128 Bit
Schlüssellänge	56 Bit effektiv	128 / 192 / 256 Bit
Ver-/Entschlüsselung	fast identisch	unterschiedlich (Inverse Operationen nötig)

 **Merke:** Die Anzahl der AES-Runden hängt von der Schlüssellänge ab.

30.3 Rundenanzahl und Unterschlüssel ★★★★★

Vom ursprünglichen Eingangsschlüssel (128, 192 oder 256 Bit) werden alle notwendigen Unterschlüssel abgeleitet.

★ **Die Formel:**

$$\# \text{Unterschlüssel} = \# \text{Runden} + 1$$

(das +1 kommt vom **zusätzlichen Key Whitening** vor der ersten Runde)

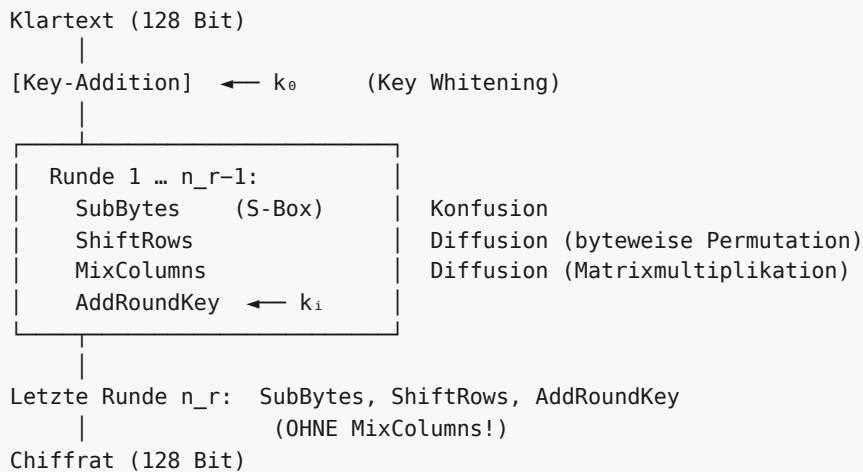
Schlüssellänge	# Runden = n _r	# Unterschlüssel
128 Bit	10	11
192 Bit	12	13
256 Bit	14	15

★ **Diese Tabelle muss man auswendig können.** Merkhilfe: 10 / 12 / 14 Runden bei 128 / 192 / 256 Bit — immer +2 Runden pro +64 Schlüsselbits.

30.4 Der Aufbau: drei Schichten ★★★★★

AES besteht aus 3 Haupt-Schichten (Layers). Jede Schicht manipuliert ALLE 128 Bits.

#	Schicht	Unterschritte	Funktion
1	Key-Addition-Schicht	AddRoundKey	XOR mit dem Rundenschlüssel
2	Byte-Substitution-Schicht (S-Box)	SubBytes	Konfusion
3	Diffusionsschicht	3.1 ShiftRows-Operation 3.2 MixColumn-Operation	Diffusion



⚠ **Die letzte Runde hat kein MixColumns** — ein klassisches Detail, das gerne abgefragt wird. Grund: Symmetrie zur Entschlüsselung; ein abschließendes MixColumns würde keine zusätzliche Sicherheit bringen, da es linear und öffentlich invertierbar ist.

30.5 Key-Addition-Schicht und Key Whitening ★★

🔑 **Merke:** VOR und NACH dem Hauptverschlüsselungsprozess kommt die Key-Addition-Schicht zum Einsatz, indem ein **Unterschlüssel aufaddiert** wird. Dieses Vorgehen wird als **Key Whitening** bezeichnet.

? „Was macht dieses Key Whitening genau?“

🔑 **Merke:** Der Begriff „Whitening“ bedeutet hier, dass die **Geheimhaltung und Komplexität des Schlüssels durch Hinzufügen weiterer Informationen erhöht** wird.

- Hinzufügen eines **zusätzlichen Schritts**, um die Sicherheit des Verschlüsselungs- algorithmus zu verbessern
- **Kombination des eigentlichen Schlüssels K mit einem weiteren, sogenannten „Whitening Key“**
- **Auswirkungen von Schlüsselangriffen zu minimieren**

★ **Warum wirkt Key Whitening?** Ohne die anfängliche Schlüsseladdition wären die ersten Operationen (SubBytes, ShiftRows) **schlüsselunabhängig** und damit für einen Angreifer frei berechenbar. Das Whitening macht schon den **Eingang** der ersten Runde geheim.

30.6 Byte-Substitution-Schicht (S-Box) ★★★

🔑 **Hinweis:** Im Gegensatz zum DES sind beim AES **ALLE 16 S-Boxen IDENTISCH**.

? „Hä, warum ist das so?“ — Die Folie erklärt die **DES-Seite**:

- Die **DES-Entwickler waren sich unsicher, ob die S-Boxen wirklich sicher sind**
- Möglichkeit einer **mathematischen Schwachstelle**
- Die **Schwäche einer S-Box sollte die anderen S-Boxen nicht betreffen**
- ➔ **Unterschiedliche S-Boxen** (bei DES)

Bei AES ist das **nicht mehr nötig**, weil die S-Box **mathematisch konstruiert und beweisbar gut** ist statt empirisch gewählt.

Die Herleitung der S-Box-Einträge ★★★

Die AES-S-Boxen haben eine **algebraische Struktur**, die **mathematisch beschrieben** werden kann.
Zweistufige mathematische Transformation:

Stufe 1: Inversion in $GF(2^m)$? „Warum macht man überhaupt die Inverse-Bildung?“

- **Momentan die beste Methode zum Schutz gegen bekannte Angriffe → differentielle Kryptanalyse**
- **Dieses Wissen hatte man bei DES noch nicht** → deshalb dort unterschiedliche S-Boxen

🔑 **Merke:** Durch die **Bildung der Inversen** erhält man einen **wirksamen Schutz gegen bekannte Angriffe**. Allerdings entstehen dadurch auch **andere potenzielle mathematische Angriffspunkte**, da die Methode eine **klare mathematische Struktur aufweist**. Aus diesem Grund wird **zusätzlich ein affiner Teil hinzugefügt** — **etwas Unstrukturiertes, das nichts mit endlichen Körpern zu tun hat** — um die bestehende mathematische Struktur zu **stören** und damit **zusätzliche Sicherheit** zu gewährleisten.

Stufe 2: Affine Abbildung in $GF(2^m)$

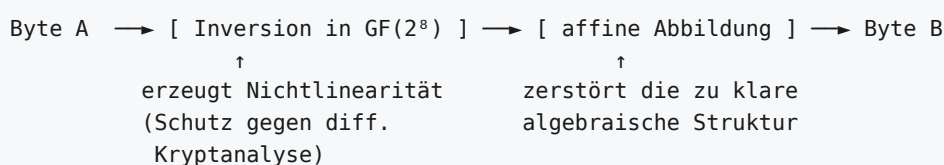
🔑 Es handelt sich um eine **stark lineare Operation (affin)** und somit um eine **1:1-Abbildung**. **Kryptographisch gesehen erhöht dies die Sicherheit NICHT direkt** — **außer nach der Inversenbildung hinzugefügt**. Damit wird die **mathematische Beschreibung zwischen A_i und B_i unbrauchbar gemacht**. Auf Bit-Ebene stellt dies kein Problem dar. Mathematisch lässt sich das jedoch nicht so beschreiben, dass daraus **ein Angriff entwickelt** werden kann.

🔑 **Merke:** In der Regel **spart man sich diese Berechnung** und arbeitet stattdessen **mit der vorberechneten Tabelle**.

? „Welchen Zweck soll durch die Inversion und die affine Abbildung erreicht werden?“

★★★ **Die Antwort (Folie 94) — auswendig:** 1. **Hohe Nichtlinearität → Schutz gegen differentielle Kryptoanalyse** 2. **Die nachgeschaltete affine Abbildung verhindert, dass die algebraische Struktur des endlichen Körpers für andere Angriffe ausgenutzt werden kann**

★ **Merkstruktur der AES-S-Box:**



30.7 Diffusionsschicht ★★★

ShiftRows

- **Permutiert die Daten byteweise** (zeilenweise zyklische Verschiebung der Zustandsmatrix)

MixColumns ★★

1. Die **MixColumn-Transformation** sorgt dafür, dass **JEDES** der **VIER Bytes** einer Spalte **ALLE** anderen Bytes der Spalte beeinflusst
 2. Die **MixColumn-Transformation** ist **DAS ausschlaggebende Diffusionselement** im AES → **Lawinen-Effekt**
- **MixColumn verwürfelt Blöcke von je vier Bytes durch Matrixmultiplikation** (in $GF(2^8)$)

🔑 **Achtung:** Durch die **Kombination aus der ShiftRows- und der MixColumn-Transformation** wird erreicht, dass **nach nur ZWEI Runden JEDES Byte der Zustandsmatrix von ALLEN 16 Bytes des Klartexts abhängt.**

★★ Vergleich der Diffusionsgeschwindigkeit — sehr beliebte Frage:

Chiffre	Volle Diffusion nach
DES	5 Runden (von 16)
AES	2 Runden (von 10/12/14)

Warum braucht AES trotzdem 10+ Runden? Weil volle Diffusion nur *notwendig*, nicht *hinreichend* ist — die zusätzlichen Runden schaffen den Sicherheitspuffer gegen differentielle und lineare Kryptanalyse.

30.8 Die AES-Zusammenfassung des Dozenten ★★★★★

Folie 108 — wörtlich, ideal als Klausurantwort:

| ❶ | **Key-Addition-Schicht** | Ein **128-Bit-Rundenschlüssel**, abgeleitet vom Hauptschlüssel, wird **per XOR auf den Zustand addiert** | | ❷ | **Byte-Substitution-Schicht (S-Box)** | **Jedes Byte des Zustands wird durch eine nichtlineare Transformation mit einer speziellen (mathematischen Eigenschaft) S-Box ersetzt**, die als **Konfusionselemente** des AES dienen | | ❸ | **Diffusionsschicht** | Diese Schicht **erzeugt Diffusion über alle Zustandsbits durch ZWEI LINEARE Operationen: ShiftRows** permutiert die Daten **byteweise**; **MixColumn** verwürfelt **Blöcke von je vier Bytes durch Matrixmultiplikation** |

⚠️ Beachte die Formulierung „**zwei LINEARE Operationen**“: ShiftRows und MixColumns sind **linear**. Die **einzige Nichtlinearität** im AES steckt — genau wie bei DES — **in der S-Box**.

30.9 AES-Steckbrief ★★★★★

Eigenschaft	Wert
Typ	Blockchiffre, SPN (kein Feistel)
Blockgröße	128 Bit (fest)
Schlüssellängen	128 / 192 / 256 Bit
Runden	10 / 12 / 14
Unterschlüssel	11 / 13 / 15 (= Runden + 1)
Orientierung	byteorientiert , rechnet in GF(2⁸)
Schichten	Key-Addition, Byte-Substitution, Diffusion (ShiftRows + MixColumns)
S-Boxen	16 identische , konstruiert aus Inversion in GF(2⁸) + affiner Abbildung
Konfusion	S-Box (einziges nichtlineares Element)
Diffusion	ShiftRows + MixColumns ; volle Diffusion nach 2 Runden
Key Whitening	ja, vor der ersten und nach der letzten Runde
Letzte Runde	ohne MixColumns

31. Betriebsmodi von Blockchiffren (Kapitel 08) ★★★★★

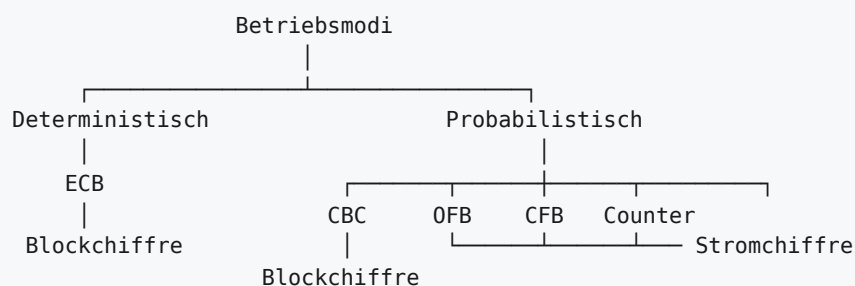
? „Wie setzt man die Blockchiffren ein?“

31.1 Die Übersicht ★★★★★

Verschlüsselungsmöglichkeiten = Betriebsmodi:

#	Modus	Abkürzung	Kategorie	Verhält sich wie
1	Electronic-Codebook-Modus	ECB	deterministisch	Blockchiffre
2	Cipher-Block-Chaining-Modus	CBC	probabilistisch	Blockchiffre
3	Output-Feedback-Modus	OFB	probabilistisch	Stromchiffre
4	Cipher-Feedback-Modus	CFB	probabilistisch	Stromchiffre
5	Counter-Modus	CTR	(siehe ⚠ unten)	Stromchiffre
6	Galois-Counter-Modus	GCM	probabilistisch + authentifiziert	Stromchiffre + MAC

Die Systematik der Folie (Folie 12):



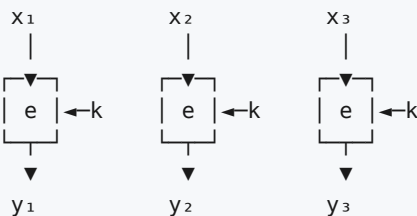
31.2 Voraussetzung: Padding ★

- Bei **ECB- und CFB-Modus** muss die **Länge des Klartexts ein genaues Vielfaches der Blockgröße** der verwendeten Chiffre sein
- Bei fehlender Länge des Klartexts wird dieser durch **Padding** erweitert → z. B. **Anhängen eines einzelnen 1-Bits gefolgt von 0-Bits** → bis die notwendige Blockgröße erreicht ist

⚠ **Die Folie nennt hier ECB und CFB.** Sachlich braucht **CBC** ebenfalls Padding, während **CFB, OFB und CTR** als Stromchiffren **kein** Padding benötigen (die Folien zu OFB, CFB und CTR nennen jeweils ausdrücklich „**Kein Padding erforderlich**“ als Vorteil). Für die Klausur: **ECB und CBC brauchen Padding; OFB, CFB und CTR nicht.** Die Padding-Methode „**1-Bit gefolgt von 0-Bits**“ heißt in der Literatur **ISO/IEC 7816-4-Padding**.

31.3 ECB — Electronic Codebook ★★★★★

Funktionsweise: Einfachste Methode. Jeder Block wird SEPARAT verschlüsselt.



$$y_i = e_k(x_i)$$

Vorteile ★:

- Einfachheit**
- Keine Synchronisation der Blöcke zwischen Sender und Empfänger notwendig** → Dechiffrierung der einzelnen Blöcke unabhängig möglich
- Bitfehler** (bei der Übertragung) **wirken sich nur auf den betroffenen Block aus**, nicht auf darauffolgende Blöcke
- Hohe Verschlüsselungsgeschwindigkeit durch Parallelisierung**

🔑 **Achtung:** Hierdurch schafft man sich **erhebliche Sicherheitsrisiken, die auf den ersten Blick nicht erkennbar** sind.

? „Warum ist das so?“

🔑 **Problem:** Die Verschlüsselung ist **deterministisch**. D. h. **identische x_i werden auf identische y_i abgebildet**.

Nachteile ★★★★★:

- Deterministisch** — identische Klartextblöcke resultieren **immer** in identischen Chiffreblöcken (bei gleichem Schlüssel)
- Angreifer kann z. B. durch **Beobachtung des Geheimtexts erkennen, ob dieselbe Nachricht zweimal gesendet wurde** → **Substitutionsangriff**
- Keine Authentifizierung**
- Keine Verdeckung von Mustern**

🔑 **Merke:** Eine Verschlüsselung ist **deterministisch**, wenn **gleiche Klartexte auf gleiche Chifftrate abgebildet** werden, **vorausgesetzt, der Schlüssel bleibt unverändert**.

🔑 **Hinweis:** Durch die deterministische Eigenschaft, dass **jeder Eingangsblock auf einen festen, bestimmten Ausgangswert abgebildet** wird, kann dieses Verfahren als **Codebuch** betrachtet werden, **woher es seinen Namen hat**.

★ **Das berühmte „ECB-Pinguin“-Beispiel:** Verschlüsselt man eine Bilddatei im ECB-Modus, bleiben die Konturen des Bildes im Chifftrat sichtbar, weil gleichfarbige Flächen zu identischen Chifftratblöcken werden. **ECB ist deshalb für strukturierte Daten praktisch unbrauchbar**.

⚠️ **Substitutionsangriff erklärt:** Ein Angreifer, der die Blockstruktur kennt (z. B. bei einer Banküberweisung: Block 1 = Absenderkonto, Block 2 = Empfängerkonto, Block 3 = Betrag), kann **Blöcke gezielt austauschen oder wiedereinspielen** — ganz ohne den Schlüssel zu kennen.

31.4 Der Ausweg: probabilistische Verschlüsselung ★★★★★

🔑 **Merke:** Ziel ist es daher, eine **PROBABILISTISCHE Verschlüsselung zu bekommen**. D. h. dass **identische Klartexte x_i zu UNTERSCHIEDLICHEN Geheimtexten y_i führen**. Um dies zu erreichen, müssen **zufällige Werte in die Verschlüsselung eingehen**, was oft in Form eines **Initialisierungsvektors (IV)** geschieht.

Formal (Folie 28) ★:

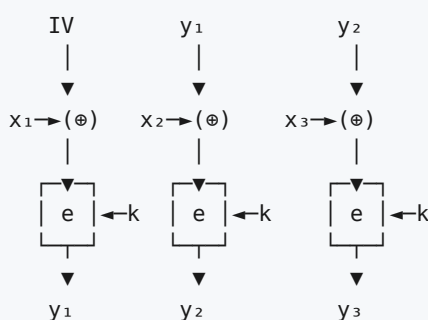
$$e_k(x_1, r_1) = y_1 \quad e_k(x_1, r_2) = y_2 \quad y_1 \neq y_2$$

Also: **Gleicher Klartext + verschiedene Zufallswerte r → verschiedene Chifftrate**.

31.5 CBC — Cipher Block Chaining ★★★★★

Funktionsweise:

- **Verkettung der Blöcke** bei der Verschlüsselung
- Der Chifftratblock y_i **hängt nicht nur vom Klartextblock x_i , sondern auch von ALLEN vorherigen Klartextblöcken ab** → Chaining-Modus
- **Randomisierung** der Verschlüsselung durch die Verwendung eines **Initialisierungsvektors (IV)**
 - **wird NICHT geheim gehalten**
 - **sollte eine Nonce (Number only used once) sein**



Formeln:

$$y_1 = e_k(x_1 \oplus IV) \qquad y_i = e_k(x_i \oplus y_{i-1})$$

$$x_1 = d_k(y_1) \oplus IV \qquad x_i = d_k(y_i) \oplus y_{i-1}$$

? „Was könnte diese Nonce (IV) sein?“

1. „Einfacher“ Zähler
2. Zufallszahl
3. Zusammensetzung: ID_A || ID_B || time

🔑 Die **Nonce selbst ist/muss nicht zufällig sein**. Sie bewirkt jedoch, dass sich das „Innere“ der Box bei der Verschlüsselung völlig anders verhält.

🔑 **Merke:** Da es für den **ersten Klartextblock x_1** **keinen vorausgehenden Chiffreblock** gibt, **übernimmt der IV diese Aufgabe**, wird aufaddiert und macht die Verschlüsselung dadurch **nichtdeterministisch**.

? „Wann ist CBC tatsächlich ein probabilistisches Verschlüsselungsschema?“

🔑 **Merke:** Wenn für JEDE neue Verschlüsselung ein **NEUER ZUFÄLLIGER IV** gewählt wird. **UND** dieser muss nicht geheim gehalten werden.

🔑 **Achtung:** Die **Sicherheit hängt von der KORREKTEN VERWENDUNG des IVs ab**. Dieser muss **für jede Nachricht zufällig und einzigartig** sein, um bestimmte Angriffe zu verhindern. D. h. die korrekte Verwendung des IV **erfordert Sorgfalt**, da eine unsachgemäße Verwendung die Sicherheit des CBC-Modus **beeinträchtigen** kann.

⚠️ **Die feine Unterscheidung, die die Folien machen:**

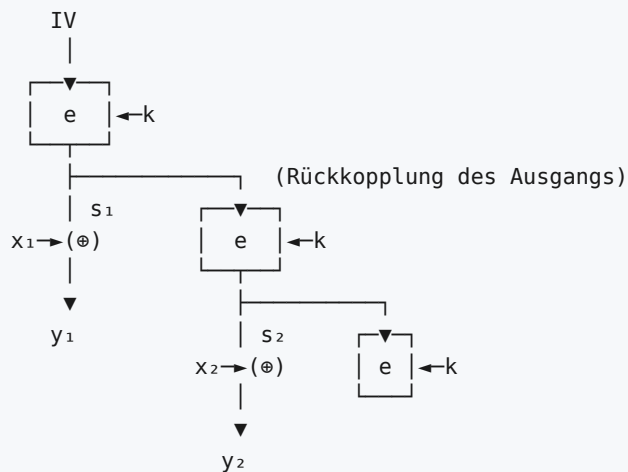
- Für **Nichtdeterminismus** genügt eine **Nonce** (einmalig, muss nicht zufällig sein)
- Für ein echt **probabilistisches Schema** braucht man einen **neuen ZUFÄLLIGEN IV** pro Nachricht

31.6 OFB — Output Feedback ★★

🔑 **Idee:** Benutze die Blockchiffre als Schlüsselstromgenerator (STG).

Funktionsweise:

- **Verwendung einer Blockchiffre zur Konstruktion einer Stromchiffre**
- **IV wird mit der Blockchiffre verschlüsselt**
- **Rückkopplung der AUSGANGSBITS auf den Eingang der Blockchiffre**



? „Worin besteht jetzt der Unterschied zum CBC-Modus?“

🔑 **Merke:** Der **Schlüsselstrom** hängt **WEDER** vom Klar- **NOCH** vom Geheimtext ab.

🔑 **Hinweis:** Da der OFB-Modus **eine Stromchiffre** ist, sind **Ver- und Entschlüsselung genau die GLEICHE Operation**. D. h., dass auf der Empfängerseite **die Blockchiffre NICHT im Entschlüsselungsmodus $e^{-1}()$ arbeiten muss**, um das Chifftrat zu entschlüsseln.

★ Sehr praktischer Vorteil: Man braucht in Hardware **nur die Verschlüsselungsrichtung** der Blockchiffre zu implementieren — spart bei AES fast die halbe Schaltung.

Vorteile:

1. **Stromchiffreigenschaften**
2. **Berechnungen der Blockchiffre sind unabhängig vom Klartext** (→ Schlüsselstrom kann **vorberechnet** werden)
3. **Kein Padding erforderlich**

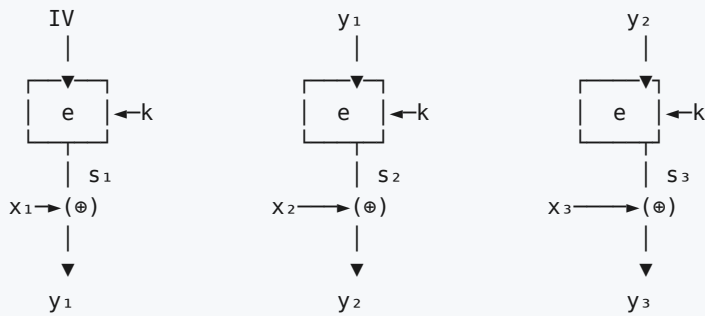
Nachteile:

1. **Keine Verschleierung von Mustern**
2. **Keine Integritätssicherung**
3. **Verlust der Synchronisation zwischen Sender und Empfänger**
4. **Potenzielles Problem bei wiederholter Nutzung des gleichen Schlüssels**

31.7 CFB — Cipher Feedback ★★

Funktionsweise:

- **Verwendung einer Blockchiffre zur Konstruktion einer Stromchiffre**
- **Verschlüsselung des IV**, um den **ersten Schlüsselstromblock s_1** zu erhalten
- Für die Schlüsselstromblöcke **$s_2, s_3, \dots$** wird **das vorhergehende CHIFFRAT** verwendet
- **Anstatt der Ausgabe der Blockchiffre (OFB) wird das CHIFFRAT auf den Eingang der Blockchiffre rückgekoppelt**



🔑 **Merke:** Durch die Verwendung des IVs ist auch die **CFB-Verschlüsselung nichtdeterministisch**.

Vorteile: 1. Stromchiffreigenschaften · 2. Kein Padding erforderlich

Nachteile: (identisch zu OFB)

1. Keine Verschleierung von Mustern
2. Keine Integritätssicherung
3. Verlust der Synchronisation zwischen Sender und Empfänger
4. Potenzielles Problem bei wiederholter Nutzung des gleichen Schlüssels

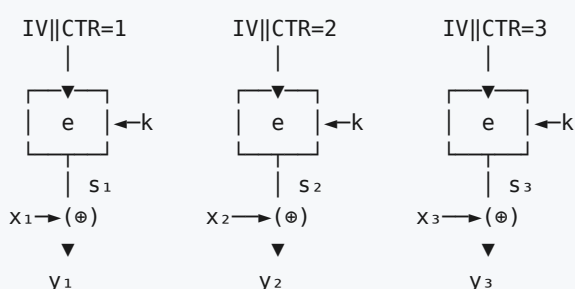
★★ **OFB vs. CFB — die Kernunterscheidung (sichere Klausurfrage):**

	OFB	CFB
Rückgekoppelt wird ...	die AUSGABE der Blockchiffre (s_i)	das CHIFFRAT (y_i)
Schlüsselstrom hängt ab von	nur k und IV	k, IV und dem Klartext (über y_i)
Vorberechenbar?	ja	nein
Bitfehler in y_i wirkt sich aus auf	nur das entsprechende Bit in x_i	das Bit + den nächsten ganzen Block

31.8 CTR — Counter Mode ★★

Funktionsweise:

- Verwendung einer Blockchiffre zur Konstruktion einer Stromchiffre
- Den Eingang der Blockchiffre bildet ein ZÄHLER



🔑 **Achtung:** Bei der Initialisierung des Eingangswerts muss verhindert werden, dass **DERSELBE Eingabewert ZWEIMAL** verwendet wird. Andernfalls kann ein Angreifer den Schlüsselstromblock berechnen, wenn er einen der beiden Klartexte kennt und damit die anderen Chiffre entschlüsseln.

⚠ **Das ist der klassische „Two-Time-Pad“-Angriff:** Werden zwei Klartexte x_1, x_2 mit demselben Schlüsselstrom s verschlüsselt, gilt

$$y_1 \oplus y_2 = (x_1 \oplus s) \oplus (x_2 \oplus s) = x_1 \oplus x_2$$

Der Schlüsselstrom fällt heraus! Kennt man einen der Klartexte, erhält man den anderen sofort. **Das ist auch der Grund, warum ein OTP-Schlüssel nur EINMAL verwendet werden darf.**

🔑 **Merke:** Der String (IV || CTR) muss **NICHT geheim gehalten werden**. CTR selbst kann entweder ein **einfacher Zähler mit natürlichen Zahlen** sein oder eine etwas komplexere Funktion wie ein **LFSR mit maximaler Länge**.

Vorteile: 1. **Stromchiffreigenschaften** · 2. **Kein Padding erforderlich** (*plus, in der Praxis entscheidend: voll parallelisierbar und wahlfreier Zugriff* — man kann Block n direkt entschlüsseln, ohne die vorherigen zu berechnen)

Nachteile (Folie 73):

1. **Deterministisch**
2. **Keine Verschleierung von Mustern**
3. **Keine Integritätssicherung**
4. **Verlust der Synchronisation zwischen Sender und Empfänger**
5. **Potenzielles Problem bei wiederholter Nutzung des gleichen Schlüssels**

⚠ **Widerspruch in den Folien beachten!** Die Übersichtsgrafik (Folie 12) ordnet den Counter-Modus den **probabilistischen** Verfahren zu; die Nachteilsliste (Folie 73) nennt ihn „**deterministisch**“. **Auflösung:** CTR ist **deterministisch bezüglich (k, IV||CTR)** — bei gleichem Zählerwert und gleichem Schlüssel kommt immer derselbe Schlüsselstrom heraus. Mit einem **frischen zufälligen IV pro Nachricht** verhält sich CTR nach außen **probabilistisch**. In der Klausur beide Aussagen kennen und den Unterschied erklären können.

31.9 GCM — Galois Counter Mode ★

Die Folien nennen GCM in der Aufzählung der sechs Betriebsmodi (Folie 13), ohne ihn im prüfungsrelevanten Foliensatz weiter auszuführen.

Was man in einem Satz sagen können sollte:

GCM = CTR-Modus + GMAC. Er kombiniert die Verschlüsselung im Counter-Modus mit einer **Authentifizierung über Multiplikation im Galois-Körper $GF(2^{128})$** . Damit ist GCM das einzige der sechs Verfahren, das **Vertraulichkeit UND Integrität/Authentizität** gleichzeitig liefert (**AEAD** = *Authenticated Encryption with Associated Data*). Genau die „**keine Integritätssicherung**“-Schwäche aller anderen Modi wird hier behoben. GCM ist der Standardmodus in **TLS 1.3**.

31.10 Vergleichstabelle aller Betriebsmodi ★★★★★

	ECB	CBC	OFB	CFB	CTR	GCM
Deterministisch?	ja ⚠	nein	nein	nein	(s. o.)	nein
IV nötig?	nein	ja	ja	ja	ja (IV CTR)	ja
Verhält sich wie	Block	Block	Strom	Strom	Strom	Strom
Padding nötig?	ja	ja	nein	nein	nein	nein
Parallel verschlüsselbar?	ja	nein (Kette)	nein	nein	ja	ja
Parallel entschlüsselbar?	ja	ja	nein	ja	ja	ja
Schlüsselstrom vorberechenbar?	—	—	ja	nein	ja	ja
Muster verdeckt?	nein ⚠	ja	ja	ja	ja	ja
Integrität?	nein	nein	nein	nein	nein	JA ★
Blockchiffre-Entschlüsselung e^{-1} nötig?	ja	ja	nein	nein	nein	nein
Fehlerfortpflanzung	1 Block	2 Blöcke	1 Bit	1 Bit + 1 Block	1 Bit	—

★ Die vier Aussagen, die in jeder Klausur zu diesem Kapitel funktionieren:

1. ECB ist deterministisch und verdeckt keine Muster → nie verwenden.
2. Alle Modi außer GCM bieten KEINE Integritätssicherung.
3. OFB, CFB, CTR machen aus einer Blockchiffre eine Stromchiffre → kein Padding.
4. Ein IV/Zähler darf NIEMALS mit demselben Schlüssel wiederverwendet werden.

32. Diffie-Hellman-Schlüsselaustausch (Kapitel 10) ★★★★★

32.1 Das Problem

🔑 Altes (bekanntes) Problem: Der Schlüssel muss auf **BEIDEN** Seiten vorhanden sein.

Genau das ist das Problem, das aus Kapitel 03 stehen geblieben ist: Kerckhoffs verlagert die Sicherheit auf den Schlüssel — aber **wie kommt der Schlüssel über einen unsicheren Kanal?**

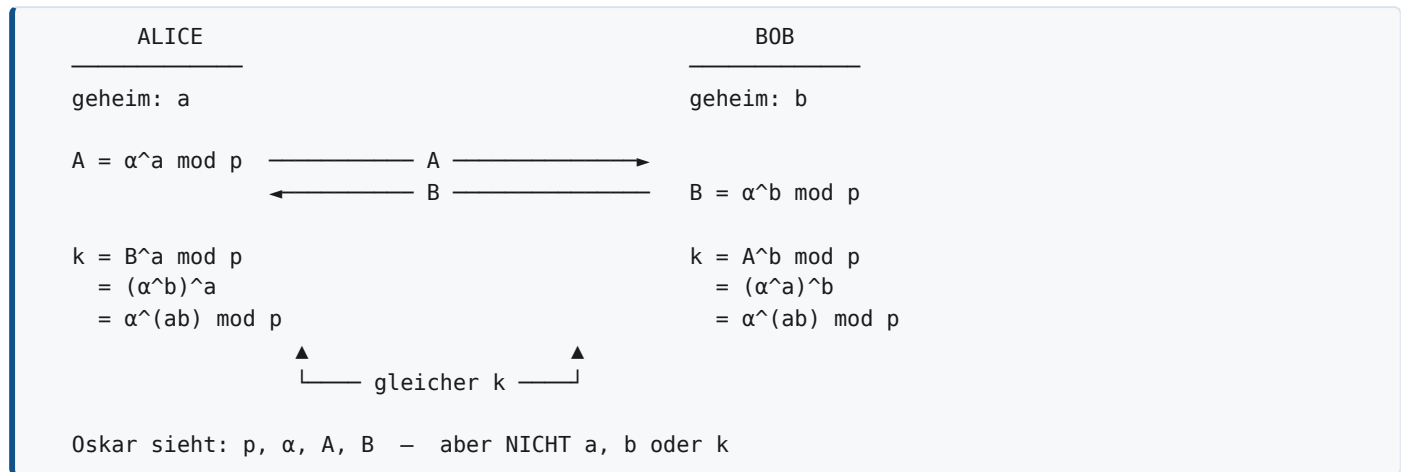
32.2 Das Protokoll ★★★★★

Set-up (öffentlich):

1. Wähle eine große Primzahl p
2. Wähle eine ganze Zahl $a \in \{2, 3, \dots, (p - 2)\}$
3. Veröffentliche p und a
4. Jeder Teilnehmer wählt einen geheimen Teil a bzw. $b \in \{2, 3, \dots, (p - 2)\}$

🔑 **Merke:** Die Parameter p und a sind **ÖFFENTLICH** und werden von **beiden Parteien zur Berechnung des gemeinsamen geheimen Schlüssels k** benutzt.

Ablauf ★★★★★:



Merke: Die **wesentliche Idee** hinter dem Diffie-Hellman-Schlüsselaustausch ist, dass *das Potenzieren in $\mathbb{Z}_p$ mit p prim eine EINWEGFUNKTION darstellt**, und dass die **Exponentiation KOMMUTATIV** ist:

$$k = (\alpha^x)^y = (\alpha^y)^x \bmod p$$

Das Beispiel der Folie: $p = 29$, $\alpha = 2$

Rechnen wir es durch (typische Klausuraufgabe):

- Alice wählt $a = 5 \rightarrow A = 2^5 \bmod 29 = 32 \bmod 29 = 3$
- Bob wählt $b = 12 \rightarrow B = 2^{12} \bmod 29$. $2^{10} = 1024 = 35 \cdot 29 + 9 \rightarrow 2^{10} \equiv 9$; $2^{12} = 9 \cdot 4 = 36 \equiv 7$
- Alice: $k = B^a = 7^5 \bmod 29$. $7^2 = 49 \equiv 20$; $7^4 \equiv 20^2 = 400 = 13 \cdot 29 + 23 \equiv 23$; $7^5 \equiv 23 \cdot 7 = 161 = 5 \cdot 29 + 16 \equiv 16$
- Bob: $k = A^b = 3^{12} \bmod 29$. $3^3 = 27$; $3^6 = 27^2 = 729 = 25 \cdot 29 + 4 \equiv 4$; $3^{12} \equiv 4^2 = 16 \checkmark$

Beide erhalten $k = 16$. ✓

32.3 Endliche Gruppen und der „Zufall“ ★

Die **Reihenfolge**, in der die **Gruppenelemente** erzeugt werden, scheint willkürlich zu sein. D. h. **man springt in der Gruppe scheinbar wahllos umher, und genau diese Zufälligkeit wird bei Kryptosystemen ausgenutzt**. D. h. **genau dieser scheinbar zufällige Zusammenhang zwischen dem Exponenten i und dem Element a der Gruppe G bildet die Basis für Kryptosysteme, die auf dem DLP basieren**.

32.4 Das Diskrete Logarithmusproblem (DLP) ★★★

„Worin besteht nun aber das DLP?“

Definition: Gegeben sind die **endliche zyklische Gruppe $\mathbb{Z}_{p^*}$** mit der **Ordnung $p - 1$** , ein **primitives Element $\alpha \in \mathbb{Z}_{p^*}$** und ein weiteres Element $\beta \in \mathbb{Z}_{p^*}$. Das **DLP besteht darin, eine ganze Zahl x im Bereich $1 \leq x \leq p - 1$ zu finden, sodass gilt:**

$$\alpha^x \equiv \beta \bmod p$$

Die Asymmetrie (Folie 51) ★★★:

Richtung	Aufwand
$\alpha^x = \beta \bmod p$ (potenzieren)	EINFACH (Square-and-Multiply, $O(\log x)$)
$x = \log_\alpha(\beta) \bmod p$ (diskreter Logarithmus)	SCHWER (kein effizienter klassischer Algorithmus bekannt)

★ **Das ist die Einwegfunktion des DHKE.** Vergleich mit RSA: Dort ist die Einwegfunktion das Faktorisierungsproblem.

⚠ **Was DHKE NICHT leistet:** Es gibt **keine Authentifizierung**. Ein aktiver Angreifer kann einen **Man-in-the-Middle-Angriff** durchführen: Er tauscht getrennt mit Alice und mit Bob je einen Schlüssel aus und leitet alles um. Deshalb wird DHKE in der Praxis **immer mit Signaturen/Zertifikaten kombiniert** (z. B. in TLS: „ECDHE_RSA“). Das ist eine sehr wahrscheinliche Verständnisfrage.

33. RSA (Kapitel 11) ★★★★★

33.1 Die Hauptanwendung ★

🔑 **Merke:** Die **Hauptanwendung der RSA-Verschlüsselung liegt im sicheren Austausch eines Schlüssels (Schlüsseltransport)**, welcher dann **für eine symmetrische Chiffre** verwendet wird.

★ **Das ist eine wichtige Aussage:** RSA wird in der Praxis **nicht** dazu benutzt, große Datenmengen zu verschlüsseln (viel zu langsam, ca. Faktor 1000 gegenüber AES), sondern um einen **AES-Sitzungsschlüssel** zu transportieren. Das nennt man **hybride Verschlüsselung** — und genau so funktioniert auch **TOR** (siehe Kapitel 13).

33.2 Ver- und Entschlüsselung ★★★★★

	Formel
Verschlüsselung	$y = e_{k_{pub}}(x) \equiv x^e \bmod n \quad x, y \in \mathbb{Z}_n$
Entschlüsselung	$x = d_{k_{pri}}(y) \equiv y^d \bmod n \quad x, y \in \mathbb{Z}_n$

🔑 **Hinweis:** **e** wird auch als **Verschlüsselungsexponent** oder **öffentlicher Exponent** bezeichnet, und der private Schlüssel **d** als **Entschlüsselungsexponent** oder **privater Exponent**.

Schlüssel	Bestandteile	Wer kennt ihn?
k_pub (öffentlich)	(n, e)	jeder
k_pri (privat)	d (und p, q, $\phi(n)$)	nur der Besitzer

33.3 Schlüsselerzeugung ★★★★★

Alle asymmetrischen Verfahren haben eine **Initialisierungsphase**, die auch als **Set-up-Phase** bezeichnet wird, in der das **Schlüsselpaar**, bestehend aus dem **öffentlichen und privaten Schlüssel**, berechnet wird.

Die fünf Schritte (auswendig!) ★★★★★:

Schritt	Aktion
1	Wähle zwei große Primzahlen p und q
2	Berechne: $n = p \cdot q$
3	Berechne: $\phi(n) = (p - 1) \cdot (q - 1)$
4	Wähle den öffentlichen Exponenten $e \in \{1, 2, \dots, \phi(n) - 1\}$, sodass gilt: $\text{ggT}(e, \phi(n)) = 1$
5	Berechne den privaten Schlüssel d , sodass gilt: $d \cdot e \equiv 1 \pmod{\phi(n)}$

🔑 **Achtung:** Die Bedingung $\text{ggT}(e, \phi(n)) = 1$ stellt sicher, dass **die Inverse von e existiert** und es damit **auch den privaten Schlüssel d gibt**.

★ Man sieht hier wieder die **zentrale Merkregel aus Kapitel 04**: $\text{ggT}(a, m) = 1 \Leftrightarrow a^{-1} \pmod{m}$ existiert. Bei RSA ist $a = e$ und $m = \phi(n)$.

📝 Vollständiges Rechenbeispiel (typische Klausuraufgabe):

Schritt	Rechnung
1	$p = 3, q = 11$
2	$n = 3 \cdot 11 = 33$
3	$\phi(n) = (3-1)(11-1) = 2 \cdot 10 = 20$
4	$e = 3$, denn $\text{ggT}(3, 20) = 1 \checkmark$
5	d mit $3d \equiv 1 \pmod{20} \rightarrow d = 7$, denn $3 \cdot 7 = 21 = 20 + 1 \equiv 1 \checkmark$

Öffentlicher Schlüssel: $(n, e) = (33, 3)$ · **Privater Schlüssel:** $d = 7$

Verschlüsseln von $x = 4$: $y = 4^3 \pmod{33} = 64 \pmod{33} = 31$

Entschlüsseln: $x = 31^7 \pmod{33}$. Schrittweise: $31 \equiv -2 \pmod{33} \rightarrow (-2)^7 = -128$; $-128 \pmod{33}$: $-128 + 4 \cdot 33 = -128 + 132 = 4 \checkmark$

33.4 Sicherheit von RSA ★★★★★

? „Auf welcher Sicherheit beruht RSA?“

🔑 **Merke:** Die Sicherheit beruht auf dem **FAKTORISIERUNGSPROBLEM ganzer Zahlen**, was die **Einwegfunktion** darstellt.

? „Was ist nun dieses Faktorisierungsproblem genau?“

🔑 **Hinweis 1:** Die **Multiplikation zweier großer Primzahlen ist rechnerisch einfach** durchzuführen. Hingegen ist der **umgekehrte Prozess der Faktorisierung** des resultierenden Produkts zurück in seine zwei Primfaktoren **sehr schwierig**.

$$p \cdot q = n \quad (\text{einfach}) \qquad n \rightarrow (p, q) \quad (\text{schwer})$$

🔑 **Hinweis 2:** Da ein Angreifer **auch auf den öffentlichen Schlüssel zugreifen kann**, muss es **rechnerisch unmöglich sein, den privaten Schlüssel d mit den gegebenen öffentlichen Parametern e und n zu berechnen**. Hierzu haben die notwendigen Parameter eine **Größe von mindestens 1024 Bit**.

⚠ **Warum wäre die Faktorisierung fatal?** Wer n in p und q zerlegen kann, berechnet sofort $\phi(n) = (p-1)(q-1)$ und daraus $d = e^{-1} \bmod \phi(n)$. **Faktorisierung von n = Bruch von RSA.**

⚠ **Zur Schlüssellänge:** Die Folie nennt **mindestens 1024 Bit**. Aktuelle Empfehlungen (BSI TR-02102-1) liegen bei ≥ 3000 Bit für RSA; 1024 Bit gilt heute als **unsicher**. In der Klausur die Folienzahl nennen und den aktuellen Stand als Ergänzung erwähnen.

🔑 **Merke:** Aufgrund von Hinweis 1 und 2 sollte für ein gegebenes n **sehr viele Schlüsselpaare existieren**, da andernfalls ein **Brute-Force-Angriff** durchgeführt werden könnte.

🔑 **Wichtig:** Neben dem Faktorisierungsproblem versteckt sich auch das **DLP im RSA**. Siehe hierzu die Gleichung zur Ver- und Entschlüsselung.

★ **Erläuterung dieser letzten Aussage** (beliebte Verständnisfrage): In $y \equiv x^e \bmod n$ ist der Angreifer, der aus dem bekannten Chiffre y und dem bekannten Exponenten e auf x schließen will, mit einem **modularen Wurzelproblem** konfrontiert; kennt er umgekehrt x und y und sucht e , steht er vor einem **diskreten Logarithmus** modulo n . Beide Richtungen sind ohne Kenntnis der Faktorisierung hart.

33.5 RSA vs. DHKE — Gegenüberstellung ★★

	DHKE	RSA
Zweck	Schlüsselvereinbarung (beide erzeugen gemeinsam k)	Verschlüsselung / Schlüsseltransport (einer wählt k und sendet ihn)
Mathematisches Problem	DLP — diskreter Logarithmus	Faktorisierungsproblem (+ DLP-Anteil)
Öffentliche Parameter	$p, \alpha, A = \alpha^a, B = \alpha^b$	n, e
Geheim	a, b	d (und $p, q, \phi(n)$)
Einwegfunktion	Potenzieren in $\mathbb{Z}^*_p$	Multiplikation von Primzahlen
Signaturen möglich?	nicht direkt (dafür DSA/ECDSA)	ja
Man-in-the-Middle	anfällig ohne Authentifizierung	anfällig ohne Zertifikat (PKI nötig)

34. Hash-Funktionen (Kapitel 13) ★★★

34.1 Grundlagen ★

Hash-Funktionen berechnen aus einer gegebenen Nachricht eine Bitfolge mit Fester Länge. → Repräsentant der Nachricht Hash-Wert = Fingerabdruck der Nachricht ★ Hash-Funktionen haben **KEINEN** Schlüssel

Einsatzmöglichkeiten:

- Digitale Signaturen
- Prüfsummen (MAC)
- Schlüsselableitung

⚠ **Wichtige Abgrenzung:** Eine **Hash-Funktion $h(x)$** hat **keinen Schlüssel**. Ein **MAC** hat einen Schlüssel (MAC = Hash + Schlüssel, z. B. HMAC). Deshalb liefert ein Hash allein **keine Authentizität** — jeder kann ihn neu berechnen.

🔑 **Merke:** Hash-Funktionen ver- oder entschlüsseln Daten NICHT.

34.2 Das Motivationsproblem: Signieren langer Nachrichten ★★

🔑 **Erinnerung:** Digitale Signaturen nutzen entweder das RSA-Verfahren oder das Diskrete Logarithmus-Problem (DLP) als Grundlage. Bei **beiden Verfahren** ist die **Größe des Klartexts**, der signiert werden kann, **BESCHRÄNKT**.

? „Wie kann man effizient Signaturen für lange Nachrichten berechnen?“

Der naive Ansatz:

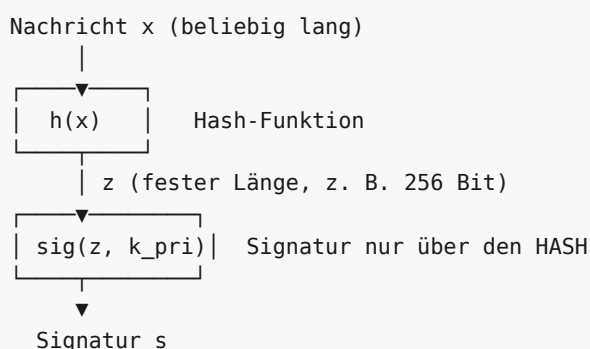
1. Unterteile die Nachricht x in Blöcke x_i
2. x_i darf nicht länger sein als die Eingangslänge des Signaturverfahrens
3. Signiere jeden Block x_i einzeln

? „Welche Probleme könnten sich bei diesem Ansatz ergeben?“

Die drei Probleme (Folie 7) ★★★:

#	Problem	Erläuterung
1	Hoher Rechenaufwand	Digitale Signaturen = asymmetrische Algorithmen = rechenintensiv
2	Nachrichten-Overhead	Verdoppelt die Bitlänge der Übertragung , da sowohl die Nachricht als auch die gleich lange Signatur gesendet werden muss
3	Sicherheitsprobleme	Möglichkeit, Nachrichten und Signaturen umzuordnen oder zu entfernen

🔑 **Idee:** Erzeugung einer **EINZELNEN KURZEN** Signatur für eine Nachricht **BELIEBIGER LÄNGE**, indem mittels einer Hash-Funktion ein **Fingerabdruck der Nachricht** erstellt wird.



🔑 **Merke:** Sowohl die Signaturerstellung als auch die Verifikation verwenden den **HASH-WERT z** als Eingang und **NICHT** die eigentliche Nachricht. D. h. der Hash-Wert repräsentiert die **Nachricht selbst** und wird daher auch als **Fingerabdruck** bezeichnet.

34.3 Frage 1: Eingang-Ausgang-Verhalten ★★★★★

Welches Eingang-Ausgang-Verhalten sollte eine Hash-Funktion aufweisen?

1. Sollte sehr schnell zu berechnen sein
2. Der Ausgangswert soll, unabhängig von der Länge des Eingangs, eine FESTE Länge haben
3. Der Fingerabdruck soll von ALLEN Eingangsbits abhängen
4. Kleine Änderungen im Eingangswert sollen zu einem VOLLSTÄNDIG UNTERSCHIEDLICHEN Fingerabdruck führen

★ Punkt 4 ist wieder der **Avalanche-Effekt** aus dem DES-Kapitel — und genau der Grund, warum Hash-Werte in der **Pyramid of Pain** der schwächste IOC sind.

34.4 Frage 2: Die drei Sicherheitseigenschaften ★★★★★

Drei zentrale Eigenschaften, die für die Sicherheit von Hash-Funktionen entscheidend sind:

#	Deutsch	Englisch
1	Urbildresistenz (Einwegeigenschaft)	Preimage resistance (One-wayness)
2	Schwache Kollisionsresistenz (zweite Urbildresistenz)	Second preimage resistance (Weak collision resistance)
3	Starke Kollisionsresistenz (Kollisionsresistenz)	Collision resistance (Strong collision resistance)

(1) Einwegeigenschaft / Urbildresistenz ★

- Hash-Funktion muss eine Einwegfunktion sein
- Es muss **rechentechnisch unmöglich** sein, aus einem gegebenen Hash-Wert z den Eingangswert x mit $z = h(x)$ zu berechnen

Gegeben: z . **Gesucht:** x mit $h(x) = z$. → **muss unmöglich sein**

(2) Schwache Kollisionsresistenz ★★

- Zwei unterschiedliche Nachrichten dürfen nicht den gleichen Hash-Wert besitzen
- Es muss rechentechnisch unmöglich sein, zwei unterschiedliche Nachrichten $x_1 \neq x_2$ mit gleichem Hash-Wert $z_1 = h(x_1) = h(x_2) = z_2$ zu erzeugen
- ★ x_1 IST GEGEBEN, und man versucht, ein (passendes) x_2 zu finden

Gegeben: x_1 . **Gesucht:** $x_2 \neq x_1$ mit $h(x_2) = h(x_1)$. → **ein Freiheitsgrad**

🔑 **Achtung:** Wenn ein Angreifer in der Lage ist, eine zweite Nachricht mit dem gleichen Fingerabdruck (d. h. dem gleichen Hash-Wert) zu finden, hat diese den GLEICHEN Signatur- und Verifikationswert wie die erste Nachricht.

⚠ **Das ist der Angriff:** Alice signiert „Ich schulde Bob 100 €“. Findet Bob eine zweite Nachricht „Ich schulde Bob 100 000 €“ mit demselben Hash, ist Alices Signatur **auch für die zweite Nachricht gültig**.

Warum schwache Kollisionen unvermeidbar sind ★★★★★

🔑 Idealerweise hätte man gerne eine Hash-Funktion, bei der schwache Kollisionen **gar nicht auftreten können**.

🔑 **Leider ist dies NICHT möglich**, da **jede Hash-Funktion eine FESTE Ausgangslänge von n Bit** hat. Das bedeutet, dass es **genau 2^n mögliche Ausgangswerte** gibt. Da es jedoch **UNENDLICH viele mögliche Eingangswerte** gibt, müssen **zwangsläufig mehrere unterschiedliche Eingangswerte denselben Ausgangswert erzeugen**.

★ **Das ist das Schubfachprinzip (Taubenschlagprinzip / pigeonhole principle).**

🔑 D. h. **jeder Ausgangswert ist für einen zufälligen Eingangswert gleich wahrscheinlich**, sodass eine **schwache Kollision für alle Ausgangswerte immer existiert**.

🔑 **Idee:** Da **schwache Kollisionen IMMER existieren**, muss man dafür sorgen, dass sie **in der PRAXIS nicht erzeugt werden können**.

★★ **Sehr gute Klausurantwort:** „Kollisionen existieren mathematisch zwangsläufig (Schubfachprinzip: endlich viele Ausgänge, unendlich viele Eingänge). Sicherheit bedeutet deshalb nicht ihre Nichtexistenz, sondern ihre praktische Unauffindbarkeit.“

(3) **Starke Kollisionsresistenz** ★★

- **Zwei unterschiedliche Nachrichten dürfen nicht den gleichen Hash-Wert besitzen**
- Es muss rechentechisch unmöglich sein, $x_1 \neq x_2$ mit $z_1 = h(x_1) = h(x_2) = z_2$ zu erzeugen
- ★ **SOWOHL x_1 ALS AUCH x_2 können FREI GEWÄHLT werden**

Gegeben: nichts. **Gesucht:** irgendein Paar (x_1, x_2) mit gleichem Hash. → **zwei Freiheitsgrade**

🔑 **Merke:** Diese Bedingung zu erfüllen ist **deutlich SCHWERER als die schwache Kollisionsresistenz**, da ein Angreifer in diesem Fall **mit x_1 und x_2 ZWEI Freiheitsgrade** hat.

⚠️ Die zentrale Verwechslungsgefahr ★★★★★

	Schwache Kollisionsresistenz	Starke Kollisionsresistenz
Auch genannt	2. Urbildresistenz, <i>second preimage resistance</i>	Kollisionsresistenz, <i>collision resistance</i>
x_1 ist ...	vorgegeben	frei wählbar
Freiheitsgrade des Angreifers	1	2
Schwerer zu brechen für den Angreifer	schwerer (die Eigenschaft ist leichter zu erfüllen)	leichter (die Eigenschaft ist schwerer zu erfüllen)
Aufwand für den Angriff	2^n	$2^{(n/2)}$ (Geburtstagsparadoxon)

⚠️ **Die Namensfalle:** *Schwach* und *stark* beziehen sich auf die **Anforderung an die Hash-Funktion**, nicht auf die Stärke des Angreifers. **Starke Kollisionsresistenz ist die stärkere Forderung** — sie zu brechen ist für den Angreifer **einfacher**. Merksatz: **Starke Kollisionsresistenz $\Rightarrow$ schwache Kollisionsresistenz** (aber nicht umgekehrt).

34.5 Das Geburtstagsparadoxon ★★★★★

🔑 Daraus lässt sich grob folgern, dass die **Anzahl der zu hashenden Nachrichten, die für eine Kollision erforderlich sind**, näherungsweise ist:

$$\sqrt{2^n} = 2^{\frac{n}{2}}$$

🔑 **Merke:** 2^{40} Hashwerte können heutzutage leicht durchprobiert werden. Aus diesem Grund haben **alle Hash-Funktionen mindestens eine Ausgangsbreite von mindestens 128 Bit.**

★ **Das Geburtstagsparadoxon erklärt:** In einer Gruppe von nur **23 Personen** liegt die Wahrscheinlichkeit, dass **zwei beliebige** denselben Geburtstag haben, bereits über **50 %** — obwohl es 365 Tage gibt. Der Grund: Es gibt $(23 \cdot 22)/2 = 253$ **Paare**, nicht 23 Vergleiche.

Übertragen auf Hashes: Bei n Ausgangsbits braucht man nur $\sim 2^{(n/2)}$ Versuche für eine **beliebige** Kollision statt 2^n .

Hash-Länge n	Aufwand 2. Urbild (2^n)	Aufwand Kollision ($2^{(n/2)}$)	Bewertung
64 Bit	2^{64}	$2^{32} \approx 4,3$ Mrd.	trivial brechbar
80 Bit	2^{80}	$2^{40} \approx 1,1$ Bio.	★ „leicht durchprobierbar“ (Folie)
128 Bit	2^{128}	2^{64}	Mindestmaß laut Folie
160 Bit (SHA-1)	2^{160}	2^{80}	praktisch gebrochen (2017: SHAttered)
256 Bit (SHA-256)	2^{256}	2^{128}	sicher

★★ **Die Merkregel:** Für ein Sicherheitsniveau von s Bit gegen **Kollisionen** braucht man eine Hash-Länge von $n = 2s$ Bit. Deshalb bietet SHA-256 „nur“ **128 Bit Kollisionssicherheit**.

📝 **Typische Klausuraufgabe:** „Wie viele Nachrichten muss man im Mittel hashen, um bei einer 160-Bit-Hash-Funktion eine Kollision zu finden?“ $\rightarrow 2^{(160/2)} = 2^{80} \approx 1,2 \cdot 10^{24}$

34.6 Die 6 Eigenschaften einer Hash-Funktion ★★★★★

Die Zusammenfassung der Folien 79/82 — DIE Aufzählung des Kapitels:

#	Eigenschaft	Definition (wörtlich)
1	Beliebige Eingangslänge	Eine Hash-Funktion $h(x)$ kann Nachrichten x beliebiger Länge verarbeiten
2	Feste Ausgangslänge	Eine Hash-Funktion $h(x)$ erzeugt Hash-Werte z fester Länge
3	Effizienz	Eine Hash-Funktion $h(x)$ kann einfach berechnet werden
4	Einwegeigenschaft	Es ist rechnerisch unmöglich , für einen gegebenen Ausgangswert z einen Eingangswert x zu finden, sodass $h(x) = z$ gilt — d. h. $h(x)$ ist eine Einwegfunktion
5	Schwache Kollisionsresistenz	Für einen GEGEBENEN Eingangswert x_1 ist es rechentechnisch unmöglich, einen zweiten Wert x_2 zu finden , sodass $h(x_1) = h(x_2)$ gilt
6	Starke Kollisionsresistenz	Es ist rechentechnisch unmöglich, ZWEI Eingangswerte $x_1 \neq x_2$ zu finden , sodass $h(x_1) = h(x_2)$ gilt

★ **Merkstruktur:** Die ersten **drei** Eigenschaften (1–3) sind **funktionale** Anforderungen, die letzten **drei** (4–6) sind **Sicherheitsanforderungen**.

35. TOR — The Onion Router (Kapitel TOR) ★★★★★

35.1 Was ist TOR? ★

TOR-Netzwerk:

- **Dezentrales Netzwerk von Servern**, das die **Internetverbindung eines Nutzers anonymisiert** → **Nodes oder Relays**
- **Datenverkehr wird über mehrere, weltweit verteilte Knotenpunkte geleitet**

TOR-Browser:

- **Angepasste Version des Firefox-Browsers**
- **Standardmäßig so konfiguriert, dass er das TOR-Netzwerk verwendet**

? „Was bietet mir TOR?“

- **Anonymität und Schutz der Privatsphäre**
- **Schutz vor Tracking und Überwachung**
- **Zugang zu zensierten Inhalten**

 **Merke:** Das TOR-Netzwerk und der TOR-Browser **fördern Privatsphäre und Anonymität im Internet**, ermöglichen **anonymes Surfen** und den **Zugang zu speziellen .onion-Seiten**, die **nur über das TOR-Netzwerk erreichbar** sind.

 **Merke:** Im Wesentlichen verwendet TOR eine **MEHRSCICHTIGE Verschlüsselung**, um die Kommunikation zwischen dem Nutzer und dem Zielsystem zu schützen.

★ Der Name kommt von der **Zwiebel (onion)**: Die Nachricht wird in mehrere Verschlüsselungsschichten eingepackt, und jeder Knoten schält genau **eine** Schicht ab.

35.2 Wie funktioniert das TOR-Netzwerk? — Die 5 Schritte ★★★★★

#	Schritt
1	Verbindung zum TOR-Netzwerk
2	Datenweiterleitung über Relays
3	Verbindung zum Austrittsknoten
4	Verschlüsselungsschichten
5	Zugriff auf die Zielseite

Schritt 1: Verbindung zum TOR-Netzwerk ★

- Der TOR-Browser verbindet sich zunächst mit einem **Einstiegsknoten** → **Entry Node (Guard Node)**
- ★ **Der Einstiegsknoten kennt die IP-Adresse des Nutzers, ABER NICHT das Ziel der Verbindung**

Schritt 2: Datenweiterleitung über Relays ★

- Der Einstiegsknoten leitet die Daten an einen **Mittelknoten** weiter → **Middle Node**
- ★ **Der Mittelknoten kennt WEDER die IP-Adresse des Nutzers NOCH die Zieladresse**
- Der Mittelknoten **dient nur als Zwischenstation**

Schritt 3: Verbindung zum Austrittsknoten ★

- Der Mittelknoten leitet die Daten an einen **Austrittsknoten** weiter → **Exit Node**
- ★ **Der Austrittsknoten kennt NUR das Ziel der Verbindung** (z. B. die Webseite)
- ★ **Der Austrittsknoten kennt NICHT die ursprüngliche IP-Adresse des Nutzers**

Schritt 4: Verschlüsselungsschichten ★

- Jede Station (Node) entschlüsselt NUR die Schicht, die für sie bestimmt ist
- Jede Station erhält dadurch die Adresse der nächsten Station
- Das vollständige Ziel bleibt bis zum Austrittsknoten unbekannt

Schritt 5: Zugriff auf die Zielseite ★

- Der Austrittsknoten stellt die Anfrage an die Zielseite
- Der Austrittsknoten sendet die Antwort über DIESELBEN Knoten zurück an den Nutzer

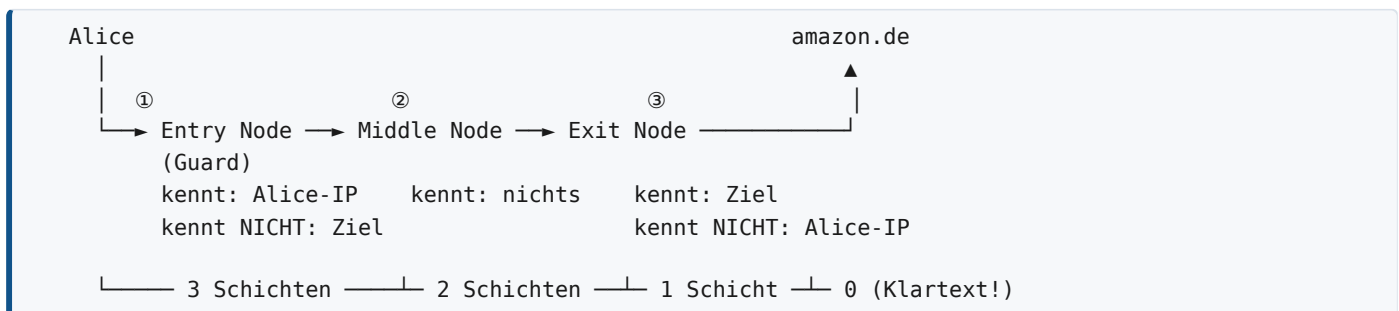
35.3 Die Wissensverteilung — die zentrale Tabelle ★★★

Das ist **die** Klausurfrage zu TOR.

Knoten	Kennt die IP des Nutzers?	Kennt das Ziel?
Entry Node (Guard Node)	✓ JA	✗ NEIN
Middle Node	✗ NEIN	✗ NEIN
Exit Node	✗ NEIN	✓ JA

★★ Das Anonymitätsprinzip in einem Satz:

Kein einzelner Knoten kennt gleichzeitig Absender UND Ziel. Nur wer **Entry- und Exit-Node gleichzeitig kontrolliert** (oder deren Verkehr korrelieren kann), kann die Verbindung deanonymisieren.



!!! Wichtig: Zwischen **Exit Node und Zielserver** ist der Verkehr **NICHT mehr von TOR verschlüsselt!** Der Exit Node sieht den **Klartext**, sofern nicht zusätzlich **HTTPS/TLS** verwendet wird. Das ist die bekannteste TOR-Schwachstelle („*malicious exit node*“). Die Folie sagt es explizit: „**R3 sendet die entschlüsselte Nachricht M an das Ziel im OFFENEN Internet.**“

35.4 Schlüsselaustausch im TOR-Netzwerk ★★★

? „Wie tauscht der Browser die Verschlüsselungsschlüssel mit den Nodes aus?“

🔑 Merke: Die **Schlüsselverwaltung im TOR-Netzwerk basiert auf einem ASYMMETRISCHEN Verschlüsselungssystem**, das sicherstellt, dass die Kommunikation zwischen dem Nutzer und den Nodes vollständig verschlüsselt ist.

Die Mechanik ★★:

- TOR verwendet eine **KOMBINATION** aus **RSA (Schlüsselaustausch)** und **AES (eigentliche Datenverschlüsselung)**, indem es einen **Sitzungsschlüssel** verwendet
- Jeder Node im TOR-Netzwerk besitzt dafür ein **Schlüsselpaar**
- Der öffentliche Schlüssel ist im **KONSENSUS-DOKUMENT** gespeichert, das der Browser herunterlädt

🔑 **Merke:** Jeder Node im Netzwerk entfernt **NUR** die (verschlüsselte) Schicht, die für ihn bestimmt ist, bevor er das Paket weiterleitet.

🔑 **Wichtig:** Das TOR-Netzwerk verwendet **RSA NUR für den sicheren Austausch der SITZUNGSSCHLÜSSEL** zwischen dem TOR-Browser und den Nodes. Die **eigentliche Datenverschlüsselung im Circuit erfolgt anschließend mit diesen Schlüsseln mithilfe eines SYMMETRISCHEN Algorithmus wie AES.**

⚠️⚠️ Prof. Inan korrigiert hier ausdrücklich eine verbreitete Fehlvorstellung:

Manche veraltete Quellen behaupten, dass **Public/Private Keys ZWISCHEN** den Nodes genutzt werden. Das trifft jedoch **NUR** auf die **Schlüsselvereinbarung beim Circuit-Aufbau** zu. Der **RÜCKWEG** verwendet **AUSSCHLIESSLICH** die **Sitzungsschlüssel (K_1, K_2, K_3)** und **KEINE** asymmetrische Verschlüsselung.

★ Das ist die **hybride Verschlüsselung** aus dem RSA-Kapitel in Reinform: **asymmetrisch für den Schlüsseltransport, symmetrisch für die Nutzdaten.**

35.5 Die Mathematik des Onion Routing ★★★

Definitionen (Folie 43):

Symbol	Bedeutung
M	die ursprüngliche Nachricht
R_1	Entry Node
R_2	Middle Node
R_3	Exit Node
K_1	Sitzungsschlüssel zwischen Client und R_1
K_2	Sitzungsschlüssel zwischen Client und R_2
K_3	Sitzungsschlüssel zwischen Client und R_3
$E_K(M)$	Verschlüsselungsfunktion, die M mit Schlüssel K verschlüsselt
$D_K(C)$	Entschlüsselungsfunktion mit $D_K(E_K(M)) = M$

Verschlüsselung beim Client (Hinweg) ★★★

Der Client verschachtelt die Verschlüsselung für **JEDES Relay, BEGINNEND MIT R_3 :**

Schicht	Formel
1. Innere Schicht (für R_3)	$C_3 = E_{K_3}(M)$
2. Mittlere Schicht (für R_2)	$C_2 = E_{K_2}(C_3) = E_{K_2}(E_{K_3}(M))$
3. Äußere Schicht (für R_1)	$C_1 = E_{K_1}(C_2) = E_{K_1}(E_{K_2}(E_{K_3}(M)))$

Die verschlüsselte Nachricht C_1 wird an R_1 gesendet.

⚠ **Merken:** Der Client verschlüsselt VON INNEN NACH AUSSEN, beginnend beim Exit Node R_3 .

Entschlüsselung auf dem Hinweg ★★★★★

Jedes Relay entfernt SEINE EIGENE Schicht der Verschlüsselung:

Relay	Formel
R_1 (Entry Node)	$C_2 = D_{K_1}(C_1) = D_{K_1}(E_{K_1}(E_{K_2}(E_{K_3}(M)))) = E_{K_2}(E_{K_3}(M))$
R_2 (Middle Node)	$C_3 = D_{K_2}(C_2) = D_{K_2}(E_{K_2}(E_{K_3}(M))) = E_{K_3}(M)$
R_3 (Exit Node)	$M = D_{K_3}(C_3) = D_{K_3}(E_{K_3}(M))$

⚠ R_3 sendet die entschlüsselte Nachricht M an das Ziel im OFFENEN INTERNET.

Zusammenfassung der Mathematik ★★★★★

Hinweg:

$$C_1 = E_{K_1}(E_{K_2}(E_{K_3}(M))) \longrightarrow M = D_{K_3}(D_{K_2}(D_{K_1}(C_1)))$$

Rückweg:

$$C'_1 = E_{K_1}(E_{K_2}(E_{K_3}(M'))) \longrightarrow M' = D_{K_3}(D_{K_2}(D_{K_1}(C'_1)))$$

(Der Client entschlüsselt.)

🔑 Die **Sicherheit besteht primär darin, dass JEDE Station NUR IHREN TEIL der Verschlüsselungsschichten kennt.** Dadurch **bleibt die Nachricht selbst für kompromittierte Nodes geheim.**

35.6 Der Rückweg ★★

🔑 **Erinnerung:** Beim **Aufbau des TOR-Circuits** generiert der TOR-Browser **für JEDEN Knoten (Entry, Middle und Exit Node) einen EIGENEN Sitzungsschlüssel.** Das bedeutet:

1. Jeder Knoten besitzt seinen eigenen sicheren Sitzungsschlüssel, der vom Browser generiert wurde
2. Diese Sitzungsschlüssel gelten SOWOHL für den Hin- ALS AUCH für den Rückweg
3. Für den Rückweg wird der GLEICHE Circuit (Verbindungspfad) genutzt, jedoch in UMGEKEHRTER Reihenfolge

🔑 **Merke:** Nur der TOR-Browser kann damit die endgültige Antwort vollständig entschlüsseln, da er die Sitzungsschlüssel für ALLE Knoten kennt.

★ Auf dem Rückweg wird also **jeder Knoten eine Schicht HINZUFÜGEN** (statt zu entfernen), und der Client schält am Ende alle drei ab.

35.7 Circuit-IDs ★

? „Wie aber kann eine Node speichern, welche Pakete für welchen Weg bestimmt sind, da es ja mehr wie eine Anfrage gibt?“

Eine Node erkennt unterschiedliche Datenpakete, die durch sie hindurchfließen, indem sie jedes Paket einer bestimmten CIRCUIT-ID zuweist.

★ Jeder Knoten führt eine Tabelle: (eingehende Circuit-ID, eingehender Link) → (ausgehende Circuit-ID, ausgehender Link). So kann er Pakete zuordnen, **ohne die Endpunkte zu kennen**.

35.8 Der Guard Node ★★★★★

? „Warum gibt es den Guard Node?“

- Der **Guard Node ist der ERSTE Node im Circuit** und **kennt daher die ECHTE IP-Adresse des Benutzers**
- Guard Nodes **spielen eine zentrale Rolle für die Sicherheit und Anonymität im TOR-Netzwerk**, da sie dazu beitragen, das **Risiko von Angriffen auf die Identität eines Benutzers zu minimieren**

🔑 **Wichtig:** Der TOR-Browser bleibt für eine **LÄNGERE ZEIT**, in der Regel **2–3 MONATE** oder länger, mit **DEMSELBEN** Guard Node verbunden.

? „Warum macht man das und warum ist dieser Node so wichtig für die Sicherheit?“

Die drei Gründe (Folie 150) ★★★★★:

#	Grund
1	Einschränkung der Sichtbarkeit der IP-Adresse
2	Verbesserte Stabilität
3	Schutz vor SYBIL- und TRAFFIC-CORRELATION-Angriffen

★★ **Die Logik dahinter (unbedingt verstehen, häufige Verständnisfrage):**

Würde der Browser **bei jeder Verbindung einen NEUEN Entry Node** wählen, wäre die Wahrscheinlichkeit, **irgendwann einmal** einen vom Angreifer kontrollierten Entry Node zu erwischen, **mit jeder neuen Verbindung höher** — über die Zeit näherte sie sich **100 %**. Durch das **Festhalten an EINEM Guard Node über 2–3 Monate** gilt: Ist der Guard Node **sauber**, bleibt der Nutzer die ganze Zeit **sicher**; ist er **bösartig**, ist der Nutzer die ganze Zeit **gefährdet** — aber die **Gesamtwahrscheinlichkeit**, überhaupt an einen bösartigen Guard zu geraten, sinkt drastisch. Man tauscht „oft ein bisschen Risiko“ gegen „selten ein großes Risiko“.

⚠ **Die beiden Angriffsnamen erklären können:**

Angriff	Beschreibung
Sybil-Angriff	Ein Angreifer betreibt viele gefälschte Identitäten/Knoten im Netzwerk, um die Wahrscheinlichkeit zu erhöhen, in einen Circuit zu gelangen
Traffic-Correlation-Angriff	Ein Angreifer, der Entry- UND Exit-Traffic beobachtet, korreliert Zeitpunkte und Datenmengen und deanonymisiert so die Verbindung — auch ohne den Inhalt zu entschlüsseln

35.9 TOR-Steckbrief ★★

Eigenschaft	Wert
Prinzip	Onion Routing — mehrschichtige Verschlüsselung
Standard-Circuit	3 Knoten: Entry (Guard) → Middle → Exit
Asymmetrisch	RSA — nur für den Sitzungsschlüsselaustausch beim Circuit-Aufbau
Symmetrisch	AES — für die eigentlichen Daten (Hin- und Rückweg)
Öffentliche Schlüssel	im Konsensus-Dokument , das der Browser herunterlädt
Guard-Node-Lebensdauer	2–3 Monate oder länger
Paketzuordnung	über Circuit-IDs
Browser	angepasster Firefox
Spezielle Domains	.onion
Größte Schwäche	Exit Node sieht Klartext (ohne HTTPS); Traffic-Correlation

TEIL E — QUERSCHNITTSTHEMEN UND SYNTHESE

36. Die großen Verbindungslinien des Moduls ★★

Diese Verknüpfungen tauchen erfahrungsgemäß in Transferfragen auf.

36.1 Schutzziel → Mechanismus → Kapitel

Schutzziel	Mechanismus	Kapitel
Vertraulichkeit	Verschlüsselung (symmetrisch: DES/AES; asymmetrisch: RSA), Steganografie	04–11
Integrität	Hash-Funktionen, MACs , digitale Signaturen, Checksummen	13
Verfügbarkeit	Redundanz, Backups, Incident Response , Recovery	02_4
Authentizität	digitale Signaturen, MFA , Biometrie, Blockchain	02_1, 13
Autorisation	ACLs , OAuth	02_1
Verbindlichkeit	digitale Signaturen, PKI (nicht MAC!)	02_1, 13
Prävention/Detektion/Protokollierung	SIEM, EDR, IDS/IPS, Logging	02_4
Anonymisierung/Pseudonymisierung	Aggregation, Unterdrückung, Rauschüberlagerung, TOR	02_1, TOR

36.2 Die Einwegfunktionen im Überblick ★★

Verfahren	Einwegfunktion	Leicht	Schwer
DHKE	Potenzieren in $\mathbb{Z}_p^*$	$a^x \bmod p$ berechnen	$x = \log_a(\beta) \bmod p$ — DLP
RSA	Multiplikation von Primzahlen	$p \cdot q = n$	$n \rightarrow (p, q)$ — Faktorisierung
Hash	$h(x)$	$h(x)$ aus x	x aus $h(x)$ — Urbildproblem

36.3 Konfusion und Diffusion — wo sie überall auftauchen ★★

Chiffre	Konfusionselement	Diffusionselement
Vigenère	—	(nur Diffusion-artig, unsicher)
Enigma	(nur Konfusion, unsicher)	—
DES	S-Boxen (8 unterschiedliche)	E-Box, P-Box
AES	S-Box (16 identische)	ShiftRows, MixColumns

★ In beiden modernen Chiffren ist die S-Box das EINZIGE nichtlineare Element.

36.4 Symmetrisch vs. asymmetrisch ★★

	Symmetrisch	Asymmetrisch
Schlüssel	ein gemeinsamer geheimer Schlüssel	Schlüsselpaar (öffentlich/privat)
Beispiele	DES, AES, Trivium	RSA, DHKE
Geschwindigkeit	schnell	langsam (~Faktor 1000)
Schlüsselaustausch	Problem!	löst das Problem
Anzahl Schlüssel bei n Teilnehmern	$n(n-1)/2$	$2n$
Verwendung	Nutzdaten	Schlüsseltransport, Signaturen

★ **Hybride Verschlüsselung:** In der Praxis kombiniert man beides — **asymmetrisch für den Schlüsselaustausch, symmetrisch für die Daten**. Beispiele im Modul: **TLS, TOR** (RSA + AES), die im RSA-Kapitel genannte Hauptanwendung „Schlüsseltransport“.

36.5 Brücken zum IT-Recht-Teil (Modul 10) ★

IT-Security-Konzept	Rechtliche Entsprechung
TOM (technisch/organisatorisch)	Art. 32 DSGVO , § 30 BSIG
Compliance by Design	Privacy by Design, Art. 25 DSGVO ; Security by Design im CRA
Incident Response, Meldewege	Meldepflichten Art. 33/34 DSGVO, § 32 BSIG (24 h / 72 h / 1 Monat)
KRITIS, NIS2, IT-SiG	BSIG , KRITIS-Dachgesetz
Risikobasierter Ansatz (ALARP)	„angemessene Maßnahmen nach dem Stand der Technik“
Pseudonymisierung/Anonymisierung	Art. 4 Nr. 5 DSGVO (pseudonym = weiterhin personenbezogen!)
Verbindlichkeit / Nichtabstreitbarkeit	eIDAS , qualifizierte elektronische Signatur

TEIL F — SELBSTTEST

Anleitung: Frage lesen, laut oder schriftlich beantworten, **dann erst** aufklappen. Die Fragen sind nach Kapiteln geordnet; die mit ★ markierten sind besonders klausurwahrscheinlich.

Block 1 — Cyber-Sicherheit (Fragen 1–40)

▼ 1. ★ Definieren Sie den Cyber-Raum.

Der Cyber-Raum umfasst **sämtliche mit dem Internet verbundene IT-Systeme und IT-Infrastrukturen**. Dazu zählt auch die dort angewendete Kommunikation, Anwendungen und alle Prozesse mit Daten und Informationen. Insgesamt ist es ein **globales und komplexes System** mit vielen Abhängigkeiten auf unterschiedlichen Ebenen und vielen involvierten Akteuren.

▼ 2. Welche physikalischen Basis-Infrastrukturen nennt die Vorlesung für das Internet-Protokoll?

Ethernet, WLAN, Satellit. Dazu: dezentrale Struktur mit selbstorganisierten Netzen → **Autonome Systeme (AS)**.

▼ 3. ★ Was ist die Besonderheit des Cyber-Raums bezüglich staatlicher Macht?

Die Staaten können hier ihr **Gewaltmonopol nicht vollständig ausüben**; es hat sich ein **erfolgreiches Ökosystem für kriminelle Organisationen** etabliert. Gründe: Nicht alle Staaten kooperieren international, Angreifer greifen aus nicht-kooperierenden Ländern an, und es besteht das **Attributionsproblem** (Zuordnung eines Angriffs).

▼ 4. ★★★ Zeichnen Sie das Verhältnis von Cyber-Sicherheit, Informationssicherheit und IT-Sicherheit.

Cyber-Sicherheit ⊃ Informationssicherheit ⊃ IT-Sicherheit

- **Informationssicherheit** = Schutz von **Informationen** (digital **und** analog/Papier)
- **IT-Sicherheit** = Schutz von **IT-Systemen**
- **Cyber-Sicherheit** = Schutz **im Internet** / im gesamten Cyber-Raum

Randnotiz: Umgangssprachlich werden „IT-Sicherheit“ und „Cybersicherheit“ oft synonym verwendet, um die Relevanz zu betonen.

▼ 5. ★ Definieren Sie IT-Sicherheit.

IT-Sicherheit umfasst **alle Maßnahmen zum Schutz von IT-Systemen, Daten und Netzwerken vor unbefugtem Zugriff, Manipulation, Verlust oder Störungen**. Ziel: **Sicherheit und Funktionsfähigkeit** dieser Systeme aufrechterhalten.

▼ 6. ★ Was ist das übergeordnete Ziel der IT-Sicherheit — und was ist es NICHT?

Ziel ist die **Reduzierung der vorhandenen Risiken auf ein ANGEMESSENES MASS** in Bezug auf den Cyber-Raum. Es ist **nicht** „absolute“ oder „hundertprozentige“ Sicherheit — die gibt es nicht.

▼ 7. ★★★ Nennen Sie die 3 Hauptziele und die 5 Nebenziele der IT-Sicherheit.

Hauptziele: 1. Vertraulichkeit · 2. Integrität · 3. Verfügbarkeit **Nebenziele:** 4. Authentizität und Authentifikation · 5. Autorisation · 6. Verbindlichkeit (Nichtabstreitbarkeit) · 7. Maßnahmen zur Verhinderung, Entdeckung oder Protokollierung von Bedrohungen · 8. Anonymisierung/Pseudonymisierung

▼ 8. ★ Nennen Sie Mechanismen für Vertraulichkeit, Integrität und Authentizität.

- **Vertraulichkeit:** Verschlüsselung, **Steganografie**
- **Integrität:** Hash-Funktionen, **MACs**, digitale Signaturen, Checksummen
- **Authentizität:** digitale Signaturen, Blockchain, **MFA**, biometrische Verfahren

▼ 9. ★★ Unterscheiden Sie Authentifizierung und Autorisierung.

- **Authentifizierung:** Überprüfung, **ob der Benutzer auch der ist, der er vorgibt zu sein** (*Wer bist du?*)
- **Autorisierung:** Erteilung einer Erlaubnis/Befugnis an den Benutzer (*Was darfst du?*)

Reihenfolge: erst Authentifizierung, **dann** Autorisierung.

▼ 10. ★★ Was ist Verbindlichkeit, und warum genügt ein MAC dafür nicht?

Verbindlichkeit (Nichtabstreitbarkeit): Der **Sender kann nicht abstreiten**, dass die Nachricht von ihm stammt; man kann **Inhalt und Absender gegenüber einem nicht beteiligten Dritten beweisen**.

Mechanismen: **digitale Signaturen, PKI, Blockchain**.

Ein **MAC genügt nicht**, weil **beide** Kommunikationspartner denselben Schlüssel besitzen — ein Dritter kann nicht unterscheiden, wer den MAC erzeugt hat.

▼ 11. Welche Mechanismen nennt die Vorlesung für Anonymisierung/Pseudonymisierung?

Datenaggregation, Datenunterdrückung, Rauschüberlagerung.

▼ 12. ★★ Unterscheiden Sie Safety und Security in fünf Dimensionen.

	Safety	Security
Deutsch	funktionale Sicherheit	Angriffssicherheit
Schutzrichtung	schützt Mensch/Umwelt vor dem System	schützt das System vor der Umwelt
Auslöser	Fehlfunktion, Ausfall	Angriff
Mechanismen	leichter rekonstruierbar, z. B. CRC	kryptographische Prüfsummen
Charakter	statisch , systemspezifisch	dynamisch , laufend anzupassen

▼ 13. ★ Warum bietet eine CRC-Prüfsumme keine Security?

CRC ist **linear und ohne Schlüssel** — jeder kann sie nach einer Manipulation neu berechnen. Sie schützt nur gegen **zufällige** Übertragungsfehler, nicht gegen **absichtliche** Manipulation. Dafür braucht man eine **kryptographische Prüfsumme (MAC)**.

▼ 14. ★ Definieren Sie Sicherheitslücke.

Eine **Schwachstelle in Software oder Hardware**, die es einem Angreifer erlaubt, **mithilfe speziell dafür entwickelter Software (Exploits)** Angriffe auf ein IT-System erfolgreich umzusetzen.

▼ 15. ★ Definieren Sie Angriffsvektor.

Die **Kombination aus einem ANGRIFFSWEG und einer ANGRIFFSTECHNIK**, die einen erfolgreichen Angriff auf ein IT-System oder einen Dienst ermöglicht.

▼ 16. ★★ Wodurch ist eine Angriffsfläche bestimmt?

Durch **(1) die Anzahl der genutzten IT-Systeme und -Dienste** und **(2) die vorhandenen Cyber-Sicherheitsmaßnahmen**. Sie umfasst die **Kombination aus Schwachstellen und Angriffsvektoren**. Je größer die Angriffsfläche, desto höher die Erfolgswahrscheinlichkeit eines Angriffs.

▼ 17. Nennen Sie die sechs Ebenen der Angriffsfläche.

Nutzer, Netzwerk, IT-System, Betriebssystem, Anwendung(en), Daten.

▼ 18. ★ Woraus setzt sich das Wort „Malware“ zusammen?

Malicious (böartig, schädlich) + **Software** = **Malware** — Oberbegriff für Schadsoftware.

▼ 19. ★★ Unterscheiden Sie Clear Web, Deep Web und Dark Net.

- **Clear Web / Surface Web:** leicht zugänglich, indexiert (Google, Wikipedia, Amazon, YouTube)
- **Deep Web (ca. 90 %):** nicht indexiert, aber normal erreichbar (Firmendatenbanken, Streaming-Server, Online-Speicher)
- **Dark Net:** nicht auf herkömmliche Weise auffindbar, nur über spezielle Software (TOR)

⚠ Deep Web ≠ Dark Net!

▼ 20. ★★ Kann Malware „gute Software“ sein? Begründen Sie.

Ja. Qualität und Absicht sind **unabhängige Dimensionen**. Die Folie sagt wörtlich: „Bedauerlicherweise handelt es sich bei Malware sehr oft um eine **sehr gute Software** im Sinne der Klassifizierung von Software.“ Professionelle Malware ist fehlerarm, zuverlässig und gut getestet — **gute Software mit böartiger Absicht**.

▼ 21. ★ Nennen Sie die Ursachen für „schlechte Software“.

Steigende **Komplexität**; fehlendes **Sicherheitsbewusstsein** und mangelnde **Expertise** der Entwickler; **schlechter Programmierstil**; mangelnde Kenntnis verwendeter **Bibliotheken**; **Zeitdruck (Time-to-Market)**; **unzureichendes Testen**; **unklare Anforderungen**.

▼ 22. Warum ist schlechte Software das „Übel der modernen IT“?

Sie ist die **Basis für den Erfolg bössartiger Software** und trägt dazu bei, dass viele IT-Systeme mit Malware infiziert werden.

▼ 23. ★★ Unterscheiden Sie passive und aktive Angriffe.

- **Passiv:** Angreifer liest mit, ohne zu verändern; keine eigenen Daten eingeschleust; **schwer zu erkennen**; verletzt die **Vertraulichkeit**
- **Aktiv:** **Modifizierung, Manipulation, Sabotage**; Identitätsdiebstahl, Brechen von Verschlüsselungen, Lahmlegen von Systemen; **kann auffallen und Spuren hinterlassen**

▼ 24. Nennen Sie vier Beispiele für passive Angriffe aus der Vorlesung.

Unverschlüsselte öffentliche WLANs (Abhören aller Pakete im Sendebereich); **schlecht konfigurierte Router** (Admin-Schnittstellen); **Routing-Umleitung** über einen eigenen Knoten; **DNS Cache Poisoning**.

▼ 25. ★★ Unterscheiden Sie zielgerichtete und nicht-zielgerichtete Angriffe.

- **Nicht-zielgerichtet:** kein gezieltes Auswählen der Opfer, **generische** Methoden bei vielen Nutzern — Beispiel: **Massenversand von Phishing-Mails**
- **Zielgerichtet:** auf ein **spezifisches Opfer zugeschnitten**, Kombination aus **Social Engineering** und **technischen Maßnahmen**, **APT** — Erkennung und Verteidigung **schwierig**

▼ 26. ★ Wofür steht APT, und was bedeuten die drei Wortteile?

Advanced Persistent Threat — langanhaltende, zielgerichtete Angriffe. **Advanced:** hochentwickelte Techniken · **Persistent:** langanhaltend, lange unentdeckt · **Threat:** organisierter, ressourcenstarker Akteur.

▼ 27. ★★ Wer zählt zu den Innentätern?

Nicht nur eigene Mitarbeiter! Alle Personen mit **internem Know-how**: **Geschäftspartner**, **Lieferanten**, **externe Dienstleister** und **Kunden**.

▼ 28. Warum sind Innentäter besonders gefährlich?

Insider-Informationen und **Kenntnis interner Abläufe**; begünstigt durch **fehlende interne Schutzmechanismen**, selten umgesetzte **Verschlüsselung und Härtung** interner Systeme, **unzureichende interne Überwachung und Protokollierung**. Angriffe sind zudem **ortsunabhängig** möglich.

▼ 29. ★★★ **Nennen und erklären Sie die vier Schwachstellenkategorien.**

1. **Anforderungsfehler:** Sicherheitsanforderungen wurden **nicht berücksichtigt** → keine Schutzmechanismen vorhanden
2. **Designfehler:** Die **Spezifikation erfüllt die Anforderungen nicht** und enthält ausnutzbare Schwachstellen
3. **Implementierungsfehler: Fehlerhafte Umsetzung des Designs** — Implementierung weicht von der Spezifikation ab
4. **Installations-/Administrationsfehler: unsachgemäße Konfiguration**, z. B. **Test-Accounts** oder **deaktivierte Sicherheitsfunktionen**

→ Folgt dem Wasserfall: Anforderung → Design → Implementierung → Betrieb.

▼ 30. ★ **Ordnen Sie zu: Passwörter werden gemäß Spezifikation mit MD5 gehasht. Welche Fehlerkategorie?**

Designfehler — die Spezifikation selbst erfüllt die Sicherheitsanforderung nicht. (Wäre bcrypt spezifiziert und SHA-1 implementiert worden → Implementierungsfehler.)

▼ 31. **Was gilt es laut Vorlesung bei Angriffen immer zu finden?**

Das **schwächste Glied in der Kette** — es ist die grundlegende Ursache für erfolgreiche Angriffe auf IT-Systeme.

▼ 32. **Warum war Sicherheit zu Beginn des Internets kein Thema?**

Der Fokus lag auf **Innovation** (Kommunikation, Effizienz, globale Vernetzung). **Vertrauen statt Absicherung** — Sicherheitsaspekte wurden vernachlässigt. Diese Lücke nutzten erste Angreifer **oft mit einfachen Mitteln** aus.

▼ 33. **In welchen Anwendungsfeldern gilt IT-Sicherheit?**

Klassische IT-Systeme, Industrie 4.0, Internet of Things — betrifft **Unternehmen wie Privatpersonen**.

▼ 34. ★ **Erklären Sie den Unterschied zwischen Angriffsvektor und Angriffsfläche an einem Beispiel.**

Angriffsvektor = **ein einzelner Pfad**, z. B. „E-Mail-Anhang (Weg) + Makro-Ausführung (Technik)“.

Angriffsfläche = **Gesamtheit** aller Schwachstellen und Vektoren eines Systems. Ein System hat **viele** Vektoren, aber **eine** Angriffsfläche.

▼ 35. **Welche Ziele der IT-Sicherheit betreffen unmittelbar das Netzwerk?**

Absicherung der **Kommunikationskanäle** zwischen Systemen und Anwendungen sowie Absicherung des **Netzwerks**, das für den Datenaustausch genutzt wird.

▼ 36. Was bedeutet „gutartige Software“, und wie wird sie bewertet?

„Normale“ Software (Betriebssysteme, Treiber, Anwendungen), **ohne kriminelle Hintergedanken** entwickelt. Sie kann **gut oder schlecht** sein — der Maßstab sind **Funktionen und Eigenschaften**. Kritisch: Features können nützlich, aber auch **bedenklich** sein („**Bezahlen mit persönlichen Daten**“).

▼ 37. Ist absolute Fehlerfreiheit bei großer Software erreichbar?

Nein. Die Fehlerdichte sinkt zwar, aber die **Bedrohung durch gezielte Angriffe wächst** aufgrund des zunehmenden **Know-hows der Angreifer**.

▼ 38. Was zeichnet „gute Software“ aus?

Minimale Anzahl von Fehlern/Schwachstellen; **hohe Funktionalität** (korrekt und zuverlässig); **einfache, verständliche Nutzerschnittstelle**; erfüllt **IT-Sicherheits- und Datenschutzansprüche**; **besserer Schutz** vor Malware-Angriffen.

▼ 39. ★ Warum funktioniert globale Strafverfolgung im Cyber-Raum nicht?

Nicht alle Staaten kooperieren; Angreifer agieren **aus nicht-kooperierenden Ländern**; **Attributionsproblem** — die Zuordnung eines Cyber-Angriffs ist schwierig.

▼ 40. Nennen Sie die drei zentralen Begriffe der Cyber-Security aus Kapitel 02_1.

1. Sicherheitslücke · 2. Angriffsfläche · 3. Angriffsvektor.

Block 2 — GRC (Fragen 41–80)

▼ 41. ★★ Wofür steht GRC, und was leisten die drei Komponenten?

Governance, Risk, Compliance.

- **Governance:** strategische Steuerung und Verantwortungsstruktur
- **Risk Management:** Identifizieren, bewerten und steuern von Risiken
- **Compliance:** Sicherstellung und **Nachweis** regulatorischer Konformität

▼ 42. ★ Definieren Sie GRC.

Ein **umfassendes Rahmenwerk** bzw. **integriertes Managementsystem** zur **koordinierten Steuerung** von **Informationssicherheit, Risiken und regulatorischen Anforderungen** im Unternehmen — abgestimmt auf die **Unternehmensziele**.

▼ 43. Nennen Sie die drei Hauptziele von GRC.

1. Schutz von **Unternehmensdaten, IT-Systemen und digitalen Vermögenswerten**
2. Einhaltung **gesetzlicher, regulatorischer und branchenspezifischer** Anforderungen
3. **Minimierung rechtlicher, finanzieller und reputativer Risiken** durch Nichteinhaltung

▼ 44. ★ Was sind die drei Praxis-Ziele von GRC?

Steuerbarkeit, Anpassungsfähigkeit, Nachweisbarkeit.

▼ 45. ★ Ist GRC ein IT-Thema?

Nein. GRC ist ein **unternehmensweites Organisationsprinzip**, das **alle Geschäftsbereiche** betrifft — es geht um **Prozesse, Verantwortlichkeiten und Entscheidungen** im gesamten Unternehmen, nicht nur um technische Maßnahmen.

▼ 46. ★ Definieren Sie Compliance.

Die **Einhaltung gesetzlicher, regulatorischer sowie interner Vorgaben und Standards** — sowohl **verbindliche Vorschriften** (DSGVO) als auch **freiwillige Organisationsrichtlinien**. Gilt **bereichsübergreifend** von IT über Finanzen bis HR.

▼ 47. ★ Nennen Sie interne und externe Compliance-Vorgaben mit Beispielen.

- **Intern:** Unternehmensrichtlinien, Verhaltensregeln, **Betriebsvereinbarungen**; IT-Nutzung, HR-Richtlinien, Sicherheitsvorgaben
- **Extern — Datenschutz:** DSGVO
- **Extern — IT-Sicherheit:** NIS2, DORA
- **Extern — Branchenstandards:** MaRisk, GoBD, ISO 27001

▼ 48. ★ Wofür stehen NIS2, DORA, MaRisk, MaSI und GoBD?

- **NIS2:** *Network and Information Security Directive 2* (EU, IT-Sicherheit)
- **DORA:** *Digital Operational Resilience Act* (EU, Finanzsektor)
- **MaRisk:** Mindestanforderungen an das Risikomanagement (Banken)
- **MaSI:** Mindestanforderungen an die Sicherheit von Internetzahlungen
- **GoBD:** Grundsätze zur ordnungsmäßigen Führung und Aufbewahrung von Büchern ... in elektronischer Form

▼ 49. Was umfasst IT-Compliance inhaltlich?

Informationssicherheit (IT-Security, Verfügbarkeit, Datenschutz), **Dokumentationspflicht**, **Datenaufbewahrung**.

▼ 50. ★★★ Nennen Sie die drei Säulen der IT-Security.

1. **Regulatorische Vorgaben** (DSGVO, GoBD, MaRisk, NIS2, AI Act, DORA)
2. **Technische Maßnahmen** (Zugriffskontrollen, Verschlüsselung, Patchmanagement, Netzwerksegmentierung)
3. **Organisatorische Prozesse** (Richtliniendefinition, Schulungen, Notfallmanagement, kontinuierliche Kontrolle)

Ein belastbares Sicherheitsniveau entsteht **nur, wenn alle drei systematisch aufeinander abgestimmt** sind.

▼ 51. ★★★ Warum bedeutet Compliance nicht Sicherheit?

Compliance ist **leicht messbar** (Erfüllungsgrade, Quoten, Fristen, Auditstatus) und liefert **objektive Nachweise, aber KEINE Aussage über Angemessenheit und Wirksamkeit**. Sie ist **vergangenheitsorientiert**, während Angreifer **vorausschauend, dynamisch und anpassungsfähig** agieren und Lücken **außerhalb des Prüfungsfokus** nutzen. **Erfüllung ≠ Wirksamkeit; Prüfungen bestehen ≠ Bedrohung abwehren.**

▼ 52. ★★ Was ist die „Komfortzonen-Falle“?

Die Erfüllung von Compliance-Vorgaben erzeugt eine **trügerische Sicherheitsillusion**: Zertifizierungen vermitteln ein **falsches Sicherheitsgefühl**, kritische Entscheidungen werden **reaktiv abgearbeitet statt gesteuert**. Je stärker die formale Regelkonformität, desto größer die Gefahr, sich in dieser Komfortzone einzurichten. Beispiele: veraltete Software, nicht freigegebene Software/Prozesse, ignorierte Meldewege.

▼ 53. ★ Was besagt „Compliance by Design“?

Compliance ist **integraler Bestandteil von Anfang an**: Neue Prozesse und digitale Lösungen werden **von Beginn an regelkonform gestaltet**, statt Compliance nachträglich „**drüberzustülpen**“. Parallelen: Privacy by Design (Art. 25 DSGVO), Security by Design (CRA).

▼ 54. ★ Ist IT-Compliance ein Projekt?

Nein — es ist **kein einmaliges Projekt mit festem Endpunkt**, sondern ein **kontinuierlicher Regelprozess**.

▼ 55. ★★★ Welche zwei Sätze verbinden Compliance und Governance?

„Governance ist notwendig, um zu steuern, nicht nur zu erfüllen.“ „Ohne Governance wird Compliance zur Illusion von Sicherheit.“

▼ 56. ★ Definieren Sie Security Governance.

Ein **strategischer Rahmen zur Steuerung von Informationssicherheit**, bestehend aus **Richtlinien, Rollenmodellen und Entscheidungsprozessen** (z. B. Datenschutz- und Informationssicherheitsrichtlinien, Incident-Response-Pläne). Sie definiert **Verantwortlichkeiten** (Führungskräfte, IT-SB, DSB), entwickelt Strategien und implementiert Maßnahmen. Sie ist **keine Regelverletzungskontrolle, sondern ein strategischer Ordnungsrahmen**.

▼ 57. ★ Was soll Governance sicherstellen?

Dass **Sicherheitsziele ebenso verbindlich sind wie Umsatz- oder Qualitätsziele** — sie bestimmt den **Stellenwert der (IT-)Sicherheit in der Strategie**.

▼ 58. ★ **Nennen Sie die sechs Kernelemente der Governance.**

1. Sicherheitsrichtlinien und Standards · 2. Strategische Steuerung und klare Verantwortlichkeiten · 3. Incident Response · 4. Risikomanagement und Risikotragfähigkeit ·
2. Awareness und Schulung · 6. Monitoring, Audits und Reporting

▼ 59. ★★ **Was bedeutet Governance NICHT?**

Nicht, dass die Führung **jede Einzelmaßnahme absegnet**. Fachbereiche handeln **selbstständig innerhalb definierter Leitplanken**. Governance definiert **Rollen, Entscheidungskriterien und Eskalationswege** — sie führt **über Richtung und Konsequenz**, nicht über Detailvorgaben.

▼ 60. ★ **Nennen Sie vier Governance-Kennzahlen.**

Zeit von Risikoerkennung bis zur Entscheidung · Häufigkeit und Begründung von Ausnahmen · Budgeteinsatz vs. Risikoprioritäten · Eingriffe durch Steuerkreise. Ziel: Entscheidungsfähigkeit sichtbar machen — Reifegrad statt Checkliste.

▼ 61. ★★ **Definieren Sie Risikomanagement.**

Der **systematische Prozess zur Identifikation, Bewertung, Steuerung und Überwachung von Risiken** mit dem Ziel, **potenzielle Gefährdungen frühzeitig zu erkennen** und geeignete Maßnahmen zu ergreifen.

▼ 62. ★ **Sind Risiken immer Bedrohungen?**

Nein. Manche Risiken können **gezielt akzeptiert, kontrolliert oder bewusst getragen** werden.

▼ 63. ★★★ **Nennen Sie die vier Schritte des Risikomanagementprozesses.**

1. **Risikoanalyse** — identifizieren, beschreiben, bewerten (Eintrittswahrscheinlichkeit, Auswirkung)
2. **Risikosteuerung** — akzeptieren, vermeiden, vermindern oder übertragen (z. B. Versicherung)
3. **Risikomonitoring** — laufende Überwachung: Wirken die Maßnahmen? Gibt es neue Risiken?
4. **Risikoreporting** — Kommunikation, Risiken transparent machen, Status an die Führung berichten

Nach welchen Normen? **ISO 31000** oder den **BSI-Standards**.

▼ 64. ★★ **Nennen Sie die vier Risikosteuerungsstrategien mit je einem Beispiel.**

- **Akzeptieren:** Restrisiko bewusst tragen
- **Vermeiden:** riskanten Dienst abschalten
- **Vermindern:** Patchmanagement, Backups, Segmentierung
- **Übertragen:** **Cyber-Versicherung**, Outsourcing

⚠ Das Übertragen verlagert nur die **finanzielle Folge**, nicht die Verantwortung.

▼ 65. ★ **Warum ist die Risikoidentifikation der entscheidende erste Schritt?**

Wird ein Risiko nicht erkannt, können weder eine fundierte Bewertung noch geeignete Maßnahmen zur Risikosteuerung eingeleitet werden.

▼ 66. **Wo liegt die Verantwortung für das Risikomanagement?**

Bei der **Unternehmensführung**, nicht nur bei einzelnen Fachabteilungen. Governance schafft den Rahmen (welche Risiken werden getragen, welche nicht). **Kommunikation ist entscheidend** — Risiken müssen **verstanden, akzeptiert und verfolgt** werden.

▼ 67. **Was ist IT-Risikomanagement, und wie verhält es sich zum Gesamtrisikomanagement?**

Ein **spezialisierte Bestandteil** des unternehmensweiten Risikomanagements, fokussiert auf Risiken der **Informations- und Kommunikationstechnologien**; eng verknüpft mit **Informationssicherheit, Business Continuity und Governance**. Beispiele für Risiken: Cyber-Angriffe, Datenverlust, **Fehlkonfigurationen**, Systemausfälle.

▼ 68. **Was ist Security Incident Management?**

Ein **Spezialbereich der IT-Sicherheit**, der sich **ausschließlich auf den Umgang mit sicherheitsrelevanten Ereignissen** fokussiert (→ Incident Response). Basiert auf **vordefinierten Prozessen und Verhaltensregeln** — Entscheidungen werden **VOR dem Eintritt eines Vorfalls** festgelegt.

▼ 69. ★★ **Erklären Sie die SWOT-Analyse und ihre Achsen.**

Strengths / Weaknesses (**intern**) und Opportunities / Threats (**extern**), angeordnet in einer **2x2-Matrix**. Ziel: **systematische Gegenüberstellung interner und externer Faktoren** als Grundlage für strategische Entscheidungen und Risikobewertung.

▼ 70. ★ **Nennen Sie Vorteile und Grenzen der SWOT-Analyse.**

Vorteile: einfache, verständliche Methode; fördert **interdisziplinären Dialog**; unterstützt ganzheitliche Risiko- und Chancenbewertung. **Grenzen:** **subjektive Einschätzungen ohne klare Bewertungsskala**; **keine Gewichtung** von Faktoren; **keine Maßnahmenplanung** — nur Analyse.

▼ 71. ★★ **Wofür steht ALARP, und welche Farblogik gilt?**

As Low As Reasonably Practicable. Bewertung anhand von **Eintrittswahrscheinlichkeit** und **Schadensausmaß**: ● **grün** = akzeptabel · ● **gelb** = muss **abgewogen** werden · ● **rot** = **nicht tragbar, Handlung erforderlich**. Typisch als 3x3- oder 5x5-Matrix.

▼ 72. ★ **Wofür steht FTA, und wie funktioniert die Methode?**

Fehlerbaumanalyse (Fault Tree Analysis). **Graphisch-deduktive Top-Down-Analyse**: Beginn mit einem **Top Event** (Fehler/Ereignis), dann Analyse **verknüpfter Ursachen bis zur Basis**. Gute Visualisierung komplexer Zusammenhänge, unterstützt **Ursachenpriorisierung**.

▼ 73. ★★★★★ **Wofür steht PDCA, welche anderen Namen gibt es, und auf welcher Norm basiert es?**

Plan – Do – Check – Act. Auch: **Demingkreis, Deming-Rad, Shewhart Cycle.** Basierend auf der **DIN-Norm 31000.**

▼ 74. ★★★★★ **Was bedeutet „Do“ im PDCA — und was bedeutet es NICHT?**

Do = testweise Umsetzung IM KLEINEN: Lösungsansatz im **Pilotumfeld** umsetzen/testen, **iteratives Feintuning** vor der breiten Einführung. **NICHT** die sofortige umfassende Umsetzung — der Rollout erfolgt erst in **Act.**

▼ 75. ★ **Beschreiben Sie „Act“ im PDCA.**

Standardisierung und Umsetzung: Entscheidung über die **breite Umsetzung zur Freigabe**, neue Prozesse **offiziell einführen, dokumentieren und auditen** — Grundlage für die **nächste PDCA-Iteration.**

▼ 76. **Nennen Sie fünf Normen/Standards, in denen PDCA verankert ist.**

ISO 9001 (QM), ISO/IEC 27001 (ISMS), ISO 14000, ISO 20000, BSI-Standard 200-1. Einsatz im **kontinuierlichen Verbesserungsprozess (KVP).**

▼ 77. ★★★★★ **Wofür steht SDCA, und wozu dient es?**

Standardize – Do – Check – Act. Nach **jeder erfolgreichen PDCA-Iteration** wird der neue Prozess **standardisiert.** Zweck: den **erreichten verbesserten Zustand dauerhaft stabilisieren**, bevor der nächste Verbesserungszyklus beginnt.

▼ 78. ★★★★★ **Grenzen Sie PDCA und SDCA gegeneinander ab.**

PDCA = Veränderung und Verbesserung (Weiterentwicklung bestehender Prozesse). **SDCA = Einhaltung und Stabilisierung** (Sicherung des erreichten Standards, Wiederholbarkeit, Schulung). Merksatz: **Erst verbessern (PDCA), dann sichern (SDCA), dann wieder weiterentwickeln.**

▼ 79. ★★★★★ **Grenzen Sie Risikomanagementprozess, PDCA und SDCA voneinander ab.**

- **Risikomanagementprozess = das WAS** — inhaltlicher Ablauf: Risiken identifizieren, bewerten, steuern, überwachen, berichten (ISO 31000/BSI)
- **PDCA = das WIE verbessern wir den Prozess?** — steuert und entwickelt den Risikomanagementprozess weiter (Beispiel: neue Risikobewertungsmethode einführen, testen, optimieren, etablieren)
- **SDCA = das WIE stellen wir Stabilität sicher?** — sichert bewährte Prozesse im Tagesgeschäft (Beispiel: eine eingeführte Risikoklassifikation dauerhaft korrekt anwenden)

Kurz: *Risikomanagement analysiert und behandelt Risiken · PDCA verbessert den Prozess strategisch · SDCA hält ihn operativ stabil.*

▼ **80. Nennen Sie die Bestandteile des Risikomanagements.**

Strategie und Zielsetzung, Etablieren des Risikobewusstseins im Unternehmen, **Controlling und Reporting**, Integration der gewonnenen Erkenntnisse in die Strategie.

Block 3 — Incident Response (Fragen 81–115)

▼ **81. ★★ Beschreiben Sie den Paradigmenwechsel im Sicherheitsmanagement.**

Der Fokus verschiebt sich **von reiner Prävention hin zu effektiver Incident Response**. Die entscheidende Frage ist nicht mehr nur „*Wie lässt sich ein Angriff verhindern?*“, sondern auch „*Welche Maßnahmen greifen, wenn sämtliche Schutzsysteme versagen?*“ Eine **schnelle und strukturierte Reaktionsfähigkeit** gewinnt zunehmend an Bedeutung.

▼ **82. ★ Welche drei Prozesse benötigen Unternehmen, und mit welchem Ziel?**

1. Erkennung · 2. Behandlung · 3. Eindämmung von Sicherheitsvorfällen. Ziel: **maximale Abschreckung und Verlangsamung von Angreifern**.

▼ **83. ★ Nennen Sie die zwei Gründe für das wachsende Interesse an Incident Response.**

1. Die **Vielzahl öffentlich bekannt gewordener Sicherheitsvorfälle** erhöht das **Risikobewusstsein**
2. **Strengere gesetzliche und regulatorische Anforderungen**

▼ **84. ★★ Nennen Sie die drei regulatorischen Treiber für Incident Response.**

- **MaSI** — Mindestanforderungen an die Sicherheit von Internetzahlungen (Finanzsektor)
- **NIS2-Richtlinie** (EU-weit)
- **Deutsches IT-Sicherheitsgesetz** für **KRITIS**-Unternehmen — **seit Oktober 2024**; verlangt eine **strukturierte und dokumentierte Incident-Response-Strategie**

▼ **85. ★★ Ist Incident Response eine rein reaktive Notmaßnahme?**

Nein. Das ist ein häufiges Missverständnis („Eingreiftruppe, die erst gerufen wird, wenn alles brennt“). Tatsächlich ist es ein **strategischer Prozess**, der **Planung, klare Kommunikation, wiederkehrende Übungen** und eine **ganzheitliche Eingliederung in die Sicherheitsarchitektur** erfordert. Er kombiniert **proaktive Elemente** (Planung, Monitoring) mit **reaktiven Maßnahmen** (Reaktion, Forensik).

▼ **86. ★ Nennen Sie die drei Ziele des IR-Prozesses.**

1. Vorfälle schnell erkennen · 2. Schäden minimieren · 3. Geschäftsrisiken senken. Übergeordnet: **Folgeschäden, Betriebsunterbrechungen und Reputationsverluste verhindern.**

▼ 87. ★★★ **Grenzen Sie Incident Response und IT-Forensik ab.**

- **Incident Response** = **organisatorischer Rahmen** zur **Bewältigung** von Sicherheitsvorfällen
- **IT-Forensik** = **technischer Teilbereich**, der sich mit der **Analyse digitaler Spuren** befasst

Gemeinsames Ziel: Aufklärung und Reaktion auf Sicherheitsvorfälle.

▼ 88. ★ **Nennen Sie die vier Ziele der IT-Forensik.**

1. **Rekonstruktion von Abläufen**
2. **Klärung der Vorgehensweise eines Angreifers**
3. **Identifikation kompromittierter Daten**
4. **Liefert Informationen, die das IR-Team zur fundierten Entscheidungsfindung benötigt**

▼ 89. ★★★ **Was ist eine forensische Triage, und welche Artefakte werden untersucht?**

Eine **schnelle Erfassung zur fokussierten Analyse einzelner Sachverhalte** — eine **rasche Ersteinschätzung** anhand **selektiver Artefakte: Log-Dateien, Prozesse, Netzwerkaktivität**. Es ist **KEINE vollständige forensische Analyse**; oft genügt bereits eine **gezielte Vorabanalyse**, um **Eindämmung oder Isolierung** einzuleiten. Die vollumfängliche Analyse erfolgt **ggf. nachgelagert im Ermittlungs- oder Compliance-Kontext**.

▼ 90. ★★★ **Warum ist Incident Response kein reines IT-Thema?**

Der Aufbau einer IR-Strategie **kann nicht allein durch IT-Sicherheit oder IT-Betrieb erfolgen**: Strategische und operative Entscheidungen **überschneiden sich mit Produktion, Finanzen und Kommunikation**. Maßnahmen können **erhebliche Auswirkungen auf Geschäftsprozesse** haben; Entscheidungen über **Betriebsunterbrechungen oder Ressourcenverlagerung erfordern Managementverantwortung**. Erfolgreiche Strategien entstehen **nur durch aktives Commitment des Managements**.

▼ 91. ★ **Wovon hängen individuelle IR-Strategien ab?**

Von **Unternehmensgröße, Branche und vorhandener Infrastruktur**. Einflussfaktoren: **organisatorische Reife, vorhandene Prozesse, personelle Ressourcen, technische Fähigkeiten**. Zentraler Aspekt: **ob und wann externe Dienstleister hinzugezogen werden**.

▼ 92. ★★★ **Gibt es einen Goldstandard für Incident Response?**

Nein. Anders als in anderen Sicherheitsbereichen existiert **kein einheitlicher Goldstandard**. Organisationen orientieren sich an **etablierten, international anerkannten Rahmenwerken** — **ISO/IEC 27035** und **NIST SP 800-61**.

▼ 93. ★ **Welche gemeinsame Struktur haben ISO/IEC 27035 und NIST SP 800-61?**

1. **Vorbereitung und organisatorische Grundlagen**
2. **Incident-Response-Zyklus**

▼ 94. ★★ Was ist ein Playbook, und wie ist es aufgebaut?

Eine **strukturierte Handlungsanleitung**: Wer macht was, wann, wie? — eine **standardisierte Reaktion auf häufige Vorfälle**. Aufbau: **Identifikation** (IOCs, Quellen, Erkennungen) · **Eindämmung** (Maßnahmen, Kommunikation) · **Bereinigung** (Ursachenbehebung) · **Wiederherstellung** (Backups, Dienste aktivieren).

▼ 95. ★ Welche Fragen stellt man beim „Lessons Learned“ zum Playbook?

War das Playbook verständlich/anwendbar? Gab es unklare Zuständigkeiten oder technische Hürden? → Ergebnis: **Verbesserung und Anpassung des Playbooks**.

▼ 96. ★★★ Nennen Sie die sechs Phasen des Incident-Response-Zyklus.

1. **Vorbereitung** (Preparation)
2. **Erkennung** (Identification)
3. **Eindämmung** (Containment)
4. **Beseitigung** (Eradication)
5. **Wiederherstellung** (Recovery)
6. **Lessons Learned** (Nachbereitung)

▼ 97. ★★ Welche Maßnahmen gehören zur Phase 1 (Vorbereitung)?

IRP erstellen · IRT strukturieren und aufbauen · Definition **interner Zuständigkeiten und Kommunikationswege** · Schulungen, Kommunikation, Awareness · **technische Vorbereitung**: Logging, Monitoring, SIEM und Forensik-Tools etablieren. Ziel: **Organisation auf Sicherheitsvorfälle vorbereiten**.

▼ 98. ★★ Welche Maßnahmen gehören zur Phase 2 (Erkennung)?

Monitoring mit SIEM, EDR, IDS/IPS · **Analyse von Logs und Warnungen** · **Verifizierung**: Fehlalarm vs. echter Angriff · **Einstufung nach Kritikalität** (Schweregrad, betroffene Systeme) · **Dokumentation und Vorfallmeldung**. Ziel: **Vorfälle erkennen, analysieren und klassifizieren**.

▼ 99. ★★ Welche Maßnahmen und Entscheidungen gehören zur Phase 3 (Eindämmung)?

Kurzfristig: Isolierung infizierter Systeme. **Langfristig**: temporäre **Netzwerkanpassungen / Netzsegmentierung / Re-Konfiguration**. Außerdem: **Beweissicherung** (Images, RAM, Logs). **Entscheidungen**: *Wann und wie isoliert man kompromittierte Systeme? Welche Systeme dürfen weiter betrieben werden?*

▼ 100. ★★ Welche Maßnahmen gehören zur Phase 4 (Beseitigung)?

Rücksetzen kompromittierter Konten/Zugangsdaten · **Entfernen von Malware, Backdoors und kompromittierten Dateien** · **Sicherheitslücken schließen** (Update/Patch) · **forensisch prüfen, ob alles beseitigt wurde**. Ziel: **Wiederaufbau eines „sauberen“ und vertrauenswürdigen Zustands**.

▼ 101. ★ Welche Maßnahmen gehören zur Phase 5 (Wiederherstellung)?

Wiederherstellung aus GEPRÜFTEM Backup · Integritätsprüfung und Monitoring · Kommunikation mit Stakeholdern (Management, Kunden, Behörden). Ziel: **sicherer und kontrollierter Übergang in den Regelbetrieb**.

▼ 102. ★ Warum muss das Backup „geprüft“ sein?

Weil ein Backup, das den Angreifer/die Backdoor bereits enthält, den Vorfall beim Restore **reproduziert**. Deshalb kommt die **Beseitigung (Phase 4) VOR der Wiederherstellung (Phase 5)**.

▼ 103. ★ Welche Aktivitäten gehören zur Phase 6 (Lessons Learned)?

Post-Incident-Review durchführen · **Schwächen in Technik, Organisation, Kommunikation** analysieren · **Pläne, Playbooks und IRT aktualisieren** · **Sensibilisierung der Belegschaft** basierend auf dem Vorfall.

▼ 104. ★ Wofür stehen SIEM, EDR, IDS und IPS?

SIEM = Security Information and Event Management · **EDR** = Endpoint Detection and Response · **IDS** = Intrusion Detection System (erkennt) · **IPS** = Intrusion Prevention System (erkennt **und blockiert**).

▼ 105. ★ Wofür stehen IRP, IRT und IOC?

IRP = Incident Response Plan · **IRT** = Incident Response Team · **IOC** = Indicator of Compromise (Kompromittierungsindikator).

▼ 106. ★★ Was ist die Pyramid of Pain, und von wem stammt sie?

Deutsch: **Schmerzpyramide**, entwickelt von **David J. Bianco**. Sie beschreibt die **verschiedenen Arten von Indikatoren (IoCs)**, die bei der Erkennung und Bekämpfung von Cyberangriffen verwendet werden, und zeigt, **wie „schmerzhaft“ (effektiv und aufwendig) es für einen Angreifer ist, wenn diese Indikatoren erkannt und blockiert werden**.

▼ 107. ★ Welche vier Fragen stellt man pro Ebene der Pyramid of Pain?

1. Was bedeutet die Ebene?
2. Warum ist sie wichtiger oder schmerzhafter für den Angreifer?
3. Wie leicht oder schwer ist sie für den Angreifer zu ändern?
4. Beispiel zur Veranschaulichung.

▼ 108. ★★★ Welche Ebene steht an der Spitze der Pyramid of Pain, und warum?

Ebene 6: TTPs (Tactics, Techniques and Procedures) — die **sehr schmerzhaften, schwer ersetzbaren** Informationen. Ganz unten stehen die **wenig schmerzhaften, leicht austauschbaren** Indikatoren (Hash-Werte). Ein Hash zu ändern kostet Sekunden (**Avalanche-Effekt**), das eigene Vorgehen (TTP) zu ändern kostet Monate.

▼ 109. ★ Warum ist ein Hash-Wert der schwächste IOC?

Wegen des **Avalanche-Effekts**: Die Änderung **eines** Bits in der Malware ändert **die Hälfte aller Hash-Bits** → völlig neuer Hash. Die Eigenschaft, die eine Hash-Funktion sicher macht, macht sie als Indikator nutzlos.

▼ 110. ★★ Wofür steht MITRE ATT&CK — und ist „MITRE“ eine Abkürzung?

MITRE ist ein **EIGENNAME** und **KEINE** Abkürzung — eine **Non-Profit-Organisation**, die im Auftrag der **US-Regierung** Forschung und Systementwicklung betreibt. **ATT&CK** = *Adversarial Tactics, Techniques, and Common Knowledge*.

▼ 111. ★★★ Unterscheiden Sie Taktiken und Techniken bei MITRE ATT&CK.

- **Taktiken**: „Was will der Angreifer erreichen?“ — z. B. **Initialzugriff, Privilegienerweiterung, Datenexfiltration**
- **Techniken**: „Wie wird dieses Ziel erreicht?“ — z. B. **Spear-Phishing, Pass-the-Hash, Skriptausführung über PowerShell**

Jede Technik kann in **Untertechniken** unterteilt sein.

▼ 112. ★ Warum ist die Unterteilung in Techniken und Untertechniken sinnvoll?

Besseres Verständnis der Angriffsmethode · **genauere Detektionsmöglichkeiten** (Phishing allgemein vs. Phishing mit Anhang) · **feingranulare Maßnahmen planen** (Detektion für PowerShell, aber nicht für Cmd) · **strukturierte Vergleiche und Analysen zwischen Vorfällen**.

▼ 113. ★★ Was ist das Hauptziel des MITRE-ATT&CK-Frameworks?

Ein **gemeinsames, standardisiertes VOKABULAR** und eine **strukturierte Darstellung** für die **Beschreibung und Analyse von Cyberangriffen** bereitzustellen.

▼ 114. ★ Nennen Sie die drei konkreten Ziele von MITRE ATT&CK.

1. **Besseres Verständnis von Angreiferverhalten** (verbesserte Erkennung gängiger Angriffsmuster)
2. **Verbesserung der Erkennung und Verteidigung** (Wirksamkeitsprüfung von Maßnahmen gegen bekannte Techniken → zielgerichtete Schutzmaßnahmen)
3. **Unterstützung bei Threat Intelligence und Security Operation Centers (SOC)** (klare Beschreibung und Vergleichbarkeit von Angriffen)

▼ 115. ★★ Wie hängen Pyramid of Pain und MITRE ATT&CK zusammen?

Die Pyramid of Pain zeigt, dass Verteidigung auf **TTP-Ebene** am wirksamsten ist. **Genau bei der Indikatorebene der TTPs setzt das MITRE-ATT&CK-Framework an** und macht diese oberste Ebene durch die Taktiken/Techniken-Matrix **operationalisierbar**.

Block 4 — Kryptographie-Grundlagen und klassische Chiffren (Fragen 116–150)

▼ 116. ★★ Grenzen Sie Kryptologie, Kryptographie und Kryptoanalyse ab.

- **Kryptologie:** die Wissenschaft der **Geheimhaltung von Informationen durch Transformation der Daten**; umfasst Kryptographie und Kryptoanalyse
- **Kryptographie:** die Wissenschaft von den **Methoden der Ver- und Entschlüsselung**
- **Kryptoanalyse:** die Wissenschaft, kryptographische Systeme und Verfahren auf ihre **Sicherheit bzw. Stärken und Schwächen zu testen**

▼ 117. ★★★ Formulieren Sie das Kerckhoffs'sche Prinzip.

Ein **Kryptosystem** muss auch dann noch sicher sein, wenn ein Angreifer **ALLE Details des Kryptosystems** kennt — auch der Ver- und Entschlüsselung — **BIS AUF DEN SCHLÜSSEL**.

▼ 118. ★ Nennen Sie vier Begründungen für das Kerckhoffs'sche Prinzip.

1. Verfahren lassen sich **nicht geheim halten** (Reverse Engineering, Insider, Leaks)
2. Ein **Schlüssel** lässt sich **austauschen**, ein Verfahren praktisch nicht
3. **Öffentliche Verfahren werden wissenschaftlich geprüft** — „Security by Obscurity“ ist keine Sicherheit
4. Standardisierung und Interoperabilität werden erst dadurch möglich

▼ 119. ★ Was verlagert die moderne Kryptographie — und welche Voraussetzung bleibt?

Sie **verlagert das Problem der Geheimhaltung des VERFAHRENS auf die Geheimhaltung des SCHLÜSSELS**. Voraussetzung: **Alice und Bob müssen den gleichen Schlüssel haben, der zuvor SICHER ausgetauscht wurde**.

▼ 120. ★★★ Wann existiert $a^{-1} \bmod m$?

Genau dann, wenn $\text{ggT}(a, m) = 1$ (a und m teilerfremd sind). Beispiel: $\text{ggT}(2, 9) = 1 \rightarrow$ Inverse existiert; $\text{ggT}(3, 9) = 3 \rightarrow$ keine Inverse.

▼ 121. ★ Wann ist $\mathbb{Z}_m$ ein Körper?

Genau dann, wenn m eine Primzahl ist — dann sind alle Zahlen $1 \dots m-1$ teilerfremd zu m und besitzen ein multiplikatives Inverses.

▼ 122. ★ Unterscheiden Sie $\text{GF}(p)$ und $\text{GF}(p^m)$.

- $m = 1 \rightarrow \text{GF}(p)$: **Primzahlkörper** (verwendet bei DHKE, RSA)
- $m > 1 \rightarrow \text{GF}(p^m)$: **Erweiterungskörper** (verwendet beim AES, dort $\text{GF}(2^8)$)

▼ 123. ★★ Geben Sie Ver- und Entschlüsselungsformel der Verschiebechiffre an und nennen Sie den Schlüsselraum.

$$e_k(x) = y \equiv x + k \pmod{26} \quad d_k(y) = x \equiv y - k \pmod{26}$$

Schlüsselraum: 26 (Verschiebung um 26 = Verschiebung um 0). Leicht per **Brute Force** brechbar.

▼ 124. ★★ Geben Sie die Formeln der multiplikativen Chiffre an.

$$e_k(x) = y \equiv (x \cdot k) \pmod{26} \quad d_k(y) = x \equiv (y \cdot k^{-1}) \pmod{26}$$

Bedingung: $\text{ggT}(k, 26) = 1$.

▼ 125. ★★ Warum funktioniert $k = 2$ bei der multiplikativen Chiffre nicht, $k = 3$ aber schon?

$\text{ggT}(2, 26) = 2 \neq 1 \rightarrow 2$ hat kein Inverses mod 26. Die Abbildung ist **nicht bijektiv**: a und n werden beide auf A abgebildet usw. — nur die 13 geraden Werte werden getroffen, die Entschlüsselung ist nicht eindeutig. $\text{ggT}(3, 26) = 1 \rightarrow$ alle 26 Buchstaben werden genau einmal getroffen.

▼ 126. ★★★ Wie viele multiplikative Chiffren gibt es in $\mathbb{Z}_{26}$, und welche?

Zwölf: 1, 3, 5, 7, 9, 11, 15, 17, 19, 21, 23, 25 — also alle **ungeraden Zahlen außer 13** ($\phi(26) = 12$). Der Schlüsselraum ist damit **noch kleiner als bei der Verschiebechiffre**.

▼ 127. ★ Berechnen Sie k^{-1} für $k = 3 \pmod{26}$.

Gesucht ist k^{-1} mit $k \cdot k^{-1} \equiv 1 \pmod{26}$. $3 \cdot 9 = 27 \equiv 1 \pmod{26} \rightarrow k^{-1} = 9$.

▼ 128. ★ Nennen Sie die Inversen von 5, 7, 11, 17 und 25 modulo 26.

$5^{-1} = 21$ ($105 \equiv 1$) · $7^{-1} = 15$ ($105 \equiv 1$) · $11^{-1} = 19$ ($209 \equiv 1$) · $17^{-1} = 23$ ($391 \equiv 1$) · $25^{-1} = 25$ ($625 \equiv 1$)

▼ 129. ★★★ Geben Sie die Formeln der affinen Chiffre und ihren Schlüsselraum an.

$$e_k(x) = y \equiv (a \cdot x) + b \pmod{26} \quad d_k(y) = x \equiv a^{-1}(y - b) \pmod{26}$$

mit $k = (a, b)$ und $\text{ggT}(a, 26) = 1$. Schlüsselraum = $12 \cdot 26 = 312$.

▼ 130. ★ Entschlüsseln Sie den Buchstaben `R` mit der affinen Chiffre und $k = (5, 8)$.

$a^{-1} = 5^{-1} = 21$; $y = R = 17$ $x \equiv 21 \cdot (17 - 8) = 21 \cdot 9 = 189 \pmod{26} = 189 - 182 = 7 \rightarrow h$ Probe: $5 \cdot 7 + 8 = 43 \equiv 17 = R \checkmark$

▼ 131. ★★ Unterscheiden Sie monoalphabetische und polyalphabetische Chiffren.

- **Monoalphabetisch**: reine **bijektive Abbildung** von Klartext auf Chiffretext — ein Buchstabe wird **immer gleich** ersetzt → **Häufigkeitsanalyse direkt anwendbar**
- **Polyalphabetisch**: jedes Klartextzeichen kann je nach Kontext auf **unterschiedliche Chiffretextzeichen** abgebildet werden → Häufigkeitsanalyse **nicht direkt** anwendbar

▼ 132. ★ Was sind homophone Chiffren?

Chiffren, bei denen im Geheimtext **jedes Zeichen (in etwa) gleich häufig vorkommt** — sie **verschleiern die Häufigkeiten der Klartextzeichen** (häufige Buchstaben bekommen mehrere Geheimtextzeichen zugeordnet).

▼ 133. ★★ Beschreiben Sie das Vigenère-Verfahren.

Verwendung eines **Codeworts (Schlüsselwort)**: **Klartext + Schlüsselwort = Geheimtext**, jeweils buchstabenweise. Ist das Schlüsselwort zu Ende, **beginnt es von vorne**. Formeln wie bei der Verschiebechiffre, aber **k wechselt pro Position**:

$$e_k(x) = y \equiv x + k \bmod 26$$

▼ 134. ★ Verschlüsseln Sie `TOP` mit dem Schlüsselwort `GEHEIM`.

$T(19)+G(6) = 25 \rightarrow \mathbf{Z}$ · $O(14)+E(4) = 18 \rightarrow \mathbf{S}$ · $P(15)+H(7) = 22 \rightarrow \mathbf{W} \rightarrow \mathbf{ZSW}$

▼ 135. ★ Nennen Sie Vor- und Nachteile der Vigenère-Chiffre.

Vorteile: 1. relativ einfaches Verfahren · 2. **Häufigkeitsanalyse nicht mehr direkt anwendbar** · 3. **beliebige Schlüssellänge** **Nachteil:** kleine Schlüssellänge lässt sich mittels Häufigkeitsanalyse knacken (Kasiski-Test)

▼ 136. ★ Wie funktioniert der Kasiski-Test?

Man sucht **wiederholte Zeichenfolgen** im Geheimtext. Der **Abstand** zwischen zwei identischen Folgen ist mit hoher Wahrscheinlichkeit ein **Vielfaches der Schlüssellänge**. Ist die Schlüssellänge m bekannt, zerfällt der Geheimtext in m **Cäsar-Chiffren**, die je per Häufigkeitsanalyse gebrochen werden.

▼ 137. ★★ Wie macht man Vigenère unknackbar, und wie heißt das Verfahren?

Durch einen Schlüssel, der **genau so lang ist wie der Klartext selbst** („Buch-Verfahren“). Andere Namen: **Einmal-Schlüssel-Verfahren**, individuelle Wurmverschlüsselung, Zahlenwurm, **One-Time-Pad (OTP)**.

▼ 138. ★★ Nennen Sie die drei Bedingungen für ein sicheres One-Time-Pad.

1. Schlüssel **echt zufällig** (TRNG)
2. Schlüssel **genauso lang** wie die Nachricht
3. Schlüssel wird **nur EINMAL** verwendet

▼ 139. ★★ Grenzen Sie Strom- und Blockchiffre ab.

- **Stromchiffre:** verschlüsselt **jedes Klartextbit einzeln** unter Verwendung eines **Schlüsselstroms**, der zum Klartextbit **addiert** wird
- **Blockchiffre:** verschlüsselt **Blöcke** von b Bit (DES: 64, AES: 128)

▼ 140. ★★★ Geben Sie die Formeln der Stromchiffre an und beweisen Sie, dass die Entschlüsselung funktioniert.

$$e_{s_i}(x_i) = y_i \equiv x_i + s_i \pmod{2} \quad d_{s_i}(y_i) = x_i \equiv y_i + s_i \pmod{2}$$

Beweis: $d(y_i) \equiv y_i + s_i \equiv (x_i + s_i) + s_i \equiv x_i + 2 \cdot s_i \equiv x_i + 0 \equiv x_i \pmod{2}$ ■ (denn $2 \cdot s_i \equiv 0 \pmod{2}$ für jedes s_i)

▼ 141. ★★ Warum ist XOR kryptographisch geeigneter als AND?

1. **XOR ist perfekt ausbalanciert:** Bei einem gegebenen Ausgangswert sind **alle Eingangswerte gleich wahrscheinlich** — das **ermöglicht kein anderes Gatter**
2. **XOR ist invertierbar**

Bei AND verrät ein Ausgang von 1 sofort, dass beide Eingänge 1 waren, und AND ist nicht invertierbar.

▼ 142. ★★ Warum ist eine Stromchiffre mit echt zufälligem Schlüsselstrom beweisbar sicher?

Der Angreifer kennt y_i , kann aber **nicht auf x_i schließen**: Beide Lösungen $x_i = 0$ und $x_i = 1$ haben **die gleiche Wahrscheinlichkeit (50 %)**, vorausgesetzt s_i stammt von einem **TRNG**. Da jede Nachricht mit einem Schlüssel gleicher Länge verknüpft wird, **geht jegliche Struktur verloren** — für die Kryptanalyse gibt es **keinerlei Anhaltspunkte**.

▼ 143. ★★ Wann gilt eine Stromchiffre nicht mehr als beweisbar sicher?

Wenn die **Schlüsselstrombits nicht mehr echt zufällig** sind: Dann besteht eine **funktionale Abhängigkeit zwischen den Bits s_i und den mod-2-Gleichungen**, die dadurch **nicht mehr unabhängig** sind. Das Verfahren ist dann **nicht mehr beweisbar sicher** — auch wenn das entstehende Gleichungssystem schwer zu lösen ist.

▼ 144. ★ Unterscheiden Sie „beweisbar sicher“ und „praktisch sicher“.

- **Beweisbar sicher** (informationstheoretisch): auch mit **unendlicher** Rechenkraft nicht brechbar — nur beim echten **OTP**
- **Praktisch sicher** (komplexitätstheoretisch): mit **heutiger** Rechenkraft nicht in vernünftiger Zeit brechbar — AES, RSA, Trivium usw.

▼ 145. ★★★ Warum darf der Schlüsselstrom NICHT von einem TRNG stammen?

Weil **Bob denselben Schlüsselstrom reproduzieren** muss. Ein TRNG ist **nicht reproduzierbar** — man müsste den gesamten Strom übertragen und hätte das OTP-Schlüsselaustauschproblem. Also braucht man einen **deterministischen Generator**, der aus einem kurzen gemeinsamen **Initial-Schlüssel k** einen langen, zufällig **aussehenden** Strom erzeugt.

▼ 146. ★★ Nennen Sie die zwei Anforderungen an den Schlüsselstrom.

1. Für den Angreifer muss der Schlüsselstrom wie eine zufällige Bitfolge erscheinen
2. Der Schlüsselstrom kann nicht von einem TRNG stammen → **deterministischer Generator**

▼ 147. ★★★ Nennen Sie die drei Typen von Zufallszahlengeneratoren.

1. **PRNG** — *Pseudo Random Number Generator* (Pseudozufallszahlengenerator)
2. **TRNG** — *True Random Number Generator* (echter Zufallszahlengenerator)
3. **CSPRNG** — *Cryptographically Secure PRNG* (kryptografisch sicherer PRNG)

▼ 148. ★ Welcher Generator wofür?

- **PRNG:** Simulation, Monte Carlo, Spiele
- **TRNG:** Erzeugung von Seeds, Langzeitschlüsseln, IVs
- **CSPRNG:** **Schlüsselstrom** einer Stromchiffre, Sitzungsschlüssel, Nonces

In der Praxis: TRNG liefert den **Seed**, CSPRNG expandiert ihn.

▼ 149. Wofür werden Zufallszahlen in der Kryptografie gebraucht?

Für die **Erzeugung von Sitzungsschlüsseln** und für **Randomisierungswerte**, die als Eingabe für Verschlüsselungen benötigt werden.

▼ 150. Nennen Sie die Eckdaten von Trivium.

Moderne Stromchiffre aus dem **eSTREAM**-Projekt: **80-Bit-Schlüssel**, **80-Bit-IV**, drei gekoppelte nichtlineare Schieberegister mit **288 Bit** Zustand, sehr **hardwarefreundlich**.

Block 5 — DES, AES, Betriebsmodi (Fragen 151–190)

▼ 151. ★★★ Gibt es ein allgemeines Verfahren zur Konstruktion sicherer Blockchiffren?

NEIN. Aber es gibt **zwei atomare Operationen**, die das ermöglichen: **Konfusion und Diffusion** (Claude Shannon).

▼ 152. ★★★ Definieren Sie Konfusion und Diffusion und nennen Sie ihre Realisierungen.

- **Konfusion:** Verschleierung der Beziehung zwischen Schlüssel/Klartext und Chifftrat → Substitutionstabellen (S-Box)
- **Diffusion:** Streuung des Einflusses eines Klartextsymbols auf zahlreiche Chiffratsymbole; Verbergen statistischer Eigenschaften → DES: Bitpermutation (P-Box), AES: MixColumn-Operation

▼ 153. ★★★ Was besagt der Avalanche-Effekt?

Die **Änderung EINES Bits im Klartext** ändert **durchschnittlich die HÄLFTE aller Ausgabebits**. Zwei Chifftrate, deren Klartexte sich in nur einem Bit unterscheiden, sind **statistisch vollkommen unabhängig** voneinander. Das **zerstört jede 1:1-Abbildung und Korrelation**.

▼ 154. ★ Warum reicht Konfusion oder Diffusion allein nicht aus?

Historisch hat sich gezeigt, dass **nur Konfusion** (z. B. Enigma) oder **nur Diffusion** (z. B. Vigenère) als einzige Operation **nicht sicher** ist. Erst die **Hintereinanderschaltung beider** ergibt eine starke Chiffre.

▼ 155. ★★ Was ist eine Produktchiffre?

Eine Chiffre, die durch die **Hintereinanderschaltung von Konfusion und Diffusion** entsteht. **Alle heutigen Blockchiffren** gehören dazu. Sie bestehen aus **sich wiederholenden Runden**, die die Eingangsdaten **sukzessiv** verschlüsseln, jeweils mit einem **eigenen Rundenschlüssel k_i** , der **vom Hauptschlüssel k abgeleitet** wird.

▼ 156. ★ Nennen Sie die drei Konstruktionsregeln für Produktchiffren.

1. Eine **S-Box als ganze Chiffre** aufzubauen ist **keine gute Idee**
2. Eine **S-Box als Teil-Operation** dagegen schon
3. Eine **P-Box** sorgt für das „**Verstreuen**“ der Bits, damit das Ersetzen nicht lokal beschränkt bleibt

▼ 157. ★★★ Geben Sie die Feistel-Gleichungen an.

$$L_i = R_{i-1} \qquad R_i = L_{i-1} \oplus f(R_{i-1}, k_i)$$

▼ 158. ★★ Nennen Sie die drei Eigenschaften des Feistel-Netzwerks.

1. **Ver- und Entschlüsselung sind fast identisch**
2. Die **Entschlüsselung benötigt die Schlüsselableitung in umgekehrter Reihenfolge** (Schlüsselfahrplan rückwärts)
3. **Pro Runde wird immer nur EINE Hälfte der eingehenden Bits verschlüsselt** — in der ersten Runde die **LINKE**

▼ 159. ★ Warum muss die f-Funktion nicht invertierbar sein?

Weil beim Entschlüsseln gilt: $R_{i-1} = L_i$ und $L_{i-1} = R_i \oplus f(L_i, k_i)$ — die f-Funktion wird **in beide Richtungen vorwärts** angewandt. Das spart in Hardware die halbe Schaltung.

▼ 160. ★★ Wo steckt beim DES „die eigentliche Krypto“?

In der f-Funktion. Dort werden **Konfusion und Diffusion** realisiert.

▼ 161. ★★ Beschreiben Sie den Aufbau der f-Funktion.

E-Box (Expansion 32 → 48 Bit) → **XOR mit dem 48-Bit-Rundenschlüssel** → **8 S-Boxen** (je 6 Bit → 4 Bit, zusammen 48 → 32 Bit) → **P-Box** (Permutation 32 → 32 Bit).

▼ 162. ★ Welchen Zweck verfolgt die E-Box?

Sie **erhöht die Diffusionseigenschaft von DES**, da sich **manche Eingangsbits auf ZWEI verschiedene Positionen am Ausgang** auswirken (32 → 48 Bit).

▼ 163. ★★★ Nennen Sie die drei Eigenschaften der DES-S-Boxen.

1. Sie **bilden den eigentlichen kryptografischen Kern**
2. Sie sind die **EINZIGEN nichtlinearen Elemente** → $S(a) \oplus S(b) \neq S(a \oplus b)$
3. Sie **erzeugen die Konfusion**

Zudem: **Alle S-Boxen sind unterschiedlich aufgebaut.**

▼ 164. ★ Wie liest man eine DES-S-Box-Tabelle?

Eingang **6 Bit**, Ausgang **4 Bit**. Die **äußeren zwei Bits** bestimmen die **Zeile**, die **inneren vier Bits** die **Spalte**.

▼ 165. ★★★ Warum ist die Nichtlinearität der S-Boxen so wichtig?

Würde dieses nichtlineare Element fehlen, könnte ein Angreifer den Zusammenhang zwischen DES-Input und -Output durch ein LINEARES GLEICHUNGSSYSTEM beschreiben, bei dem die Schlüsselbits die zu berechnenden Unbekannten sind. Alle anderen DES-Bausteine sind linear — die S-Boxen sind das Einzige, was DES sicher macht.

▼ 166. ★★ Welchen Zweck verfolgt die P-Box, und was garantiert sie?

Verwürfelung der 32 Ausgangsbits, fügt **Diffusion** ein. Die vier Ausgabebits jeder S-Box werden so permutiert, dass sie **mehrere S-Boxen in der nächsten Runde beeinflussen**. Zusammen mit E-Box und S-Boxen wird garantiert, dass **jedes Bit am Ende der FÜNFTEN Runde eine Funktion von jedem Bit des Klartexts UND des Schlüssels ist**.

▼ 167. ★ Ordnen Sie E-Box, S-Boxen und P-Box den Kategorien zu.

E-Box: Diffusionselement · S-Boxen: Konfusionselement · P-Box: Diffusionselement

▼ 168. ★★★ Wie viele Bit hat der DES-Schlüssel effektiv, und warum?

56 Bit — DES ist **keine 64-Bit-Chiffre, sondern nur eine 56-Bit-Chiffre**. Von den 64 angegebenen Schlüsselbits ist **jedes 8. ein Paritätsbit; PC-1 verwirft diese 8 Bits**. Der Schlüsselraum ist damit 2^{56} — heute per Brute Force durchsuchbar.

▼ 169. ★ Wie viele Bit hat ein DES-Rundenschlüssel, und wie viele Runden gibt es?

48 Bit pro Rundenschlüssel, **16 Runden** — pro Runde werden also nur **48 der 56 Bit** verwendet (Auswahl durch **PC-2**).

▼ 170. ★★ Warum ist PC-2 kryptographisch wichtig?

Es sorgt für eine **gleichmäßige Verteilung der Bits auf die einzelnen S-Boxen**. Erreicht wird das durch das **Zusammenspiel zwischen PC-2 und den Linksverschiebungen**.

▼ 171. ★★ Fassen Sie den DES-Schlüsselfahrplan in vier Punkten zusammen.

1. Jeder Rundenschlüssel ist eine **Auswahl von 48 Bits des Hauptschlüssels k**
2. Jeder der 16 Rundenschlüssel könnte auch durch **eine einzige bestimmte Permutation** des Hauptschlüssels beschrieben werden
3. Der Schlüsselfahrplan ist **lediglich eine Methode, die 16 Permutationen systematisch und einfach zu erzeugen** — besonders in Hardware
4. Er ist so gestaltet, dass **jedes der 56 Schlüsselbits in durchschnittlich 14 der 16 Runden** vorkommt

▼ 172. ★★ Nennen Sie die vier Anforderungen an den AES.

1. **Blockchiffre mit 128 Bit Blockgröße**
2. **Unterstützung von drei Schlüssellängen: 128, 192 und 256 Bit**
3. **Hohe Sicherheit relativ zu den anderen eingereichten Algorithmen**
4. **Effizienz in Soft- und Hardware**

▼ 173. ★★★ Nennen Sie fünf Unterschiede zwischen DES und AES.

	DES	AES
Struktur	Feistel	kein Feistel (SPN)
Pro Runde	halber Block	alle 128 Bit
Orientierung	bitorientiert (Bitpermutationen)	byteorientiert
S-Boxen	8 unterschiedliche	16 identische
Blockgröße	64 Bit	128 Bit

▼ 174. ★★★ Wie viele Runden und Unterschlüssel hat AES bei welcher Schlüssellänge?

Schlüssellänge	Runden	Unterschlüssel
128 Bit	10	11
192 Bit	12	13
256 Bit	14	15

Formel: **# Unterschlüssel = # Runden + 1** (das +1 wegen des zusätzlichen **Key Whitening**).

▼ 175. ★★★ Nennen Sie die drei Hauptschichten des AES.

1. Key-Addition-Schicht
2. Byte-Substitution-Schicht (S-Box)
3. Diffusionsschicht mit 3.1 ShiftRows und 3.2 MixColumn

Jede Schicht manipuliert alle 128 Bits.

▼ 176. ★★ Was ist Key Whitening, und wo wird es angewandt?

Vor und nach dem Hauptverschlüsselungsprozess wird ein **Unterschlüssel aufaddiert**. „Whitening“ bedeutet, dass die **Geheimhaltung und Komplexität des Schlüssels durch Hinzufügen weiterer Informationen erhöht** wird — Ziel ist es, die **Auswirkungen von Schlüsselangriffen zu minimieren**.

▼ 177. ★★ Warum hat DES unterschiedliche, AES aber identische S-Boxen?

Die **DES-Entwickler waren sich unsicher, ob die S-Boxen wirklich sicher sind** (mögliche mathematische Schwachstelle); die **Schwäche einer S-Box sollte die anderen nicht betreffen** → unterschiedliche S-Boxen. Beim AES ist die S-Box **mathematisch konstruiert** (Inversion + affine Abbildung) und **beweisbar gut** → 16 identische S-Boxen genügen.

▼ 178. ★★★ Wie wird die AES-S-Box hergeleitet, und welchen Zweck haben die beiden Stufen?

Zweistufige mathematische Transformation:

1. **Inversion in $GF(2^m)$** → hohe Nichtlinearität, Schutz gegen differentielle Kryptoanalyse
2. **Affine Abbildung** → verhindert, dass die algebraische Struktur des endlichen Körpers für andere Angriffe ausgenutzt werden kann — sie „stört“ die zu klare mathematische Struktur

In der Praxis nutzt man die **vorberechnete Tabelle**.

▼ 179. ★ Erhöht die affine Abbildung allein die Sicherheit?

Nein — sie ist eine **stark lineare (affine) 1:1-Abbildung** und erhöht die Sicherheit **nicht direkt**, **außer** wenn sie **nach der Inversenbildung** hinzugefügt wird. Dann macht sie die mathematische Beschreibung zwischen A_i und B_i **unbrauchbar** für Angriffe.

▼ 180. ★★ Was leistet MixColumns, und was ist die Kombination mit ShiftRows?

MixColumns sorgt dafür, dass **jedes der vier Bytes einer Spalte alle anderen Bytes der Spalte beeinflusst**, und ist **DAS ausschlaggebende Diffusionselement im AES** (Lawineneffekt). Durch die **Kombination aus ShiftRows und MixColumns** hängt **nach nur ZWEI Runden jedes Byte der Zustandsmatrix von allen 16 Bytes des Klartexts ab**.

▼ 181. ★★ Vergleichen Sie die Diffusionsgeschwindigkeit von DES und AES.

DES: volle Diffusion nach **5 Runden** (von 16). **AES:** nach **2 Runden** (von 10/12/14).

▼ 182. ★★ Welche Operationen der AES-Diffusionsschicht sind linear?

Beide — ShiftRows und MixColumns sind **lineare Operationen**. Die **einzige Nichtlinearität** im AES steckt in der **S-Box**.

▼ 183. ★★★ Nennen Sie die sechs Betriebsmodi.

1. **ECB** — Electronic Codebook · 2. **CBC** — Cipher Block Chaining ·
2. **OFB** — Output Feedback · 4. **CFB** — Cipher Feedback ·
3. **CTR** — Counter · 6. **GCM** — Galois Counter

▼ 184. ★★ Nennen Sie Vor- und Nachteile des ECB-Modus.

Vorteile: 1. Einfachheit · 2. **keine Synchronisation** der Blöcke nötig · 3. **Bitfehler wirken sich nur auf den betroffenen Block aus** · 4. **hohe Geschwindigkeit durch Parallelisierung**
Nachteile: 1. **deterministisch** · 2. Angreifer erkennt, **ob dieselbe Nachricht zweimal gesendet** wurde → **Substitutionsangriff** · 3. **keine Authentifizierung** · 4. **keine Verdeckung von Mustern**

▼ 185. ★★ Definieren Sie „deterministische Verschlüsselung“ und erklären Sie den Namen ECB.

Eine Verschlüsselung ist **deterministisch**, wenn **gleiche Klartexte auf gleiche Chiffre abgebildet** werden — **vorausgesetzt, der Schlüssel bleibt unverändert**. Da jeder Eingangsblock auf einen **festen, bestimmten Ausgangswert** abgebildet wird, kann das Verfahren als **Codebuch** betrachtet werden — **daher der Name**.

▼ 186. ★★ Wie erreicht man eine probabilistische Verschlüsselung?

Es müssen **zufällige Werte in die Verschlüsselung eingehen**, meist in Form eines **Initialisierungsvektors (IV)**. Formal: $e_k(x_1, r_1) = y_1$ und $e_k(x_1, r_2) = y_2$ mit $y_1 \neq y_2$ — gleicher Klartext, verschiedene Chiffre.

▼ 187. ★★ Wie funktioniert CBC, und welche Rolle spielt der IV?

Verkettung der Blöcke: y_i hängt **nicht nur von x_i , sondern von allen vorherigen Klartextblöcken** ab. Da es für x_1 **keinen vorausgehenden Chiffreblock** gibt, **übernimmt der IV diese Aufgabe** und macht die Verschlüsselung **nichtdeterministisch**. Der IV **wird nicht geheim gehalten** und **sollte eine Nonce** (Number only used once) sein.

$$y_1 = e_k(x_1 \oplus IV), \quad y_i = e_k(x_i \oplus y_{i-1})$$

▼ 188. ★★ Wann ist CBC tatsächlich probabilistisch?

Wenn für JEDE neue Verschlüsselung ein NEUER ZUFÄLLIGER IV gewählt wird — dieser muss **nicht geheim** gehalten werden. Die Sicherheit hängt von der **korrekten Verwendung des IV** ab: **zufällig und einzigartig pro Nachricht**.

▼ 189. ★ Was könnte eine Nonce sein?

1. „Einfacher“ Zähler · 2. Zufallszahl · 3. Zusammensetzung: **ID_A || ID_B || time** Die Nonce **muss selbst nicht zufällig sein**; sie bewirkt aber, dass sich das „Innere“ der Verschlüsselung völlig anders verhält.

▼ 190. ★★★ Grenzen Sie OFB und CFB voneinander ab.

- **OFB**: Rückkopplung der **AUSGANGSBITS der Blockchiffre** auf deren Eingang → der **Schlüsselstrom hängt WEDER vom Klar- NOCH vom Geheimtext ab** und ist **vorberechenbar**
- **CFB**: Rückkopplung des **CHIFFRATS** auf den Eingang der Blockchiffre → Schlüsselstrom hängt vom Chifftrat ab, **nicht vorberechenbar**

Beide: Verwendung einer Blockchiffre zur Konstruktion einer **Stromchiffre**, IV macht sie **nichtdeterministisch, kein Padding** nötig.

Block 6 — Betriebsmodi (Fortsetzung), DHKE, RSA, Hashing, TOR (Fragen 191–235)

▼ 191. ★★ Warum muss auf der Empfängerseite bei OFB die Blockchiffre nicht im Entschlüsselungsmodus arbeiten?

Weil OFB **eine Stromchiffre** ist — **Ver- und Entschlüsselung sind genau die gleiche Operation** (XOR mit dem Schlüsselstrom). Man braucht **nur die Verschlüsselungsrichtung** $e()$, nie $e^{-1}()$. Gleiches gilt für CFB und CTR.

▼ 192. ★ Nennen Sie die vier Nachteile von OFB und CFB.

1. **Keine Verschleierung von Mustern** · 2. **Keine Integritätssicherung** · 3. **Verlust der Synchronisation zwischen Sender und Empfänger** · 4. **Potenzielles Problem bei wiederholter Nutzung des gleichen Schlüssels**

▼ 193. ★★ Wie funktioniert der CTR-Modus?

Verwendung einer Blockchiffre zur Konstruktion einer Stromchiffre, wobei **den Eingang der Blockchiffre ein ZÄHLER bildet**. Der String (**IV || CTR**) **muss nicht geheim gehalten werden**; CTR kann ein **einfacher Zähler** oder eine komplexere Funktion wie ein **LFSR mit maximaler Länge** sein.

▼ 194. ★★★ Warum darf derselbe Zählerwert nie zweimal verwendet werden?

Sonst **kann ein Angreifer den Schlüsselstromblock berechnen, wenn er einen der beiden Klartexte kennt**, und damit die anderen Chifftrate entschlüsseln. Formal: $y_1 \oplus y_2 = (x_1 \oplus s) \oplus (x_2 \oplus s) = x_1 \oplus x_2$ — der Schlüsselstrom fällt heraus („**Two-Time-Pad**“). Derselbe Grund, warum ein OTP-Schlüssel nur einmal genutzt werden darf.

▼ 195. ★★ Welche Modi brauchen Padding und welche nicht?

Padding nötig: ECB und CBC (Klartextlänge muss ein Vielfaches der Blockgröße sein). **Kein Padding: OFB, CFB, CTR** (Stromchiffren-Verhalten). Padding-Methode laut Folie: **ein einzelnes 1-Bit gefolgt von 0-Bits**.

▼ 196. ★★ Welcher Betriebsmodus liefert als einziger Integritätssicherung?

GCM (Galois Counter Mode) = **CTR + Authentifizierung über $GF(2^{128})$** → **AEAD**. Alle anderen fünf Modi bieten **keine Integritätssicherung**.

▼ 197. ★ Welche Modi sind parallelisierbar?

Verschlüsselung parallel: ECB, CTR, GCM. **Nicht parallel:** CBC (Kette), OFB, CFB. **Entschlüsselung parallel:** ECB, CBC, CFB, CTR, GCM (nicht OFB).

▼ 198. ★ Beschreiben Sie das Grundproblem, das DHKE löst.

Das **alte Problem**: Der **Schlüssel muss auf beiden Seiten vorhanden sein** — aber wie tauscht man ihn über einen **unsicheren Kanal** aus?

▼ 199. ★★★ Beschreiben Sie das DHKE-Protokoll in vier Set-up-Schritten und dem Ablauf.

Set-up: 1. Wähle eine **große Primzahl p** · 2. Wähle **$\alpha \in \{2, \dots, p-2\}$** · 3. **Veröffentliche p und α** · 4. Jeder Teilnehmer wählt einen **geheimen Teil a bzw. $b \in \{2, \dots, p-2\}$**

Ablauf: Alice sendet $A = \alpha^a \bmod p$, Bob sendet $B = \alpha^b \bmod p$. Alice: $k = B^a \bmod p$ · Bob: $k = A^b \bmod p$ → beide erhalten **$k = \alpha^{(ab)} \bmod p$** .

▼ 200. ★★ Was ist die wesentliche Idee hinter DHKE?

Dass das **Potenzieren in $\mathbb{Z}_p$ mit p prim eine EINWEGFUNKTION*** darstellt und dass die **Exponentiation KOMMUTATIV** ist:

$$k = (\alpha^x)^y = (\alpha^y)^x \bmod p$$

▼ 201. ★ Rechnen Sie DHKE mit $p = 29$, $\alpha = 2$, $a = 5$, $b = 12$ durch.

$A = 2^5 = 32 \equiv 3 \bmod 29$ · $B = 2^{12} \equiv 7 \bmod 29$ Alice: $k = 7^5 \bmod 29 = 16$ · Bob: $k = 3^{12} \bmod 29 = 16$ ✓

▼ 202. ★★★ Formulieren Sie das Diskrete Logarithmusproblem.

Gegeben sind die **endliche zyklische Gruppe $\mathbb{Z}_p^*$** mit der **Ordnung $p - 1$** , ein **primitives Element $\alpha \in \mathbb{Z}_p^*$** und ein **weiteres Element $\beta \in \mathbb{Z}_p^*$** . Das DLP besteht darin, **eine ganze Zahl x im Bereich $1 \leq x \leq p - 1$ zu finden, sodass $\alpha^x \equiv \beta \bmod p$ gilt**.

▼ 203. ★★ Welche Richtung ist einfach, welche schwer?

Einfach: $\alpha^x = \beta \bmod p$ (potenzieren). **Schwer:** $x = \log_\alpha(\beta) \bmod p$ (diskreter Logarithmus).

▼ 204. ★★ Was leistet DHKE NICHT?

Keine Authentifizierung → anfällig für **Man-in-the-Middle-Angriffe**. In der Praxis wird DHKE deshalb immer mit **Signaturen/Zertifikaten** kombiniert.

▼ 205. ★★ Was ist die Hauptanwendung von RSA?

Der **sichere Austausch eines Schlüssels (Schlüsseltransport)**, welcher dann **für eine symmetrische Chiffre** verwendet wird — **hybride Verschlüsselung**.

▼ 206. ★★ Geben Sie die RSA-Formeln für Ver- und Entschlüsselung an.

$$y = e_{k_{pub}}(x) \equiv x^e \mod n \qquad x = d_{k_{pri}}(y) \equiv y^d \mod n$$

e = Verschlüsselungs-/öffentlicher Exponent · **d** = Entschlüsselungs-/privater Exponent.

▼ 207. ★★★ Nennen Sie die fünf Schritte der RSA-Schlüsselerzeugung.

1. Wähle zwei große Primzahlen **p** und **q**
2. **n** = **p** · **q**
3. **φ(n)** = (**p** - 1)(**q** - 1)
4. Wähle **e** ∈ {1, ..., **φ(n)** - 1} mit ggT(**e**, **φ(n)**) = 1
5. Berechne **d** mit **d** · **e** ≡ 1 mod **φ(n)**

▼ 208. ★★ Wozu dient die Bedingung ggT(**e**, **φ(n)**) = 1?

Sie stellt sicher, dass **die Inverse von e existiert** — und damit, dass es **den privaten Schlüssel d überhaupt gibt**.

▼ 209. ★ Rechnen Sie RSA mit **p = 3** und **q = 11** durch (**e = 3**).

n = 33 · **φ(n)** = 2 · 10 = 20 · **e** = 3 (ggT(3, 20) = 1 ✓) · **d** = 7 (3 · 7 = 21 ≡ 1 mod 20 ✓) **Verschlüsseln x = 4**:
y = 4³ mod 33 = 64 mod 33 = **31** **Entschlüsseln**: **x** = 31⁷ mod 33 = **4** ✓

▼ 210. ★★★ Worauf beruht die Sicherheit von RSA?

Auf dem **Faktorisierungsproblem ganzer Zahlen** — das ist die **Einwegfunktion**: Die **Multiplikation zweier großer Primzahlen ist rechnerisch einfach**, der **umgekehrte Prozess der Faktorisierung** des Produkts zurück in seine zwei Primfaktoren **sehr schwierig**.

▼ 211. ★ Warum wäre die Faktorisierung von **n** fatal?

Wer **n** = **p** · **q** zerlegt, berechnet sofort **φ(n) = (p-1)(q-1)** und daraus **d = e⁻¹ mod φ(n)** — der private Schlüssel ist gebrochen.

▼ 212. ★ Welche Mindestgröße nennen die Folien für die RSA-Parameter?

Mindestens 1024 Bit. (Anmerkung: aktuelle BSI-Empfehlungen liegen bei ≥ 3000 Bit; 1024 Bit gilt heute als unsicher.)

▼ 213. ★ Warum sollten für ein gegebenes n sehr viele Schlüsselpaare existieren?

Weil andernfalls ein **Brute-Force-Angriff** durchgeführt werden könnte.

▼ 214. ★★ Versteckt sich im RSA neben der Faktorisierung noch ein anderes Problem?

Ja — das DLP. Siehe die Gleichungen $y \equiv x^e \bmod n$: Aus y und e auf x zu schließen ist ein modulares Wurzelproblem; aus x und y auf e zu schließen ein diskreter Logarithmus.

▼ 215. ★★ Grenzen Sie DHKE und RSA gegeneinander ab.

- **DHKE: Schlüsselvereinbarung** — beide erzeugen k gemeinsam; basiert auf dem **DLP**
- **RSA: Verschlüsselung/Schlüsseltransport** — einer wählt k und sendet ihn; basiert auf dem **Faktorisierungsproblem**; ermöglicht zusätzlich **Signaturen**

▼ 216. ★★ Was ist ein Hash-Wert, und hat eine Hash-Funktion einen Schlüssel?

Eine aus einer Nachricht berechnete **Bitfolge Fester Länge** — der **Fingerabdruck** bzw. **Repräsentant der Nachricht**. Hash-Funktionen haben **KEINEN Schlüssel**. Einsatz: **digitale Signaturen, Prüfsummen (MAC), Schlüsselableitung**.

▼ 217. ★ Verschlüsseln Hash-Funktionen Daten?

Nein — Hash-Funktionen ver- oder entschlüsseln Daten **NICHT**.

▼ 218. ★★ Warum braucht man Hash-Funktionen für digitale Signaturen?

Weil bei RSA- und DLP-basierten Signaturen die **Größe des signierbaren Klartexts beschränkt** ist. Statt die Nachricht in Blöcke zu zerlegen und jeden einzeln zu signieren, erzeugt man **eine einzelne kurze Signatur für eine Nachricht beliebiger Länge** über den **Fingerabdruck**.

▼ 219. ★★★ Nennen Sie die drei Probleme des blockweisen Signierens.

1. **Hoher Rechenaufwand** — digitale Signaturen sind asymmetrisch und damit rechenintensiv
2. **Nachrichten-Overhead** — **verdoppelt die Bitlänge** der Übertragung (Nachricht + gleich lange Signatur)
3. **Sicherheitsprobleme** — Möglichkeit, **Nachrichten und Signaturen umzuordnen oder zu entfernen**

▼ 220. ★ Was ist Eingang der Signaturerstellung und -verifikation?

Der Hash-Wert z — NICHT die eigentliche Nachricht. Der Hash-Wert **repräsentiert die Nachricht** und heißt deshalb **Fingerabdruck**.

▼ 221. ★★ Nennen Sie die vier Anforderungen an das Eingang-Ausgang-Verhalten einer Hash-Funktion.

1. Sehr schnell zu berechnen
2. Ausgangswert hat unabhängig von der Eingangslänge eine FESTE Länge
3. Der Fingerabdruck hängt von ALLEN Eingangsbits ab
4. Kleine Änderungen im Eingang führen zu einem vollständig unterschiedlichen Fingerabdruck

▼ 222. ★★★ Nennen Sie die drei Sicherheitseigenschaften von Hash-Funktionen (deutsch und englisch).

1. Urbildresistenz (Einwegeigenschaft) — *preimage resistance (one-wayness)*
2. Schwache Kollisionsresistenz (zweite Urbildresistenz) — *second preimage resistance (weak collision resistance)*
3. Starke Kollisionsresistenz (Kollisionsresistenz) — *collision resistance (strong collision resistance)*

▼ 223. ★★★ Grenzen Sie schwache und starke Kollisionsresistenz ab.

- **Schwach:** x_1 IST GEGEBEN, man sucht ein passendes x_2 mit $h(x_1) = h(x_2) \rightarrow$ ein Freiheitsgrad
- **Stark:** SOWOHL x_1 ALS AUCH x_2 frei wählbar $\rightarrow$ zwei Freiheitsgrade, deshalb deutlich schwerer zu erfüllen

Aufwand: 2^n vs. $2^{(n/2)}$.

▼ 224. ★★ Warum kann keine Hash-Funktion kollisionsfrei sein?

Weil jede Hash-Funktion eine **feste Ausgangslänge von n Bit** hat $\rightarrow$ **genau 2^n mögliche Ausgangswerte** , aber **unendlich viele mögliche Eingangswerte** . Nach dem **Schubfachprinzip** müssen zwangsläufig mehrere Eingangswerte denselben Ausgangswert erzeugen. Man muss deshalb dafür sorgen, dass Kollisionen **in der Praxis nicht erzeugbar** sind.

▼ 225. ★★ Warum ist die schwache Kollisionsresistenz für Signaturen kritisch?

Findet ein Angreifer **eine zweite Nachricht mit demselben Hash-Wert** , hat diese **den gleichen Signatur- und Verifikationswert** wie die erste — die Signatur der ersten Nachricht ist damit auch für die untergeschobene zweite gültig.

▼ 226. ★★★ Wie viele Nachrichten muss man für eine Kollision hashen?

Näherungsweise

$$\sqrt{2^n} = 2^{n/2}$$

(Geburtstagsparadoxon). Da 2^{40} Hashwerte heute leicht durchprobiert werden können, haben alle Hash-Funktionen eine **Ausgangsbreite von mindestens 128 Bit** .

▼ 227. ★ Wie viele Versuche braucht man bei einer 160-Bit-Hash-Funktion für eine Kollision?

$2^{(160/2)} = 2^{80} \approx 1,2 \cdot 10^{24}$ — deshalb gilt SHA-1 heute als praktisch gebrochen.

▼ 228. ★★★ Nennen Sie die sechs Eigenschaften einer Hash-Funktion.

1. Beliebige Eingangslänge · 2. Feste Ausgangslänge · 3. Effizienz ·
 2. Einwegeigenschaft · 5. Schwache Kollisionsresistenz · 6. Starke Kollisionsresistenz (1–3 funktional, 4–6 sicherheitsbezogen)

▼ 229. ★★★ Beschreiben Sie den TOR-Circuit und die Wissensverteilung.

Entry Node (Guard) → Middle Node → Exit Node.

Knoten	kennt Nutzer-IP	kennt Ziel
Entry (Guard)	ja	nein
Middle	nein	nein
Exit	nein	ja

Kein einzelner Knoten kennt Absender UND Ziel gleichzeitig.

▼ 230. ★★★ Welche Algorithmen verwendet TOR wofür?

RSA nur für den sicheren Austausch der SITZUNGSSCHLÜSSEL beim Circuit-Aufbau; die **eigentliche Datenverschlüsselung im Circuit erfolgt mit einem symmetrischen Algorithmus wie AES**. Jeder Node besitzt ein Schlüsselpaar; der **öffentliche Schlüssel steht im Konsensus-Dokument**, das der Browser herunterlädt.

▼ 231. ★★★ Geben Sie die Verschachtelung der Verschlüsselung auf dem Hinweg an.

Der Client verschlüsselt **beginnend mit R_3** (von innen nach außen):

$$C_3 = E_{K_3}(M), \quad C_2 = E_{K_2}(C_3), \quad C_1 = E_{K_1}(C_2) = E_{K_1}(E_{K_2}(E_{K_3}(M)))$$

Jedes Relay entfernt seine Schicht: $R_1 \rightarrow D_{\{K_1\}}$, $R_2 \rightarrow D_{\{K_2\}}$, $R_3 \rightarrow D_{\{K_3\}}$, sodass

$$M = D_{K_3}(D_{K_2}(D_{K_1}(C_1)))$$

▼ 232. ★★★ Was passiert zwischen Exit Node und Zielservers?

R_3 sendet die entschlüsselte Nachricht M an das Ziel im OFFENEN Internet — TOR verschlüsselt diese Strecke **nicht**. Ohne zusätzliches **HTTPS/TLS** sieht der Exit Node den **Klartext**. Das ist die bekannteste TOR-Schwachstelle.

▼ 233. ★★★ Wie funktioniert der Rückweg in TOR?

Es wird **derselbe Circuit in umgekehrter Reihenfolge** genutzt; **dieselben Sitzungsschlüssel K_1 , K_2 , K_3 gelten für Hin- und Rückweg**. Jeder Knoten legt eine Schicht **hinzu**; **nur der TOR-Browser kann die Antwort vollständig entschlüsseln**, da er alle Sitzungsschlüssel kennt. **Keine asymmetrische Verschlüsselung auf dem Rückweg**.

▼ 234. ★ Wie ordnet ein Node Pakete zu Verbindungen zu?

Über eine **Circuit-ID**, die jedem Paket zugewiesen wird — so kann der Knoten mehrere gleichzeitige Verbindungen unterscheiden, **ohne die Endpunkte zu kennen**.

▼ 235. ★★★ Warum gibt es den Guard Node, wie lange bleibt er gleich, und welche drei Gründe nennt die Vorlesung?

Der Guard Node ist der **erste Node im Circuit** und **kennt die echte IP-Adresse des Benutzers**. Der Browser bleibt **2–3 Monate oder länger** mit **demselden** Guard Node verbunden. **Drei Gründe:** 1. **Einschränkung der Sichtbarkeit der IP-Adresse** · 2. **verbesserte Stabilität** · 3. **Schutz vor Sybil- und Traffic-Correlation-Angriffen**. **Logik:** Bei ständig wechselnden Entry Nodes würde die Wahrscheinlichkeit, irgendwann einen böartigen zu erwischen, gegen 100 % gehen. Mit einem festen Guard tauscht man „oft ein bisschen Risiko“ gegen „selten ein großes Risiko“.

TEIL G — KLAUSUR-SPICKZETTEL

Alles, was man auf **eine Seite** bringen muss.

G.1 Die Aufzählungen, die sicher drankommen

Thema	Merkstruktur
Schutzziele	3 Haupt: Vertraulichkeit, Integrität, Verfügbarkeit · 5 Neben: Authentizität/Authentifikation, Autorisation, Verbindlichkeit, Verhinderung/Entdeckung/Protokollierung, Anonymisierung/Pseudonymisierung
Begriffsschachtelung	Cyber-Sicherheit $\supset$ Informationssicherheit $\supset$ IT-Sicherheit
3 Cyber-Security-Begriffe	Sicherheitslücke · Angriffsfläche · Angriffsvektor
4 Schwachstellenkategorien	Anforderungs- · Design- · Implementierungs- · Installations-/Administrationsfehler
Angriffsachsen	passiv $\leftrightarrow$ aktiv · nicht-zielgerichtet $\leftrightarrow$ zielgerichtet · Außen- $\leftrightarrow$ Innentäter
GRC	G overnance (steuern) · R isk (Risiken) · C ompliance (nachweisen)
3 Säulen der IT-Security	Regulatorische Vorgaben · Technische Maßnahmen · Organisatorische Prozesse
3 Praxis-Ziele GRC	Steuerbarkeit · Anpassungsfähigkeit · Nachweisbarkeit
6 Governance-Kernelemente	Richtlinien · Steuerung/Verantwortlichkeiten · Incident Response · Risikomanagement · Awareness · Monitoring/Audits/Reporting
4 Schritte Risikomanagement	Risikoanalyse $\rightarrow$ Risikosteuerung $\rightarrow$ Risikomonitoring $\rightarrow$ Risikoreporting
4 Risikostrategien	akzeptieren · vermeiden · vermindern · übertragen
PDCA	P lan · D o (<i>Pilot!</i>) · C heck · A ct (<i>Rollout</i>)
SDCA	S tandardize · D o · C heck · A ct
6 IR-Phasen	Vorbereitung $\rightarrow$ Erkennung $\rightarrow$ Eindämmung $\rightarrow$ Beseitigung $\rightarrow$ Wiederherstellung $\rightarrow$ Lessons Learned
2 IR-Rahmenwerke	ISO/IEC 27035 · NIST SP 800-61
6 Betriebsmodi	ECB · CBC · OFB · CFB · CTR · GCM
3 Zufallsgeneratoren	PRNG · TRNG · CSPRNG
3 Hash-Sicherheitseigenschaften	Urbild- · schwache Kollisions- · starke Kollisionsresistenz
6 Hash-Eigenschaften	bel. Eingang · feste Ausgabe · Effizienz · Einweg · schwache · starke Kollisionsresistenz
3 TOR-Knoten	Entry (Guard) · Middle · Exit

G.2 Formelsammlung ★★

Klassische Chiffren (alle in $\mathbb{Z}_{26}$):

Chiffre	Verschlüsselung	Entschlüsselung	Bedingung	K
Verschiebe (Cäsar)	$y \equiv x + k \bmod 26$	$x \equiv y - k \bmod 26$	—	26
Multiplikativ	$y \equiv x \cdot k \bmod 26$	$x \equiv y \cdot k^{-1} \bmod 26$	$\text{ggT}(k, 26) = 1$	12
Affin	$y \equiv a \cdot x + b \bmod 26$	$x \equiv a^{-1}(y - b) \bmod 26$	$\text{ggT}(a, 26) = 1$	312
Vigenère	$y \equiv x + k_i \bmod 26$	$x \equiv y - k_i \bmod 26$	k zyklisch	26^m

Zentrale Regel: $\text{ggT}(a, m) = 1 \iff a^{-1} \bmod m$ existiert

Inversen mod 26: $1 \rightarrow 1 \cdot 3 \rightarrow 9 \cdot 5 \rightarrow 21 \cdot 7 \rightarrow 15 \cdot 9 \rightarrow 3 \cdot 11 \rightarrow 19 \cdot 15 \rightarrow 7 \cdot 17 \rightarrow 23 \cdot 19 \rightarrow 11 \cdot 21 \rightarrow 5 \cdot 23 \rightarrow 17 \cdot 25 \rightarrow 25$

Alphabet: a=0, b=1, ..., m=12, n=13, ..., z=25

Stromchiffre:

- $e(x_i) = y_i \equiv x_i + s_i \bmod 2$ $d(y_i) = x_i \equiv y_i + s_i \bmod 2$
- Addition mod 2 = **XOR** · Beweis: $y_i + s_i = x_i + 2s_i = x_i + 0 = x_i$

Feistel (DES):

$$L_i = R_{i-1} \quad R_i = L_{i-1} \oplus f(R_{i-1}, k_i)$$

CBC:

$$y_1 = e_k(x_1 \oplus IV) \quad y_i = e_k(x_i \oplus y_{i-1})$$

DHKE:

$$A = \alpha^a \bmod p \quad B = \alpha^b \bmod p \quad k = B^a = A^b = \alpha^{ab} \bmod p$$

DLP: $\alpha^x \equiv \beta \bmod p$ — x finden ist schwer

RSA:

$$n = p \cdot q \quad \varphi(n) = (p-1)(q-1) \quad \text{gcd}(e, \varphi(n)) = 1 \quad d \cdot e \equiv 1 \bmod \varphi(n)$$

$$y \equiv x^e \bmod n \quad x \equiv y^d \bmod n$$

Hashing (Geburtstagsparadoxon):

$$\text{Kollisionsaufwand} \approx \sqrt{2^n} = 2^{n/2}$$

TOR:

$$C_1 = E_{K_1}(E_{K_2}(E_{K_3}(M))) \quad M = D_{K_3}(D_{K_2}(D_{K_1}(C_1)))$$

AES: # Unterschlüssel = # Runden + 1

G.3 Die Zahlen, die man wissen muss ★★☆☆

Zahl	Bedeutung
3 + 5	Haupt- und Nebenziele der IT-Sicherheit
4	Schwachstellenkategorien; Schritte im Risikomanagementprozess; Phasen PDCA/SDCA
6	IR-Phasen; Betriebsmodi; Hash-Eigenschaften; Governance-Kernelemente
26 / 12 / 312	Schlüsselsräume Cäsar / multiplikativ / affin
DES: 64 / 56 / 16 / 48	Blockgröße / effektive Schlüssellänge / Runden / Rundenschlüssellänge
DES: 8 S-Boxen, 6→4 Bit	unterschiedlich aufgebaut, einzige Nichtlinearität
DES: E-Box 32→48, P-Box 32→32	Diffusionselemente
DES: 5	Runden bis zur vollen Diffusion
DES: 14 von 16	Runden, in denen ein Schlüsselbit im Schnitt vorkommt
AES: 128	Blockgröße (fest)
AES: 128/192/256 → 10/12/14 Runden → 11/13/15 Unterschlüssel	★ auswendig
AES: 16 identische S-Boxen	konstruiert aus Inversion in $GF(2^8)$ + affiner Abbildung
AES: 2	Runden bis zur vollen Diffusion
Hash: ≥ 128 Bit	Mindest-Ausgangsbreite (weil 2^{40} leicht durchprobierbar)
RSA: ≥ 1024 Bit	Mindestparametergröße laut Folie
TOR: 3 Knoten, 2–3 Monate	Circuit-Länge, Guard-Node-Lebensdauer
Deep Web: ca. 90 %	Anteil am Internet
Oktober 2024	Inkrafttreten des IT-Sicherheitsgesetzes für KRITIS (laut Folie)

G.4 Die 12 klassischen Fallen

#	Falle	Richtig
1	„Ziel ist absolute Sicherheit“	Risikoreduktion auf ein angemessenes Maß
2	Authentifizierung = Autorisierung	Wer bist du? vs. Was darfst du?
3	Deep Web = Dark Net	Deep Web = 90 % , legal; Dark Net = kleine Teilmenge, TOR
4	Malware kann keine „gute Software“ sein	Doch — Qualität $\perp$ Absicht
5	Safety = Security	Safety schützt Umwelt vor System , Security System vor Umwelt
6	PDCA „Do“ = Rollout	Do = Pilot/Test im Kleinen ; Rollout in Act
7	Compliance = Sicherheit	Erfüllung $\neq$ Wirksamkeit ; Komfortzonen-Falle
8	IR = IT-Forensik	IR = organisatorischer Rahmen , Forensik = technische Spurenanalyse
9	MITRE ist eine Abkürzung	Eigenname ; ATT&CK ist die Abkürzung
1 0	DES hat 64 Bit Schlüssel	56 Bit effektiv (8 Paritätsbits)
1 1	Starke Kollisionsresistenz ist leichter zu brechen	Ja! <i>stark/schwach</i> bezieht sich auf die Anforderung , nicht den Angreifer
1 2	TOR verschlüsselt bis zum Ziel	Nein — ab dem Exit Node Klartext ohne HTTPS

G.5 Antwortbausteine für Transferfragen

„**Warum ist X sicher/unsicher?**“ → immer über die drei Ebenen argumentieren: **(1) Schlüsselraum** (brute-forcebar?) · **(2) Struktur** (linear? deterministisch? Häufigkeitsanalyse möglich?) · **(3) Verwendung** (IV/Nonce wiederverwendet? Schlüssel zu kurz?)

„**Welches Schutzziel wird verletzt?**“ → passiv = **Vertraulichkeit**; Manipulation = **Integrität**; DoS = **Verfügbarkeit**; Identitätsdiebstahl = **Authentizität**; Abstreiten = **Verbindlichkeit**

„**Ist das technisch oder organisatorisch?**“ → Die drei Säulen: **regulatorisch** (Gesetz/Norm) · **technisch** (Verschlüsselung, Patch, Segmentierung) · **organisatorisch** (Richtlinie, Schulung, Notfallmanagement)

„**Was tun bei einem Vorfall?**“ → immer die **6 IR-Phasen** in Reihenfolge, mit den jeweils 2–3 wichtigsten Maßnahmen. Nie Recovery vor Eradication!

„**Warum PDCA/SDCA?**“ → *Risikomanagement = das WAS* · PDCA = *wie verbessern* · SDCA = *wie stabilisieren*.

Quellenverzeichnis

Alle Inhalte stammen aus dem ZIP-Archiv **WDS224 - IT-Security (INA).zip**, Ordner **Prüfungsrelevante Folien** :

Datei	Seiten	Foliennummerierung im Dokument
Kapitel_02_1_Einführung_Exam.pdf	95	„x / 160“
Kapitel_02_3_GRC_Exam.pdf	99	„x / 155“
Kapitel_02_4_Incidence_Response_Exam.pdf	54	„x / 132“
Kapitel_03_Grundlagen_Krypto_Exam.pdf	11	„x / 88“
Kapitel_04_Klassische_Chiffren_Exam.pdf	41	„x / 116“
Kapitel_05_Stromchiffren_Exam.pdf	39	„x / 133“
Kapitel_06_DES_Exam.pdf	50	„x / 137“
Kapitel_07_AES_Exam.pdf	27	„x / 154“
Kapitel_08_Betriebsmodis_Exam.pdf	45	„x / 83“
Kapitel_10_DHKE_Exam.pdf	11	„x / 75“
Kapitel_11_RSA_Exam.pdf	15	„x / 45“
Kapitel_13_Hashing_Exam.pdf	29	„x / 100“
TOR_Exam.pdf	71	„x / 180“

Die abweichende Foliennummerierung ergibt sich daraus, dass die PDFs Beamer-Overlays zusammengefasst enthalten: Die Gesamtzahl bezieht sich auf alle Overlay-Schritte, die Seitenzahl auf die zusammengefassten Seiten.

Anmerkungen zur Vollständigkeit:

- Die Textextraktion aus den LaTeX-Beamer-PDFs enthält Wasserzeichen-Fragmente („DRAFT“ als einzelne Buchstaben T/A/F/R/D), die hier entfernt wurden.
- Rein grafische Folien (Diagramme, Tabellenbilder der DES-S-Boxen und AES-Zustandsmatrizen, Pyramid-of-Pain-Grafiken der Ebenen 1–5) liegen nur als Bild vor und wurden aus dem Kontext und dem Standardwissen der jeweiligen Verfahren rekonstruiert. Solche Ergänzungen sind im Text als solche gekennzeichnet (z. B. die Ebenen 1–5 der Pyramid of Pain, die GCM-Erläuterung, die Trivium-Eckdaten).
- Sachliche Abweichungen zwischen Folien und aktuellem Stand der Technik (RSA-Schlüssellänge, Padding-Bedarf bei CBC, CTR deterministisch vs. probabilistisch) sind mit ⚠ markiert und jeweils begründet.

Ende Modul 11 — IT-Security (INA) · 13 Kapitel · 235 Selbsttestfragen